

MỤC LỤC

DANH MỤC KÝ HIỆU VÀ TỪ VIẾT TẮT	iv
DANH MỤC HÌNH VẼ	vi
DANH MỤC BẢNG.....	viii
MỞ ĐẦU	ix
CHƯƠNG 1. TỔNG QUAN VỀ ĐIỆN TOÁN Đám Mây VÀ BẢO MẬT TRONG ĐIỆN TOÁN Đám Mây	1
1.1. Lịch sử ra đời và khái niệm của điện toán đám mây	1
1.1.1. Các mô hình triển khai trong điện toán đám mây.....	3
1.1.2. Các mô hình dịch vụ trong điện toán đám mây.....	8
1.1.3. Ưu điểm và nhược điểm của điện toán đám mây	11
1.2. Các mối đe dọa rủi ro an toàn trong điện toán đám mây	12
1.2.1. Rủi ro từ kiến trúc.....	12
1.2.2. Rủi ro từ quản lý truy cập và xác thực	14
1.2.3. Rủi ro từ dữ liệu lưu trữ và truyền tải	16
1.2.4. Rủi ro từ các dịch vụ điện toán đám mây.....	17
1.2.4.1. Rủi ro trong mô hình dịch vụ SaaS.....	17
1.2.4.2. Rủi ro trong mô hình dịch vụ PaaS.....	18
1.2.4.3. Rủi ro trong mô hình dịch vụ IaaS	20
1.3. Kết luận chương 1	21
CHƯƠNG 2. GIẢI PHÁP ĐẢM BẢO AN TOÀN DỊCH VỤ TRONG ĐIỆN TOÁN Đám Mây	23
2.1. Giải pháp đảm bảo an toàn dịch vụ điện toán đám mây	23
2.1.1. Giải pháp đảm bảo kiến trúc đám mây	23
2.1.2. Giải pháp quản lý truy cập và xác thực.....	24
2.1.3. Giải pháp bảo vệ dữ liệu lưu trữ và truyền tải.....	28
2.1.4. Giải pháp giám sát và phát hiện đe dọa.....	31
2.1.4.1. Thu thập dữ liệu nhật ký tập trung.....	32
2.1.4.2. Chuẩn hóa và làm giàu dữ liệu	35
2.1.4.3. Phân tích, tương quan sự kiện.....	36
2.1.4.4. Cảnh báo và Tự động hóa phản ứng.....	37
2.1.4.5. Lưu trữ, Hiển thị và Báo cáo	37
2.1.5. Giải pháp bảo mật cho từng loại dịch vụ đám mây	38
2.1.5.1. Giải pháp bảo mật cho dịch vụ SaaS	40
2.1.5.2. Giải pháp bảo mật cho dịch vụ PaaS	41
2.1.5.3. Giải pháp bảo mật cho dịch vụ IaaS	43
2.2. Trình bày mô hình doanh nghiệp đang sử dụng	49
2.3. Ưu, nhược điểm rủi ro bảo mật của mô hình	51
2.4. Kết luận chương 2	52
CHƯƠNG 3. TRIỂN KHAI THỬ NGHIỆM GIẢI PHÁP ĐẢM BẢO AN TOÀN DỊCH VỤ TRONG ĐIỆN TOÁN Đám Mây	54
3.1. Mô hình triển khai.....	54
3.1.1. Mục tiêu	54

3.1.2	<i>Nội dung chi tiết:</i>	54
3.2.	Mô tả mô hình triển khai	55
3.2.1	<i>Mô hình tổng quan</i>	55
3.2.1.1.	Vùng Internet (Internet Zone)	56
3.2.1.2.	Vùng Google Cloud Platform (GCP)	57
3.2.1.	<i>Cấu hình hạ tầng và môi trường triển khai</i>	59
3.2.2.1.	Project & API	59
3.2.2.2.	Mạng (VPC) và Subnet	60
3.2.2.3.	Firewall Rules (GCP Firewall)	61
3.2.2.4.	Google Cloud Armor (WAF & Rate-limit)	62
3.2.2.5.	Health check	63
3.2.2.6.	Load Balancer / Backend Service	64
3.2.2.7.	Compute Engine — VM Web Server (target)	66
3.2.2.8.	Compute Engine — VM Suricata IDS (collector)	68
3.2.2.9.	Packet Mirroring	70
3.2.2.10.	Cloud Logging	71
3.3.	Thực nghiệm đánh giá mô hình	72
3.3.1.	<i>Mục tiêu thực nghiệm</i>	72
3.3.2.	<i>Môi trường và cấu hình thử nghiệm</i>	73
3.3.3.	<i>Kịch bản thử nghiệm</i>	73
3.3.4.	<i>Minh họa thử nghiệm</i>	74
3.3.5.	<i>Kết quả và đánh giá</i>	78
3.3.6.	<i>Kết luận thực nghiệm</i>	79
3.4.	Kết luận chương 3	79
3.4.1.	<i>Hiệu quả chức năng</i>	79
3.4.2.	<i>Hạn chế và rủi ro còn tồn tại</i>	80
3.4.3.	<i>Kiến nghị thực tế</i>	80
3.4.4.	<i>Tổng kết</i>	81
KẾT LUẬN		82
TÀI LIỆU THAM KHẢO		85

DANH MỤC KÝ HIỆU VÀ TỪ VIẾT TẮT

STT	Từ viết tắt	Chú giải tiếng Anh	Chú giải tiếng Việt
1	CNTT		Công nghệ thông tin
2	ĐTĐM		Điện toán đám mây
3	DDoS	Distributed Denial of Service	Tấn công từ chối dịch vụ
4	IaaS	Infrastructure as a Service	Dịch vụ hạ tầng
5	PaaS	Platform as a Service	Nền tảng hướng dịch vụ
6	SaaS	Software as a Service	Phần mềm hướng dịch vụ
7	SOC	Security Operation Center	Trung tâm điều hành an ninh
8	NIST	National Institute of Standards and Technology	Viện Tiêu chuẩn và Công nghệ Quốc gia
9	MFA	Multi-Factor Authentication	Xác thực đa nhân tố
10	IAM	Identity and Access Management Security	Bảo mật quản lý danh tính và truy cập
11	CSP	Cloud Service Provider	Nhà cung cấp dịch vụ đám mây
12	API	Application Programming Interface	Giao diện lập trình ứng dụng
13	XSS	Cross Site Scripting	Tấn công xuyên trang web
14	AES	Advanced Encryption Standard	Tiêu chuẩn mã hóa nâng cao
15	OTP	Open Time Password	Mật khẩu dùng một lần
16	DES	Data Encryption Standard	Tiêu chuẩn mã hóa dữ liệu
17	SSO	Single Sign-On	Đăng nhập một lần
18	SAML	Security Assertion Markup Language	Ngôn ngữ đánh dấu khẳng định bảo mật
19	SIEM	Security Information and Event Management	Quản lý sự kiện và thông tin bảo mật
20	PCI-DSS	Payment Card Industry – Data Security Standard	Ngành công nghiệp thẻ thanh toán – Tiêu chuẩn bảo mật dữ liệu
21	HIPAA	Health Insurance Portability and Accountability Act	Đạo luật về khả năng chuyển đổi và trách nhiệm giải trình bảo hiểm y tế

22	OWASP	Open Web Application Security Project	Dự án bảo mật ứng dụng web mở
23	SOPs	Standard Operating Procedure	Quy trình vận hành tiêu chuẩn
24	CASB	Cloud Access Security Broker	Môi giới bảo mật truy cập đám mây
25	SSPM	SaaS Security Posture Management	Quản lý tư thế bảo mật SaaS
26	SAST	Static Application Security Testing	Kiểm tra bảo mật ứng dụng tĩnh
27	DAST	Dynamic Application Security Testing	Kiểm tra bảo mật ứng dụng động
28	WAF	Web Application Firewall	Tường lửa ứng dụng web
29	CWPP	Cloud Workload Protection Platform	Nền tảng Bảo vệ Khối lượng công việc Đám mây

DANH MỤC HÌNH VẼ

Hình 1.1. Mô hình tổng quát Cloud Computing.....	2
Hình 1.2: Mô hình triển khai điện toán đám mây.....	4
Hình 1.3: Private Cloud Model.....	5
Hình 1.4: Public Cloud Model.....	6
Hình 1.5: Community Cloud Model.....	7
Hình 1.6: Hybrid Cloud Model.....	8
Hình 1.7: Phần mềm hướng dịch vụ.....	9
Hình 1.8. Nền tảng hướng dịch vụ.....	10
Hình 1.9. Dịch vụ hạ tầng.....	11
Hình 1.10: Bare metal hypervisor (Type 1).....	13
Hình 1.11: Hosted hypervisor (Type 2).....	13
Hình 2.1: Kiến trúc Hypervisor (Type 1).....	23
Hình 2.2: Mô hình hoạt động SAML.....	28
Hình 2.3: Các kỹ thuật bảo mật dữ liệu phổ biến liên quan đến các thuộc tính bảo mật dữ liệu [13].....	31
Hình 2.4: Quy trình hoạt động của SIEM đám mây.....	32
Hình 2.5. Mô hình tổng quan doanh nghiệp đang sử dụng.....	49
Hình 3.1: Sơ đồ kiến trúc tổng thể hệ thống phòng thủ đa lớp trên nền tảng GCP.....	56
Hình 3.2: Tổng hợp các API cần bật.....	60
Hình 3.3: Cấu trúc mạng VPC và mạng con.....	61
Hình 3.4: Bảng firewall rules trong Console.....	62
Hình 3.5 : cấu hình Cloud Armor policy & rule list.....	63
Hình 3.6: Danh sách Health Checks gồm web-hc và hc-suricata.....	64
Hình 3.6 : Cấu hình của web-lb.....	65
Hình 3.7 : Cấu hình của ilb-suricata-collector.....	66
Hình 3.8: cấu hình VM web trong Console.....	67
Hình 3.9: đoạn mã cần thêm vào file cấu hình nginx.conf.....	67
Hình 3.11: bảng cấu hình VM IDS.....	68
Hình 3.12: Những mục cần thiết nhất phải bật cho file eve.log.....	69
Hình 3.13: Cấu hình Packet Mirroring policy pm-web-to-suricata.....	71
Hình 3.14: Những truy vấn có sẵn trong cloud logging.....	72

Hình 3.15: Giao diện cloud logging trong console.....	72
Hình 3.16: attacker tấn công và báo bị chặn SQLi.....	74
Hình 3.17: bản ghi log trong Cloud Logging ghi nhận request SQLi bị chặn bởi Cloud Armor.	75
Hình 3.19: bản ghi log trong Cloud Logging ghi nhận request XSS bị chặn bởi Cloud Armor.	76
Hình 3.20: attacker tấn công và báo bị chặn LFI.....	76
Hình 3.21 : bản ghi log trong Cloud Logging ghi nhận request LFI bị chặn bởi Cloud Armor.	77
Hình 3.22: Người dùng sử dụng lệnh hợp lệ	77
Hình 3.23: bản ghi log trong Cloud Logging ghi nhận request được đẩy vào suricata-eve.....	78

DANH MỤC BẢNG

Bảng 1.1: Các giải pháp bảo mật dữ liệu phổ biến chính theo đặc điểm của đám mây, vòng đời dữ liệu và thuộc tính bảo mật dữ liệu.....	29
Bảng 1.2: Phương thức thu thập dữ liệu chính	32
Bảng 3.1: chi tiết các rules firewall cần tạo.....	62
Bảng 3.2: tổng hợp cấu hình	73
Bảng 3.3: tổng hợp kết quả đánh giá và thực nghiệm	79

MỞ ĐẦU

1. Tính cấp thiết của đề án

1.1. Tình hình thực tế

Trong thời đại chuyển đổi số mạnh mẽ hiện nay, điện toán đám mây (Cloud Computing) đang trở thành nền tảng quan trọng trong việc triển khai các hệ thống công nghệ thông tin, hỗ trợ lưu trữ, xử lý và chia sẻ dữ liệu một cách linh hoạt, hiệu quả. Các dịch vụ điện toán đám mây như IaaS, PaaS, SaaS đang được sử dụng rộng rãi trong cả khu vực công và tư, từ doanh nghiệp nhỏ đến các tổ chức lớn và cơ quan chính phủ.

Tuy nhiên, cùng với sự phát triển nhanh chóng của các dịch vụ đám mây là sự gia tăng về mức độ và tính phức tạp của các mối đe dọa an ninh mạng: Từ việc truy cập trái phép, rò rỉ dữ liệu, tấn công DDoS, đến các lỗ hổng trong quản trị hệ thống. Với dữ liệu lớn và nhạy cảm cao từ khách hàng doanh nghiệp và cơ quan nhà nước, việc bảo vệ thông tin và đảm bảo tính toàn vẹn, bảo mật, sẵn sàng của hệ thống là một yêu cầu cấp thiết, đồng thời cũng là thách thức lớn đối với doanh nghiệp. Mặc dù các doanh nghiệp đã triển khai nhiều biện pháp kỹ thuật và chính sách an ninh, song việc đánh giá lại tổng thể thực trạng an toàn, từ đó đề xuất các giải pháp phù hợp, cập nhật xu hướng mới và áp dụng các công nghệ tiên tiến (AI/Machine Learning, Zero Trust, mã hóa end-to-end...) là điều cần thiết trong giai đoạn hiện nay. Điều này không chỉ giúp tăng cường năng lực bảo vệ hạ tầng dịch vụ, mà còn nâng cao năng lực cạnh tranh của các doanh nghiệp trên thị trường dịch vụ điện toán đám mây trong nước và quốc tế.

Trước những thực trạng cấp thiết trên, học viên xin chọn đề án **“Nghiên cứu giải pháp đảm bảo an toàn dịch vụ trong điện toán đám mây cho doanh nghiệp”** làm đề án.

1.2. Tình hình nghiên cứu trong nước

Trong những năm gần đây, điện toán đám mây đã trở thành một lĩnh vực nhận được sự quan tâm lớn từ cả giới học thuật và doanh nghiệp tại Việt Nam, đặc biệt trong bối cảnh chuyển đổi số đang diễn ra mạnh mẽ trên toàn quốc. Cùng với đó, các vấn đề liên quan đến an toàn, an ninh thông tin trên nền tảng điện toán đám mây cũng trở thành chủ đề nghiên cứu được ưu tiên trong nhiều công trình khoa học, đề án, dự thảo chuyên ngành. Một số doanh nghiệp lớn như CMC, Viettel, VNPT, FPT cũng đang triển khai nhiều sáng kiến liên quan đến bảo vệ an toàn điện toán đám mây, đặc biệt thông qua việc xây dựng Trung tâm dữ liệu đạt chuẩn quốc tế, triển khai SOC (Security Operation Center) và đầu tư vào các nền tảng tự phát triển hoặc tích hợp công nghệ bảo mật từ đối tác nước ngoài. Tuy nhiên, các công bố nghiên cứu từ phía doanh nghiệp vẫn còn hạn chế và chưa được phổ biến rộng rãi trong giới học thuật. Mặc dù đã có nhiều hướng tiếp cận khác nhau trong việc đảm bảo an toàn điện toán đám mây, nhưng các nghiên cứu chuyên sâu tập trung vào từng loại dịch vụ cụ thể (IaaS, PaaS, SaaS) đặc biệt trong bối cảnh áp dụng thực tế tại các doanh nghiệp Việt Nam vẫn còn thiếu sót. Do đó cần có đề án nhằm hệ thống hóa, cập nhật và đề xuất giải pháp phù hợp với điều kiện triển khai tại các công ty, doanh nghiệp trong nước.

1.3. Tình hình nghiên cứu nước ngoài

Trên thế giới, an toàn thông tin điện toán đám mây là một trong những chủ đề nhận được sự quan tâm đặc biệt từ cộng đồng nghiên cứu và các tổ chức tiêu chuẩn quốc tế, đặc biệt trong bối cảnh dữ liệu ngày càng trở thành tài sản cốt lõi của doanh nghiệp, tổ chức chính phủ và cá nhân. Các tổ chức quốc tế như NIST (National Institute of Standards and Technology) đã công bố nhiều dữ liệu quan trọng, điển hình là tài liệu NIST SP 800-144 (hướng dẫn bảo mật cho các dịch vụ điện toán đám mây) và NIST SP 800-291 (cung cấp khung tiêu chuẩn kỹ thuật cho triển khai và đảm bảo an toàn trên đám mây). Những nghiên cứu này đặt nền tảng lý thuyết và thực tiễn cho các mô hình bảo mật, từ xác thực, kiểm soát truy cập, mã hóa dữ liệu đến đảm bảo tính sẵn sàng và phát hiện tấn công. Mặc dù thế giới đã đạt được nhiều thành tựu tiến bộ trong bảo mật điện toán đám mây, song phần lớn các nghiên cứu tập trung vào mô hình lý thuyết hoặc áp dụng các quốc gia có hạ tầng công nghệ mạnh. Việc tùy biến các giải pháp này sao cho phù hợp với đặc thù doanh nghiệp vừa và nhỏ, cũng như điều kiện triển khai tại các quốc gia đang phát triển như Việt Nam, vẫn còn là một khoảng trống cần nghiên cứu thêm.

1.4. Ý nghĩa của đề án

Đề án góp phần làm rõ các vấn đề lý thuyết và thực tiễn liên quan đến an toàn thông tin trong môi trường điện toán đám mây, đặc biệt là trong bối cảnh các doanh nghiệp đang ngày càng phụ thuộc vào nền tảng số để vận hành hệ thống. Thông qua việc nghiên cứu, phân tích và đánh giá hiện trạng an toàn của một số dịch vụ cloud, đề án giúp hệ thống hóa các rủi ro thường gặp, đồng thời đề xuất các giải pháp có cơ sở khoa học, sát với thực tiễn triển khai. Kết quả nghiên cứu có thể làm nền tảng cho các hướng nghiên cứu tiếp theo trong lĩnh vực bảo mật cloud tại Việt Nam.

2. Mục tiêu nghiên cứu của đề án

Mục tiêu của đề án là nghiên cứu giải pháp đảm bảo an toàn một số dịch vụ điện toán đám mây cho công ty Softel Solutions.

3. Đối tượng và phạm vi nghiên cứu

Đối tượng nghiên cứu của đề án là các giải pháp kỹ thuật và quy trình nhằm đảm bảo an toàn thông tin cho các dịch vụ điện toán đám mây, tập trung vào:

- Các mối đe dọa và lỗ hổng bảo mật thường gặp trong môi trường điện toán đám mây
- Các công nghệ, mô hình và công cụ được áp dụng để bảo vệ hệ thống đám mây
- Các phương pháp tổ chức, giám sát, phát hiện và ứng phó sự cố trong vận hành cloud

Phạm vi thực hiện tập trung tại công ty Softel Solutions.

4. Các nhiệm vụ chính cần thực hiện

Để đạt được mục tiêu, đề án đã thực hiện một số nội dung chính sau:

- Tìm hiểu tổng quan về điện toán đám mây và bảo mật điện toán đám mây nhằm mục đích khái quát lại tình hình bảo mật điện toán đám mây trong nước và trên thế giới trong thời gian qua, và đánh giá một số giải pháp đảm bảo an toàn điện toán đám mây cho doanh nghiệp
- Nghiên cứu mô hình, giải pháp đảm bảo an toàn điện toán đám mây cho doanh nghiệp nhằm mục đích đảm bảo hoạt động ổn định, an toàn, thông suốt, học viên đã tiến hành nghiên cứu các giải pháp, tiêu chuẩn về hạ tầng, thiết kế và một số giải pháp đảm bảo an toàn điện toán đám mây hiện có ở Việt Nam và trên thế giới. Từ đó, học viên sẽ đánh giá, đề xuất và lựa chọn một trong các giải pháp trên để kiểm thử tính khả thi có thể áp dụng vào thực tiễn trong công tác đảm bảo an toàn điện toán đám mây cho công ty.
- Triển khai thử nghiệm và đánh giá giải pháp đảm bảo an toàn điện toán đám mây cho doanh nghiệp và đề xuất một số nhiệm vụ, giải pháp bổ sung nhằm nâng cao tính khả thi, hiệu quả để áp dụng thực tiễn vào công tác chung của công ty.

5. Kết quả đạt được

Đạt được nhiều kiến thức vô cùng hữu ích, cùng với việc nghiên cứu các công trình khoa học, các nghiên cứu được công bố, các bài báo, tư liệu tham khảo học viên đã đúc kết được những giá trị nghiên cứu và áp dụng, vận dụng vào công tác đảm bảo an toàn điện toán đám mây cho công ty Softel Solutions.

6. Kết cấu của đề án

Đề án gồm 03 chương nội dung chính như sau:

Chương 1: Tổng quan về điện toán đám mây

Chương này trình bày về lịch sử ra đời các khái niệm, đặc điểm các mô hình triển khai và mô hình dịch vụ trong điện toán đám mây.

Chương 2: Nguy cơ bảo mật và giải pháp đảm bảo an toàn cho dịch vụ trong điện toán đám mây

Chương này trình bày về các nguy cơ, rủi ro trong điện toán đám mây (rủi ro từ kiến trúc, quản lý truy cập và xác thực, dữ liệu lưu trữ và truyền tải) từ đó đưa ra các giải pháp đảm bảo an toàn cho dịch vụ trong điện toán đám mây cho công ty Softel Solutions.

Chương 3: Triển khai thử nghiệm giải pháp đảm bảo an toàn dịch vụ trong điện toán đám mây

Chương này tập trung vào mô hình triển khai và tiến hành thử nghiệm kết quả triển khai của hệ thống đảm bảo an toàn dịch vụ điện toán đám mây sau đó đúc kết kinh nghiệm để có thể triển khai một hệ thống quy mô lớn hơn hoặc phục vụ thương mại.

CHƯƠNG 1. TỔNG QUAN VỀ ĐIỆN TOÁN Đám Mây VÀ BẢO MẬT TRONG ĐIỆN TOÁN Đám Mây

1.1. Lịch sử ra đời và khái niệm của điện toán đám mây

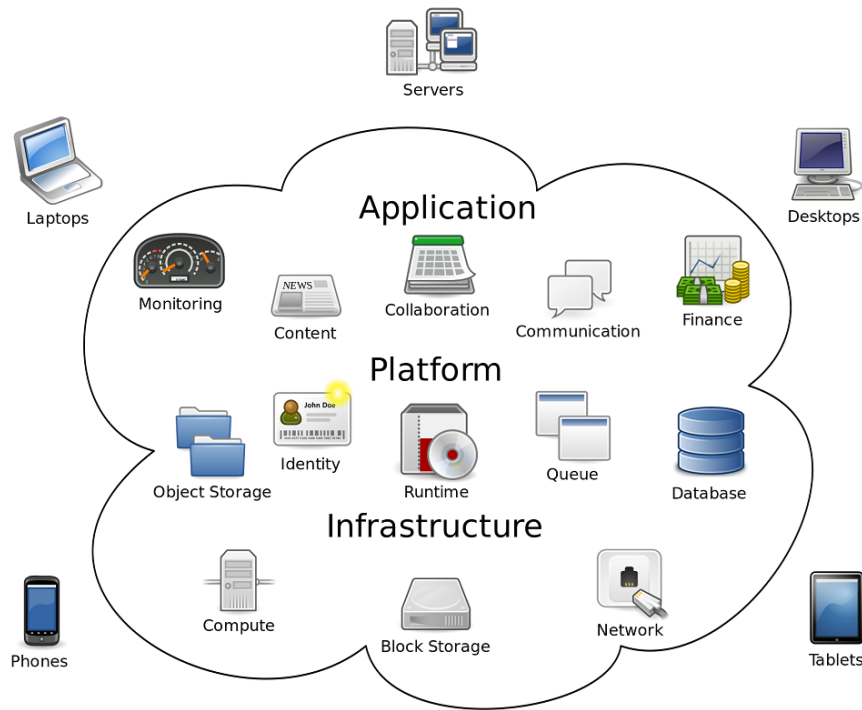
Thuật ngữ điện toán đám mây xuất hiện bắt nguồn từ ứng dụng điện toán lưới (grid computing) trong thập niên 1960, tiếp theo là điện toán theo nhu cầu (utility computing) và phần mềm dịch vụ (SaaS). Điện toán lưới đặt trọng tâm vào việc di chuyển một tải công việc đến địa điểm của các tài nguyên điện toán cần thiết để sử dụng. Một lưới là một nhóm máy chủ mà trên đó nhiệm vụ lớn được chia thành những tác vụ nhỏ để chạy song song, được xem là một máy chủ ảo. Với điện toán đám mây, các tài nguyên điện toán như máy chủ có thể được định hình động hoặc cắt nhỏ từ cơ sở hạ tầng phần cứng nền và trở nên sẵn sàng thực hiện nhiệm vụ, hỗ trợ những môi trường không phải là điện toán lưới như Web ba lớp chạy các ứng dụng truyền thống hay ứng dụng Web 2.0.[1]

Những năm 1990, các công ty viễn thông từ chỗ cung ứng kênh truyền dữ liệu điểm tới điểm (point-to-point data circuits) riêng biệt đã bắt đầu cung ứng các dịch vụ mạng riêng ảo với giá thấp. Thay đổi này tạo tiền đề để các công ty viễn thông sử dụng hạ tầng băng thông mạng hiệu quả hơn. Điện toán đám mây mở rộng khái niệm chia sẻ băng thông mạng này qua việc cho phép chia sẻ cả tài nguyên máy chủ vật lý bằng việc cung cấp các máy chủ ảo.

Amazon cung cấp nền tảng Amazon Web Services (AWS) vào năm 2006, đánh dấu việc thương mại hóa điện toán đám mây. Từ đầu năm 2008, Eucalyptus được giới thiệu là nền tảng điện toán đám mây mã nguồn mở đầu tiên, tương thích với API của AWS. Tính tới thời điểm hiện tại, có rất nhiều các sản phẩm điện toán đám mây được đưa ra như Google App Engine, Microsoft Azure, Nimbus,...

Điện toán đám mây (Cloud computing) là sự tổng hòa các khái niệm như Web service, Web 2.0 và các khái niệm mới khác cũng như các xu hướng công nghệ nổi bật, dựa trên nền tảng Internet nhằm đáp ứng nhu cầu của người dùng. Ví dụ, dịch vụ Google Application Engine hay Amazon EC2 cung cấp những ứng dụng liên quan đến mua bán trực tuyến, được truy nhập từ một trình duyệt web, còn các phần mềm và dữ liệu đều được lưu trữ trên các server hay các data center[1].

Theo Viện tiêu chuẩn và công nghệ quốc gia Bộ Thương mại Mỹ (NIST): Điện toán đám mây là một mô hình cho phép truy cập mạng thuận tiện, theo nhu cầu đến một kho tài nguyên điện toán dùng chung, có thể định cấu hình (ví dụ như mạng, máy chủ, lưu trữ, ứng dụng) có thể được cung cấp và thu hồi một cách nhanh chóng với yêu cầu tối thiểu về quản lý hoặc can thiệp của nhà cung cấp dịch vụ[4]. Các hệ thống Cloud computing thường phân tán tính năng tại các vị trí khác nhau trong các cụm server. Mô hình tổng quát về Cloud computing như trong Hình 1.1



Hình 1.1. Mô hình tổng quát Cloud Computing

Lợi ích của điện toán đám mây mang lại không chỉ gói gọn trong phạm vi người sử dụng nền tảng điện toán đám mây mà còn từ phía các nhà cung cấp dịch vụ điện toán. Theo những đánh giá của nhóm IBM CloudBurst năm 2009, trên môi trường điện toán phân tán có đến 85% tổng năng lực tính toán trong trạng thái nhàn rỗi, thiết bị lưu trữ tăng 54% mỗi năm, khoảng 70% chi phí được dành cho việc duy trì các hệ thống thông tin. Công nghiệp phần mềm mất đi 40 tỷ USD hàng năm vì việc phân phối sản phẩm không hiệu quả, khoảng 33% khách hàng phàn nàn về các lỗi bảo mật do các công ty cung cấp dịch vụ. Những thống kê này đều chỉ đến một điểm quan trọng: mô hình hệ thống thông tin hiện tại đã lỗi thời và kém hiệu quả, cần phải chuyển sang một mô hình điện toán mới – đó là điện toán đám mây.. Theo NIST (Viện Quốc gia về tiêu chuẩn và công nghệ Mỹ), Cloud computing gồm năm đặc tính cơ bản: Tự phục vụ theo yêu cầu (On-demand self-service), Sự truy cập mạng rộng rãi (Broad network access), Tập trung tài nguyên (Resource pooling), Tính mềm dẻo (Rapid elasticity or expansion) và Khả năng đo lường (Measured service). Trong đó:

- Tự phục vụ theo yêu cầu (On-demand self-service): Người dùng có thể tự cung cấp các khả năng tính toán, chẳng hạn như thời gian máy chủ lưu trữ mạng, khi cần một cách tự động mà không cần tương tác của con người với từng nhà cung cấp.
- Sự truy cập mạng rộng rãi (Broad network access): Những tài nguyên tính toán này được phân phối qua mạng Internet và được các ứng dụng client khác nhau sử dụng với những nền tảng không đồng nhất (như máy tính, điện thoại di động, PDA).
- Tập trung tài nguyên (Resource pooling): Những tài nguyên tính toán của nhà cung cấp dịch vụ đám mây được tập trung với mục đích phục

vụ đa khách hàng sử dụng mô hình ảo hóa với những tài nguyên vật lý và tài nguyên ảo được cấp phát động theo yêu cầu. Động lực của việc xây dựng một mô hình tập trung tài nguyên tính toán nằm trong hai yếu tố quan trọng: tính quy mô và tính chuyên biệt. Kết quả của mô hình tập trung tài nguyên là những tài nguyên vật lý trở nên trong suốt với người sử dụng. Ví dụ, người sử dụng không được biết vị trí lưu trữ cơ sở dữ liệu của họ trong đám mây.

- Tính mềm dẻo (Rapid elasticity or expansion): Dịch vụ cloud có khả năng dễ dàng thay đổi theo đúng nhu cầu thực tế. Các dịch vụ phải được thêm hay bớt theo đúng nhu cầu.
- Khả năng đo lường (Measured service): Dịch vụ cloud có khả năng tối ưu tài nguyên sử dụng của người dùng và được cập nhập thường xuyên.[3]

Một số đám mây phổ biến hiện nay:

Microsoft Azure: Microsoft Azure là đám mây cung cấp hạ tầng và nền tảng điện toán xây dựng bởi Microsoft và đưa vào khai thác từ 2010. Về mặt hạ tầng, Azure cung cấp các máy chủ ảo có thể chạy hệ điều hành Windows hoặc Unix. Về mặt nền tảng điện toán, Azure hỗ trợ đa ngôn ngữ lập trình cho phép triển khai trên Azure nhiều ứng dụng phát triển trên các công cụ và framework khác nhau. Phổ biến là các ứng dụng viết trên nền .Net của Microsoft.

Amazon Web Service (AWS): AWS được đưa ra vào năm 2006 với khởi đầu là tập hợp các dịch vụ tính toán như dịch vụ máy ảo EC2 và dịch vụ lưu trữ S3. AWS là nền tảng đám mây thương mại đầu tiên và phổ biến nhất hiện nay. Nhiều khách hàng lớn sử dụng AWS có thể nói đến như NASA, Pinterest, Netflix.

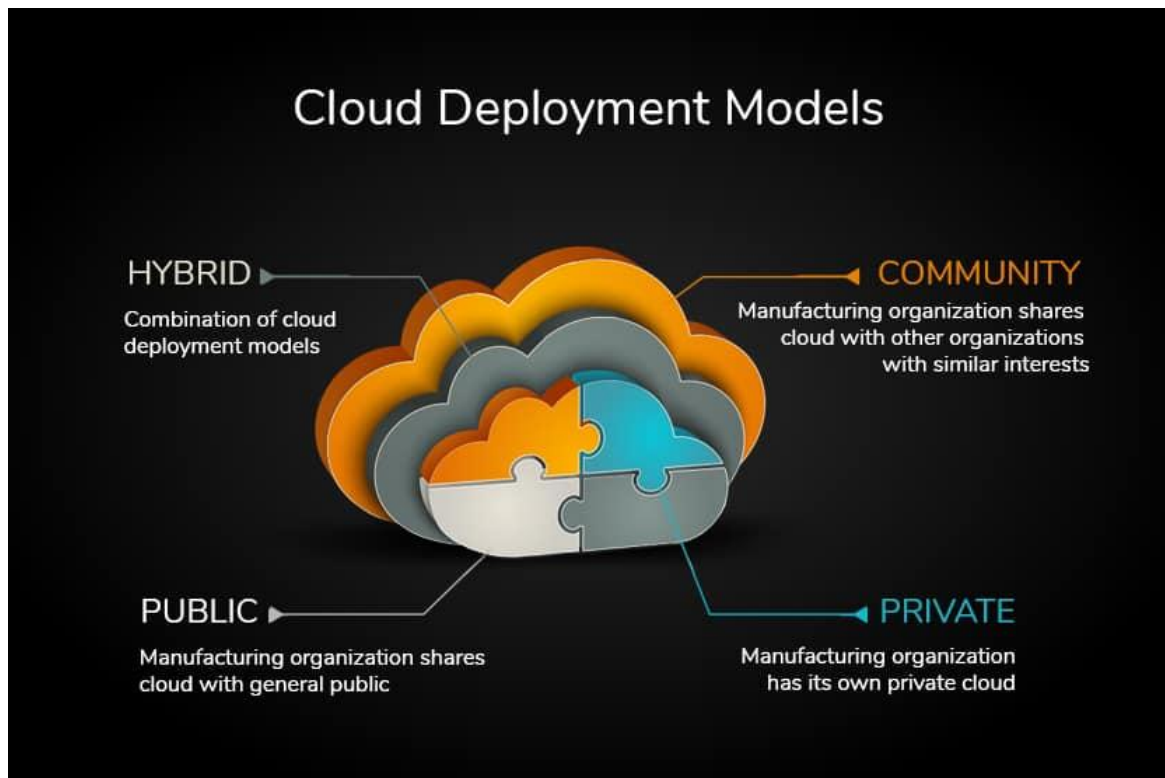
Nimbus: Nimbus là đám mây mã nguồn mở cung cấp hạ tầng máy chủ hướng theo dịch vụ thông qua giao diện kết nối dựa trên chuẩn kết nối của AWS.

Google App Engine (GAE): GAE là nền tảng đám mây mà trên đó Google cung cấp hỗ trợ cho cơ sở dữ liệu, các thư viện lập trình và các môi trường thực thi cho các ngôn ngữ lập trình phổ biến. Các ứng dụng trên các ngôn ngữ hỗ trợ sau khi triển khai trên GAE sẽ chạy trên các máy chủ ảo của Google.

1.1.1. Các mô hình triển khai trong điện toán đám mây

Theo NIST liệt kê có bốn mô hình triển khai điện toán đám mây:

- Đám mây riêng (Private Cloud)
- Đám mây công cộng (Public Cloud)
- Đám mây cộng đồng (Community Cloud)
- Đám mây lai (Hybrid Cloud)



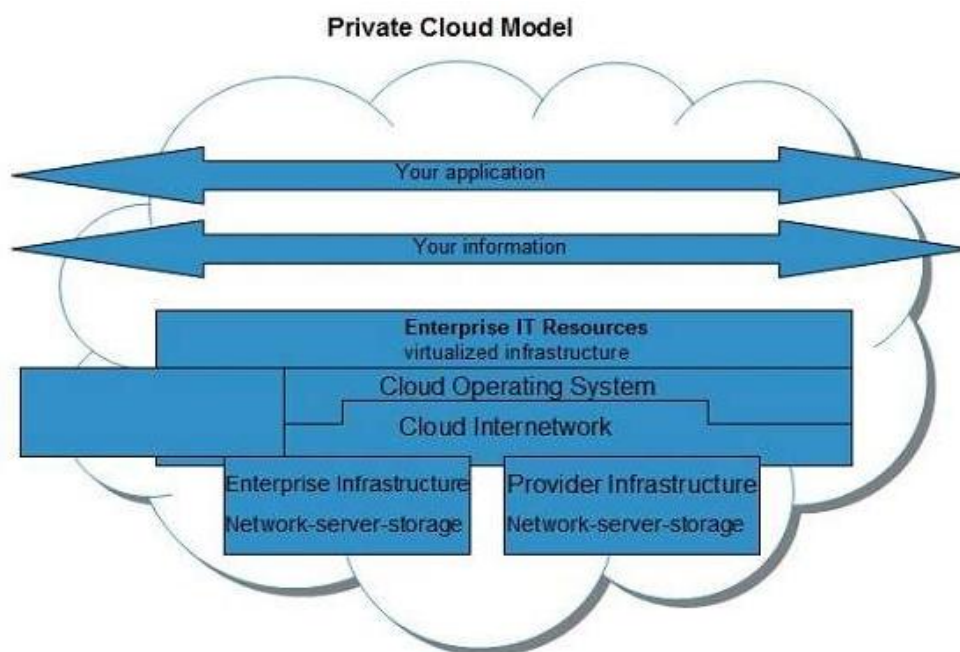
Hình 1.2: Mô hình triển khai điện toán đám mây

Đám mây riêng (Private Cloud)

Mô hình Private Cloud là mô hình mà cơ sở hạ tầng được triển khai dành cho chỉ duy nhất một khách hàng. Mỗi hệ thống Private Cloud có thể được đặt tại datacenter của người dùng nhưng cũng có thể được đặt tại datacenter của nhà cung cấp dịch vụ. Các hệ thống Private Cloud có thể được quản lý bởi người dùng, các nhà cung cấp dịch vụ hoặc một đơn vị thứ ba chuyên cung cấp các dịch vụ Cloud. Tuy nhiên, người dùng luôn phải chịu toàn bộ chi phí cho giải pháp. Các hệ thống Public Cloud là mô hình mà cơ sở hạ tầng được triển khai để tất cả mọi người, đều có thể sử dụng, không giới hạn số lượng, đối tượng người dùng (đó có thể là người dùng cá nhân hoặc các công ty lớn).

Hai mô hình dịch vụ được áp dụng trong Private Cloud bao gồm: Platform as a Service (PaaS) và Infrastructure as a Service (IaaS). Mô hình đầu tiên là Platform as a Service (PaaS) cho phép một tổ chức cung cấp mọi thứ từ các ứng dụng miễn phí cho đến các ứng dụng trả phí. Mô hình thứ hai là Infrastructure as a Service (IaaS) cho phép một tổ chức sử dụng tài nguyên của cơ sở hạ tầng như máy tính, hệ thống mạng và các thiết bị lưu trữ như một dịch vụ.[2]

Private Cloud còn kết hợp với Public Cloud để tạo ra Hybrid Cloud cho phép doanh nghiệp tận dụng Cloud Bursting để tối ưu không gian và quy mô các dịch vụ Cloud Computing khi người dùng hay tổ chức tăng nhu cầu sử dụng.



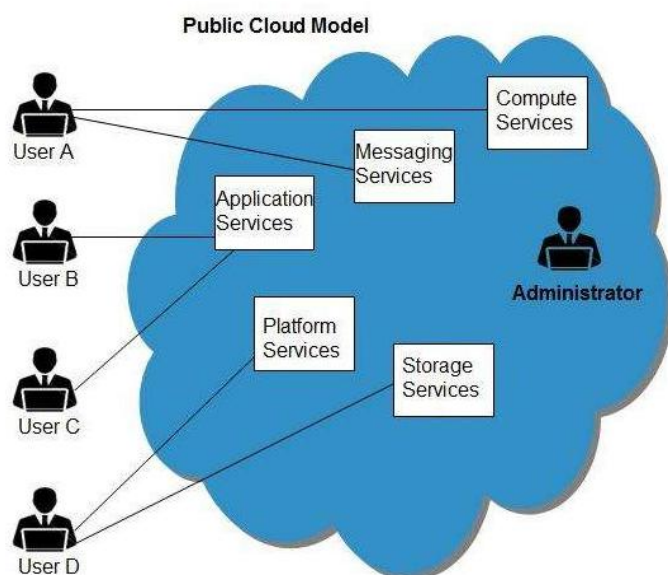
Hình 1.3: Private Cloud Model

Ưu điểm	Nhược điểm
Kiểm soát tốt hơn: Doanh nghiệp hoàn toàn kiểm soát các dịch vụ và chính sách. Bảo mật cao: Thích hợp cho lưu trữ dữ liệu quan trọng, bảo mật vì cơ sở dữ liệu đám mây chỉ có doanh nghiệp có quyền truy cập. Tùy chỉnh cao: Doanh nghiệp có thể tùy chỉnh theo nhu cầu riêng.	Khó mở rộng: Hạn chế về khả năng mở rộng vì chỉ phục vụ một tổ chức. Chi phí cao: Do tính cá nhân hóa và bảo mật, chi phí triển khai cao hơn.

Đám mây công cộng (Public Cloud)

Public Cloud là loại đám mây mà bất kỳ ai cũng có thể sử dụng, miễn là có kết nối Internet. Điều này có nghĩa là các dịch vụ của điện toán đám mây và tài nguyên như máy chủ, lưu trữ dữ liệu, phần mềm... đều được cung cấp rộng rãi cho mọi người, doanh nghiệp, hoặc các nhóm ngành lớn. Tuy nhiên, vì đám mây công cộng mở cho tất cả mọi người, nên tính bảo mật không cao như các mô hình đám mây khác. Trong mô hình này, cơ sở hạ tầng đám mây (máy chủ, phần cứng, phần mềm) do nhà cung cấp dịch vụ đám mây sở hữu và quản lý, không phải do người dùng sở hữu. Người dùng chỉ cần trả phí để sử dụng dịch vụ mà không phải lo về việc duy trì và bảo trì hạ tầng.

Public Cloud được sử dụng phổ biến và dễ dàng. Microsoft Office 365, Microsoft Azure, Amazon Web Service (AWS) và NTC Cloud Server là những ví dụ điển hình cho giải pháp Public Cloud.

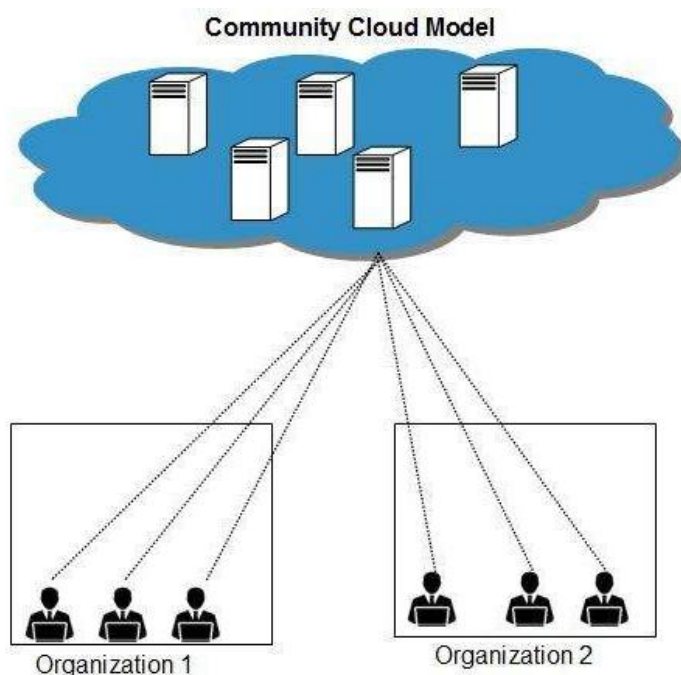


Hình 1.4: Public Cloud Model

Ưu điểm	Nhược điểm
Chi phí thấp: Không cần chi phí ban đầu lớn, chỉ trả tiền theo nhu cầu sử dụng. Không cần cài đặt phần cứng: Nhà cung cấp dịch vụ sẽ lo toàn bộ cơ sở hạ tầng. Quản lý hạ tầng dễ dàng: Không cần quản lý hạ tầng, tất cả đã được nhà cung cấp lo.	Bảo mật kém: Tính bảo mật không cao vì mọi người đều có thể truy cập vào tài nguyên. Tùy chỉnh hạn chế: Không thể tùy chỉnh hạ tầng đám mây vì nhiều người sử dụng chung.

Đám mây cộng đồng (Community Cloud)

Community Cloud là một mô hình đám mây mà tài nguyên được chia sẻ giữa các tổ chức có cùng lợi ích, yêu cầu bảo mật hoặc mục tiêu kinh doanh. Các tổ chức này có thể cùng nhau đầu tư vào cơ sở hạ tầng, hoặc nhờ một nhà cung cấp đám mây thứ ba quản lý hạ tầng chung. Community Cloud thường được sử dụng trong các ngành công nghiệp có yêu cầu bảo mật cao như chăm sóc sức khỏe, giáo dục, và chính phủ.

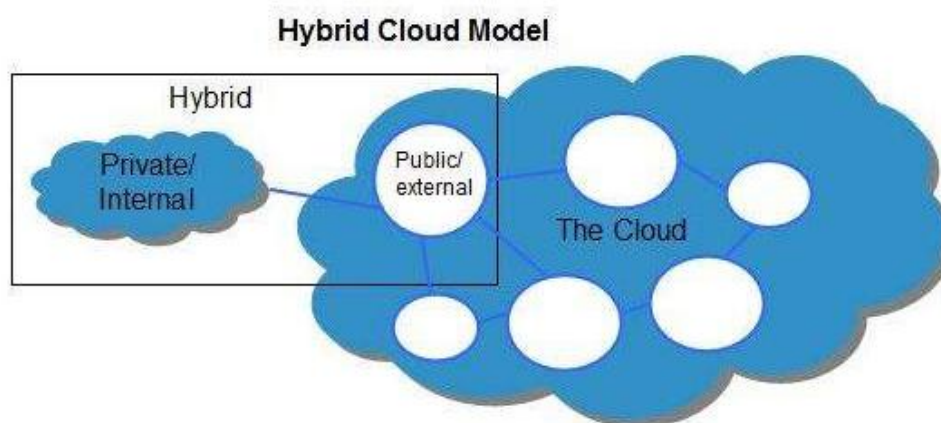


Hình 1.5: Community Cloud Model

Ưu điểm	Nhược điểm
Chi phí tiết kiệm: Vì nhiều tổ chức chia sẻ tài nguyên nên chi phí sẽ thấp hơn. Bảo mật cao: Thường cung cấp bảo mật tốt hơn so với Public Cloud Hợp tác và chia sẻ dữ liệu: Phù hợp với các tổ chức cần hợp tác và chia sẻ dữ liệu.	Khả năng mở rộng hạn chế: Do nhiều tổ chức chia sẻ tài nguyên nên quy mô có thể bị giới hạn. Tùy chỉnh khó khăn: Khi dữ liệu và tài nguyên được chia sẻ, một tổ chức không thể thay đổi theo nhu cầu riêng mà không ảnh hưởng đến các tổ chức khác.

Đám mây lai (Hybrid Cloud)

Mô hình Hybrid Cloud là mô hình kết hợp giữa đám mây công cộng (Public Cloud) và đám mây riêng (Private Cloud), cho phép các tổ chức di chuyển dữ liệu và ứng dụng giữa các môi trường công cộng và riêng biệt. Mô hình này mang lại sự linh hoạt tối đa, giúp tổ chức có thể tận dụng các ưu điểm của cả hai mô hình. Mô hình điện toán đám mây Hybrid Cloud giúp tối ưu hóa hiệu quả hoạt động cho doanh nghiệp.



Hình 1.6: Hybrid Cloud Model

Ưu điểm	Nhược điểm
Linh hoạt cao: Các tổ chức có thể chọn nơi lưu trữ và xử lý dữ liệu sao cho phù hợp với nhu cầu, chi phí và bảo mật. Khả năng mở rộng linh hoạt: Sử dụng đám mây công cộng khi cần mở rộng quy mô mà không phải đầu tư vào cơ sở hạ tầng. Bảo mật tốt: Tổ chức có thể lưu trữ dữ liệu nhạy cảm trong đám mây riêng, trong khi các ứng dụng hoặc dữ liệu ít quan trọng có thể được lưu trữ trong đám mây công cộng.	Quản lý phức tạp: Việc kết hợp giữa đám mây công cộng và đám mây riêng có thể tạo ra sự phức tạp trong việc quản lý và đồng bộ hóa các hệ thống. Chi phí duy trì cao: Mặc dù linh hoạt, nhưng mô hình này có thể đắt đỏ do yêu cầu duy trì cả hai hệ thống đám mây công cộng và riêng.

1.1.2. Các mô hình dịch vụ trong điện toán đám mây

Ba mô hình dịch vụ được NIST trình bày dùng để định nghĩa các dịch vụ cung cấp trong Cloud computing bao gồm: Phần mềm hướng dịch vụ (Software as a Service - SaaS), Nền tảng hướng dịch vụ (Platform as a Service - PaaS), Hạ tầng hướng dịch vụ (Infrastructure as a Service - IaaS).

Phần mềm hướng dịch vụ (Software as a Service - SaaS)

Phần mềm hướng dịch vụ là một mô hình triển khai ứng dụng mà ở đó nhà cung cấp cho phép người dùng sử dụng dịch vụ theo yêu cầu. Những nhà cung cấp SaaS có thể lưu trữ ứng dụng trên máy chủ của họ hoặc tải ứng dụng xuống thiết bị khách hàng, vô hiệu hoá nó sau khi kết thúc thời gian. Các chức năng theo yêu cầu có thể được kiểm soát bên trong để chia sẻ bản quyền của một nhà cung cấp ứng dụng thứ ba.

Các ứng dụng có thể truy cập từ các thiết bị khác nhau thông qua giao diện “mỏng” (thin client interface), chẳng hạn như một trình duyệt web (như email trên web), hoặc qua giao diện của chương trình. Khách hàng không quản lý hoặc kiểm soát cơ sở hạ tầng điện toán đám mây nằm bên dưới bao gồm mạng, máy chủ, hệ

điều hành... với ngoại lệ có thể thiết lập cấu hình ứng dụng hạn chế người sử dụng cụ thể.



Hình 1.7: Phần mềm hướng dịch vụ

Một số ứng dụng sử dụng dịch vụ này:

- Quản lý quan hệ khách hàng (Customer Relationship Management - CRM): Đây là một phương pháp giúp các doanh nghiệp tiếp cận và giao tiếp với khách hàng một cách có hệ thống và hiệu quả, quản lý các thông tin của khách hàng như thông tin về tài khoản, nhu cầu, liên lạc... nhằm phục vụ khách hàng tốt hơn.
- Dịch vụ hội thảo (Video Conferencing)
- Kế toán
- Hệ quản trị nội dung web DotNetNuke

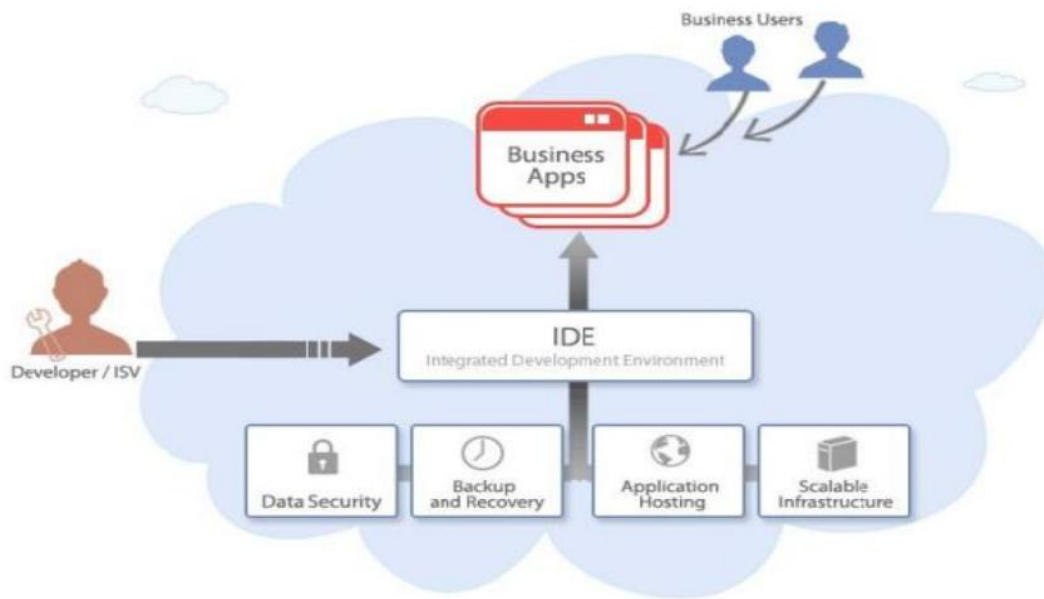
Lợi ích lớn nhất của dịch vụ này mang lại là chi phí thấp. Nhà cung cấp dịch vụ có thể đưa ra các ứng dụng rẻ hơn và đáng tin hơn. Ngoài ra còn có một số lợi ích như:

- Sử dụng ít nhân viên
- Sự tùy chỉnh: Những ứng dụng trước đây rất khó tùy chỉnh và đòi hỏi phải cập nhật các bản vá lỗi. Ứng dụng SaaS dễ dàng tùy chỉnh và có thể đáp ứng chính xác yêu cầu của tổ chức.
- Bảo mật: SSL (Secure Sockets Layer) được sử dụng rộng rãi và tin cậy.

Nền tảng hướng dịch vụ (Platform as a Service - PaaS)

Mô hình dịch vụ này cung cấp cho khách hàng khả năng triển khai trên hạ tầng điện toán đám mây các ứng dụng của họ bằng việc sử dụng các ngôn ngữ lập trình, các thư viện, dịch vụ, công cụ được hỗ trợ từ bên thứ ba. Người dùng không cần quản lý hoặc kiểm soát các cơ sở hạ tầng điện toán đám mây bên dưới như máy chủ ảo, mạng, hệ điều hành, nhưng có thể cấu hình cho môi trường chạy ứng

dụng của họ. Ngoài Windows Azure, Amazon Web Service (AWS) là ví dụ điển hình trong mô hình này.



Hình 1.8. Nền tảng hướng dịch vụ

Một số đặc trưng của PaaS bao gồm:

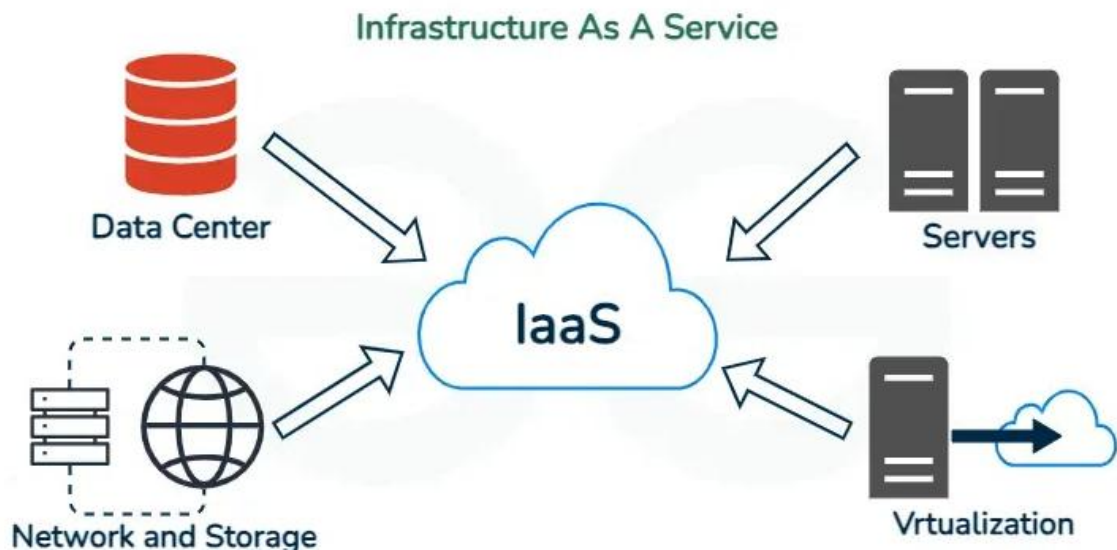
- Phục vụ cho việc phát triển, kiểm thử, triển khai và vận hành ứng dụng giống như là môi trường phát triển tích hợp
- Cung cấp các công cụ khởi tạo với giao diện trên nền web
- Có kiến trúc đồng nhất
- Tích hợp dịch vụ web và cơ sở dữ liệu
- Hỗ trợ cộng tác nhóm phát triển
- Cung cấp các công cụ hỗ trợ tiện ích khác

Việc sử dụng dịch vụ này mang lại một số lợi ích:

- Ưu điểm trong những dự án tập hợp những công việc nhóm có sự phân tán về địa lý
- Khả năng tích hợp nhiều nguồn của dịch vụ web
- Giảm chi phí ngoài lề khi tích hợp các dịch vụ về bảo mật, khả năng mở rộng, kiểm soát lỗi
- Hướng việc sử dụng công nghệ để đạt được mục đích tạo điều kiện dễ dàng cho việc phát triển ứng dụng đa người dùng cho những người không chỉ trong nhóm lập trình mà có thể kết hợp nhiều nhóm cùng làm việc.

Dịch vụ hạ tầng (Infrastructure as a Service - IaaS)

Mô hình dịch vụ này cung cấp cho khách hàng tài nguyên xử lý, lưu trữ, mạng và các tài nguyên máy tính cơ bản khác. Từ đó, khách hàng có thể triển khai và chạy phần mềm tùy ý, bao gồm hệ điều hành và các ứng dụng. Khách hàng không quản lý hoặc kiểm soát các cơ sở hạ tầng điện toán đám mây nằm bên dưới, nhưng có kiểm soát hệ thống điều hành, lưu trữ và các ứng dụng được triển khai đồng thời kiểm soát có giới hạn của các thành phần mạng.



Hình 1.9. Dịch vụ hạ tầng

Các lợi ích mà dịch vụ này mang lại:

- Cung cấp tài nguyên như là dịch vụ: bao gồm cả máy chủ, thiết bị mạng, bộ nhớ CPU, không gian đĩa cứng, trang thiết bị trung tâm dữ liệu.
- Khả năng mở rộng linh hoạt
- Chi phí thay đổi tùy theo thực tế
- Nhiều người thuê có thể cùng dùng chung trên một tài nguyên
- Về cấp độ doanh nghiệp: Đem lại lợi ích cho công ty bởi một nguồn tài chính tính toán tổng hợp

1.1.3. Ưu điểm và nhược điểm của điện toán đám mây

Ưu điểm của điện toán đám mây

Tiết kiệm và giảm chi phí: Chi phí đầu tư ban đầu về cơ sở hạ tầng, máy móc và nguồn nhân lực của người sử dụng điện toán đám mây được giảm đến mức thấp nhất. Khi khách hàng ngừng sử dụng dịch vụ thì tài nguyên sẽ được nhà cung cấp giải phóng và cho khách hàng khác thuê lại. Khách hàng sẽ tận dụng được nguồn vốn dùng để đầu tư cho thiết bị cho các công việc kinh doanh khác.

Tốc độ xử lý nhanh: Người dùng của dịch vụ điện toán đám mây sẽ tận dụng được sức mạnh mà các siêu máy tính của nhà cung cấp mang lại.

Đa phương tiện: Không còn phụ thuộc vào thiết bị và vị trí địa lý, điện toán đám mây cho phép người dùng truy cập và sử dụng hệ thống thông qua trình duyệt web ở bất kỳ đâu và trên bất kỳ thiết bị nào mà họ sử dụng (chẳng hạn là PC hoặc là điện thoại di động, v.v....)

Chia sẻ tài nguyên và chi phí trên một địa bàn rộng lớn, mang lại các lợi ích cho người dùng như:

- Công suất xử lý nhanh hơn do tài nguyên được tập trung. Ngoài ra, người dùng không cần phải đầu tư về nguồn nhân lực quản lý hệ thống.
- Khả năng khai thác và hiệu suất được cải thiện hơn 10-20% so với hệ thống máy tính cá nhân thông thường.

Độ tin cậy cao: Điện toán đám mây không chỉ giành cho người dùng phổ thông, mà còn phù hợp với các yêu cầu cao và liên tục của các công ty kinh doanh và các nghiên cứu khoa học. Tuy nhiên, một vài dịch vụ lớn của điện toán đám mây đôi khi rơi vào trạng thái quá tải, khiến hoạt động bị ngưng trệ. Khi rơi vào trạng thái này, người dùng không có khả năng để xử lý các sự cố mà phải nhờ vào các chuyên gia từ đám mây tiến hành xử lý.

Tính co giãn: Khả năng mở rộng, co giãn các tài nguyên giúp khách hàng dễ dàng cơ cấu lại hoạt động của mình khi có sự thay đổi về quy mô cũng như phương thức hoạt động.

Bảo mật: Khả năng bảo mật được cải thiện do sự tập trung về dữ liệu.

Bảo trì và sửa chữa: Các ứng dụng của điện toán đám mây dễ dàng để sửa chữa hơn bởi lẽ chúng không được cài đặt cố định trên một máy tính nào và có đội ngũ chuyên gia trong ngành chịu trách nhiệm về vấn đề bảo trì, sửa chữa.

Thông kê tài nguyên: Tài nguyên sử dụng của điện toán đám mây luôn được quản lý và thông kê trên từng khách hàng và ứng dụng, theo từng ngày, từng tuần, từng tháng. Điều này đảm bảo cho việc định lượng giá cả của mỗi dịch vụ do điện toán đám mây cung cấp để người dùng có thể lựa chọn phù hợp.

Nhược điểm của điện toán đám mây

Phụ thuộc vào nhà cung cấp: Ngày nay, khả năng tương tác giữa các nền tảng khác nhau của các phần mềm đã được cải thiện, nhưng các hàm API (Application Programming Interface) của điện toán đám mây vẫn chưa được chuẩn hóa nên nếu một người dùng viết một ứng dụng trên nền tảng của nhà cung cấp dịch vụ thì ứng dụng đó không thể chạy được trên nền tảng của nhà cung cấp dịch vụ khác. Như vậy người dùng phụ thuộc nhà cung cấp dịch vụ là điều bất lợi.

Nếu các nhà cung cấp dịch vụ điện toán đám mây cùng nhau chuẩn hóa API thì người dùng có thể phát triển ứng dụng trên nền tảng của nhiều nhà cung cấp dịch vụ. Khi hệ thống cung cấp dịch vụ nào đó gặp sự cố thì dữ liệu người dùng không mất vì nó đã nằm đâu đó trên hệ thống của các nhà cung cấp dịch vụ khác.

Bảo mật và kiểm tra dữ liệu: Dữ liệu lưu trên đám mây chưa chắc đã an toàn, xác suất bị người khác khác truy xuất rất cao, đây thực sự là một thách thức trong bảo mật dữ liệu. Trước hết người dùng phải mã hóa dữ liệu trước khi đưa lên đám mây để lưu trữ, khi sử dụng tất nhiên phải giải mã trên PC của họ. Người dùng ghi nhận thông tin hệ thống đã xử lý cùng với sử dụng các hệ điều hành ảo khi cung cấp dịch vụ IaaS sẽ làm cho ứng dụng của mình khó bị tấn công hơn.

Tắc nghẽn trên đường truyền dữ liệu và hiệu quả PC: Có những ứng dụng khi bắt đầu chạy thì dữ liệu ít, càng về sau dữ liệu càng nhiều, có ứng dụng chạy trên Cloud và có thể lưu ở các vị trí khác nhau, khi chạy ứng dụng này phát sinh “vận chuyển dữ liệu giữa các data center”. Người dùng phải trả phí vận chuyển dữ liệu giữa các data center, ứng dụng chạy càng về sau thì chi phí này càng tăng lên, đây là điều phải cân nhắc.

1.2. Các mối đe dọa rủi ro an toàn trong điện toán đám mây

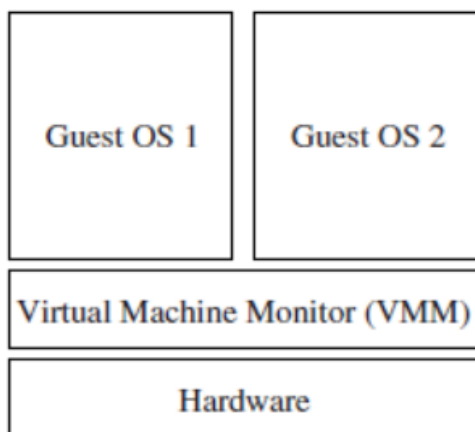
1.2.1. Rủi ro từ kiến trúc

Lỗ hổng trong ảo hóa (Virtualization Vulnerabilities)

Ảo hóa (virtualization) là công nghệ cốt lõi trong điện toán đám mây, cho phép nhiều máy ảo (Virtual Machines – VM) cùng chạy trên một hệ thống phần cứng vật lý thông qua phần mềm trung gian gọi là hypervisor (hoặc Virtual Machine Monitor – VMM). Công nghệ này giúp tối ưu hóa tài nguyên, tăng hiệu quả vận hành và hỗ trợ triển khai các mô hình đa người dùng (multi-tenant).

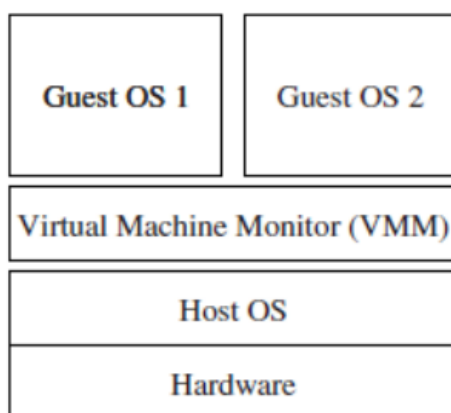
Có hai loại hypervisor chính:

- Type 1 (bare-metal): Chạy trực tiếp trên phần cứng máy chủ và bên dưới hệ điều hành của máy khách, do đó nó có thể quản lý các hệ điều hành khách và kiểm soát quyền truy cập của chúng vào phần cứng, loại này được gọi là máy chủ vật lý như Hình 1.10 (ví dụ: VMware ESXi, Microsoft Hyper-V, Xen).[5]



Hình 1.10: Bare metal hypervisor (Type 1)

- Type 2 (hosted): Loại Hypervisor thứ hai, hypervisor chạy trên hệ điều hành máy chủ, và thiết lập kết nối cho các hệ điều hành của máy khách ở trên nó để cung cấp khả năng quản lý và khả năng truy cập cho chúng, loại này được gọi là máy chủ vật lý như Hình 1.11 (ví dụ: VirtualBox, VMware Workstation).[5].



Hình 1.11: Hosted hypervisor (Type 2)

Mặc dù mang lại nhiều lợi ích, ảo hóa cũng đi kèm nhiều rủi ro bảo mật, trong đó nổi bật là VM Escape và Side-Channel Attacks.

Lỗ hổng VM Escape:

VM Escape là hình thức tấn công nghiêm trọng nhất trong môi trường ảo hóa. Đây là hiện tượng một tiến trình bên trong máy ảo có thể vượt qua lớp cách ly của hypervisor để truy cập vào hệ thống chủ hoặc các máy ảo khác.

Cơ chế tấn công VM Escape:

Bước 1: Xác định lỗ hổng trong hypervisor như

Tràn bộ đệm (buffer overflow), sử dụng con trỏ NULL, lỗi xử lý driver thiết bị ảo (vGPU, vNIC, vDisk...), các API ảo hóa không được kiểm soát đúng cách.

Bước 2: Khai thác lỗ hổng từ bên trong Guest VM

Từ bên trong một VM, kẻ tấn công thực thi mã độc hoặc một exploit để khai thác lỗ hổng đã xác định. Mã độc sẽ tương tác với thiết bị ảo (gửi dữ liệu độc hại đến các thiết bị I/O ảo), gây ra lỗi không kiểm soát trong hypervisor. Từ đó làm cho hypervisor thực thi mã tùy ý của kẻ tấn công ở cấp độ hệ thống.

Bước 3: Thoát khỏi môi trường máy ảo

Sau khi thực thi thành công mã trong hypervisor, kẻ tấn công có thể truy cập vào các VM khác nhằm mục đích đánh cắp dữ liệu hoặc làm gián đoạn dịch vụ; truy cập vào hệ điều hành máy chủ vật lý chiếm toàn quyền điều khiển hệ thống; cài đặt phần mềm độc hại ở tầng thấp để duy trì quyền truy cập.

1.2.2. Rủi ro từ quản lý truy cập và xác thực

Các rủi ro phổ biến nhất trong quản lý truy cập và xác thực:

- Sử dụng sai mục đích quyền truy cập đặc quyền: Các sai sót do nhân viên hiện tại gây ra (các mối đe dọa nội bộ). Ví dụ một nhân viên không hài lòng có thể lợi dụng quyền truy cập đặc quyền để chiếm đoạt hồ sơ tài chính hoặc đánh cắp tài sản trí tuệ. Tương tự, một nhà thầu có quyền truy cập vào các hệ thống nhạy cảm có thể cố ý làm rò rỉ thông tin mật cho đối thủ cạnh tranh để trục lợi cá nhân.
- Mật khẩu và xác thực yếu: Nhiều người trong chúng ta sử dụng mật khẩu yếu như "123456", "admin" và "password", khiến kẻ tấn công dễ dàng truy cập vào các tài khoản đặc quyền. Mật khẩu yếu tiềm ẩn những rủi ro đáng kể vì chúng dễ bị tấn công mạng, chẳng hạn như tấn công brute-force và lừa đảo. Ngoài ra, việc chia sẻ và sử dụng lại thông tin đăng nhập làm tăng nguy cơ bị xâm phạm trên nhiều tài khoản. Sử dụng mật khẩu mạnh và xác thực đa yếu tố (MFA) để đảm bảo an toàn. MFA bổ sung thêm các lớp bảo mật, khiến tin tặc khó tấn công hoặc đánh cắp danh tính hơn. Nó cũng giúp các tổ chức tuân thủ các quy tắc bảo mật và khiến người dùng có trách nhiệm hơn.
- Hiện thị thiếu dữ liệu truy cập của người dùng: Các tổ chức gặp phải những vấn đề lớn khi không thể biết ai đang truy cập vào nội dung gì. Việc không thể hiển thị mọi thứ cũng đồng nghĩa với việc khó phát hiện ai đó đang xâm nhập vào nơi không được phép hoặc phát hiện ra các tài khoản cũ không còn quyền truy cập. Ngoài ra, các tài khoản không hoạt động không được phát hiện gây ra rủi ro, bao gồm vi

phạm bảo mật, mất dữ liệu, vi phạm tuân thủ, mối đe dọa nội bộ, gián đoạn hoạt động, tổn hại danh tiếng và quản lý vòng đời người dùng không hiệu quả. Vì vậy, các tổ chức phải thiết lập các hệ thống an toàn để theo dõi ai đang truy cập vào dữ liệu gì và đảm bảo phát hiện mọi sự cố trước khi chúng trở nên nghiêm trọng.

- Truy cập trái phép: Việc hủy truy cập không đúng cách có thể dẫn đến các rủi ro bảo mật nghiêm trọng, bao gồm việc truy cập trái phép bởi các nhân viên cũ vẫn còn giữ quyền tài khoản người dùng. Truy cập trái phép có thể dẫn đến hậu quả nghiêm trọng cho tổ chức, bao gồm vi phạm dữ liệu, đánh cắp sở hữu trí tuệ, gián đoạn hoạt động. Các tổ chức có thể sử dụng nhiều kỹ thuật khác nhau để ngăn chặn truy cập trái phép, bao gồm xác thực mạnh, kiểm soát truy cập và mã hóa, đồng thời đào tạo nhân viên về các kỹ thuật này và cập nhật bảo mật thường xuyên.
- Kiểm soát truy cập không đầy đủ: Các vấn đề như mật khẩu yếu hoặc không giám sát người đang truy cập vào dữ liệu nào có thể dẫn đến việc truy cập trái phép vào dữ liệu nhạy cảm. Việc không thiết lập các biện pháp kiểm soát truy cập phù hợp có thể cho phép những người không được phép truy cập vào thông tin hoặc hệ thống quan trọng. Ví dụ: việc truy cập dữ liệu không phù hợp với vai trò công việc của họ làm tăng nguy cơ rò rỉ dữ liệu vô tình hoặc cố ý.
- Cấu hình sai: Cấu hình sai giữa hệ thống hoặc ứng dụng có thể vô tình làm lộ dữ liệu nhạy cảm hoặc tạo ra rủi ro bảo mật. Gần 23% sự cố bảo mật đám mây bắt nguồn từ việc cấu hình sai, trong khi 27% doanh nghiệp đã phải đối mặt với các lỗ hổng bảo mật trong hệ thống đám mây công cộng của họ. Ví dụ: việc thiết lập lưu trữ đám mây không đúng cách có thể khiến bất kỳ ai trực tuyến cũng có thể truy cập dữ liệu, dẫn đến vi phạm. Tương tự, các quy tắc tường lửa được cấu hình sai có thể cho phép truy cập trái phép vào mạng nội bộ, gây nguy hiểm cho bảo mật của tổ chức.
- Rủi ro từ kiến trúc đa đám mây (multi-cloud): Việc sử dụng thiết lập đa đám mây mang lại rất nhiều lợi ích. Nó giúp phục hồi sau thảm họa, mang lại sự linh hoạt, tránh bị mắc kẹt với một nhà cung cấp, cải thiện hiệu suất bằng cách sử dụng các vị trí khác nhau, tiết kiệm chi phí và cho phép các tổ chức lựa chọn những dịch vụ tốt nhất từ các nhà cung cấp khác nhau. Nhưng không phải tất cả đều dễ dàng. Việc xử lý nhiều đám mây có thể phức tạp và rủi ro. Việc đảm bảo mọi người đều có quyền truy cập phù hợp và giữ dữ liệu an toàn bằng khóa mã hóa trên các đám mây khác nhau cần được lập kế hoạch cẩn thận. Nếu không được thực hiện đúng cách, có thể xảy ra sai sót và lỗ hổng bảo mật. Thêm vào đó, nếu có sự cố bảo mật trong một đám mây, nó có thể lan sang các đám mây khác nếu chúng không được tách biệt. Vì vậy, mặc dù việc sử dụng nhiều đám mây có thể là một lựa chọn thông minh, nhưng điều quan trọng là phải tập trung vào việc giữ mọi thứ an toàn và được quản lý tốt để tránh sự cố.

- Chính sách bảo mật IAM (Identity and Access Management Security) yếu: Theo CrowdStrike, 80% các cuộc tấn công mạng sử dụng phương pháp tấn công dựa trên danh tính. Do đó, các tổ chức phải thiết lập các chính sách bảo mật IAM rõ ràng và mạnh mẽ để quản lý quyền truy cập và thực hành xác thực của người dùng. Việc triển khai các chính sách mật khẩu mạnh là rất quan trọng để tăng cường các biện pháp kiểm soát bảo mật IAM. Chính sách mật khẩu yếu có thể gây tổn hại nghiêm trọng đến an ninh. Ví dụ: nếu không có các quy tắc nghiêm ngặt về độ phức tạp của mật khẩu, nhân viên có thể chọn mật khẩu dễ đoán, vô tình tạo điều kiện cho kẻ tấn công khai thác tài khoản thông qua các cuộc tấn công brute force hoặc password-spraying. Để giải quyết những rủi ro này, hãy thực thi các chính sách mật khẩu mạnh mẽ trong tổ chức.

1.2.3. Rủi ro từ dữ liệu lưu trữ và truyền tải

Rủi ro đối với dữ liệu lưu trữ (Data-at-Rest Risks)

Hiện nay dữ liệu của tổ chức được lưu trữ tại các hệ thống máy chủ do nhà cung cấp dịch vụ đám mây (Cloud Service Provider - CSP) quản lý. Dữ liệu ở trạng thái nghỉ (data-at-rest) bao gồm tất cả các tệp, cơ sở dữ liệu và bản ghi được lưu trữ trong các kho lưu trữ đối tượng (object storage), lưu trữ khối (block storage) hoặc hệ thống lưu trữ tệp (file storage). Dù được lưu trữ đám mây mang lại khả năng mở rộng linh hoạt và giảm chi phí vận hành, nhưng cũng tiềm ẩn nhiều rủi ro bảo mật, đặc biệt là nguy cơ truy cập trái phép, rò rỉ hoặc thay đổi dữ liệu mà không được phép. Các rủi ro được chia thành ba loại: Rủi ro liên quan đến chia sẻ phương tiện lưu trữ, rủi ro liên quan đến vị trí để dữ liệu và rủi ro liên quan đến độ tin cậy của phương tiện lưu trữ.

- Rủi ro liên quan đến chia sẻ phương tiện lưu trữ: Rủi ro đầu tiên liên quan đến việc chia sẻ cơ sở hạ tầng vật lý giữa nhiều người dùng khác nhau. Do nhiều người dùng cùng chia sẻ một không gian lưu trữ vật lý, rủi ro bảo mật dữ liệu tăng lên và ảnh hưởng đến nhiều người. Do đó, việc truy cập trái phép của nhà cung cấp dịch vụ hoặc khách hàng là một vấn đề nghiêm trọng, đặc biệt là dữ liệu nhạy cảm. Trộm cắp, rò rỉ và thay đổi dữ liệu là những rủi ro chính do việc chia sẻ lưu trữ gây ra.
- Rủi ro liên quan đến vị trí để dữ liệu: Dữ liệu người dùng được lưu trữ ở nhiều vị trí khác nhau trên toàn thế giới, người dùng không biết cụ thể chính xác dữ liệu để ở đâu. Ví dụ: Tin nhắn và ảnh được trao đổi qua Facebook đặt ở bất kỳ đâu trên thế giới và người dùng thường không lo lắng nhưng với dữ liệu của tổ chức được đặt trên đám mây thì vị trí của dữ liệu rất quan trọng. Vị trí địa lý của nhà cung cấp đám mây có thể ảnh hưởng tới bảo mật và quyền riêng tư của dữ liệu, thực tế mỗi quốc gia nơi lưu trữ lại có một quy định luật pháp riêng mà dữ liệu đặt tại đó chịu ảnh hưởng của luật pháp.

- Rủi ro liên quan đến độ tin cậy của phương tiện lưu trữ: Người dùng không kiểm soát được quyền truy cập vật lý vào dữ liệu, cần dựa vào nhà cung cấp để bảo mật dữ liệu của mình. Ngoài ra nhà cung cấp dịch vụ có thể ký hợp đồng với bên thứ ba khác mà không thông báo cho người dùng, cũng tăng nguy cơ rủi ro.

Đối với dữ liệu truyền tải (Data-in-transit)

Bảo mật dữ liệu đang truyền đề cập đến bảo mật của việc truyền dữ liệu trên đám mây. Nó đảm bảo dữ liệu sẽ không bị chặn, thay đổi hoặc thay thế. Dữ liệu đang truyền có thể rất nhạy cảm, chẳng hạn như tên người dùng và mật khẩu. Dữ liệu đang truyền có thể gặp rủi ro cao hơn dữ liệu lưu trữ, vì chúng di chuyển từ nơi này sang nơi khác.

Đối với dữ liệu đang sử dụng (Data-in-user)

Trong quá trình đọc hoặc xử lý dữ liệu (tạo, sao chép, xóa) diễn ra trên đám mây đều có nguy cơ rủi ro bảo mật tăng lên khi có người dùng lớn tham gia vào đám mây. Trong môi trường truyền thống, người dùng nắm giữ và quản lý quyền dữ liệu của mình. Tuy nhiên, trong điện toán đám mây, dữ liệu của người dùng có thể được tạo và xử lý bởi bên thứ ba. Vấn đề đối với chủ sở hữu là giữ quyền kiểm soát dữ liệu của mình do người khác tạo ra. Đối với thông tin cá nhân và riêng tư, chủ sở hữu phải biết thông tin cá nhân nào được thu thập và trong một số trường hợp, phải ngừng thu thập và sử dụng thông tin này. Hơn nữa, chủ sở hữu dữ liệu cần đảm bảo rằng việc sử dụng dữ liệu của họ phù hợp với mục đích thu thập và thông tin riêng tư không bị tiết lộ cho bên thứ ba.

Xóa dữ liệu cũng là một vấn đề liên quan đến xử lý dữ liệu trên đám mây. Do đặc điểm vật lý của thiết bị lưu trữ, dữ liệu đã xóa vẫn có thể tồn tại và có thể được khôi phục. Vấn đề này phát sinh khi dữ liệu còn sót lại trên phương tiện lưu trữ sau thao tác xóa. Lưu trữ dữ liệu là một mối đe dọa nghiêm trọng đối với quyền riêng tư dữ liệu, khi dữ liệu bí mật có thể bị tiết lộ, đặc biệt là khi dữ liệu này nằm trong một môi trường không được kiểm soát như đám mây. Mối lo ngại càng gia tăng khi dữ liệu có thể được lưu trữ bởi nhiều môi trường khác nhau. Do đó, nguy cơ rò rỉ dữ liệu của người dùng là rất cao nếu tài nguyên vật lý được người dùng khác sử dụng lại.

1.2.4. Rủi ro từ các dịch vụ điện toán đám mây

1.2.4.1. Rủi ro trong mô hình dịch vụ SaaS

Mô hình SaaS hiện là mô hình điện toán đám mây được áp dụng rộng rãi nhất, nơi các nhà cung cấp phân phối ứng dụng trực tiếp đến người dùng cuối thông qua nền tảng internet. Các ví dụ điển hình và phổ biến cho mô hình này bao gồm Google Workspace, Salesforce và Microsoft 365. Với SaaS, người dùng chỉ cần một tài khoản có kết nối internet để truy cập và sử dụng toàn bộ các chức năng phần mềm ngay lập tức mà hoàn toàn không phải tự mình cài đặt, bảo trì hay vận hành bất kỳ hệ thống hạ tầng phức tạp nào. Mặc dù mang lại sự tiện lợi tối ưu và tiết kiệm chi phí ban đầu, mô hình này cũng đi kèm với không ít điểm yếu bảo mật đáng lo ngại, nổi bật nhất trong số đó là nguy cơ mất quyền kiểm soát dữ liệu (data privacy).

Trong môi trường SaaS, toàn bộ dữ liệu nhạy cảm của doanh nghiệp, từ thông tin khách hàng, tài liệu nội bộ đến dữ liệu tài chính, đều được lưu trữ và xử lý trên cơ sở hạ tầng vật lý do nhà cung cấp sở hữu và quản lý. Điều này đồng nghĩa với việc quyền kiểm soát an ninh thực tế nằm trong tay bên thứ ba. Nếu nhà cung cấp không triển khai các cơ chế bảo vệ mạnh mẽ như mã hóa dữ liệu từ đầu đến cuối (end-to-end encryption) và các hệ thống kiểm soát truy cập (access control) chặt chẽ, dữ liệu có nguy cơ cao bị truy cập trái phép, đánh cắp hoặc thậm chí bị lạm dụng cho các mục đích khác. Rủi ro bị đánh cắp thông tin đăng nhập (credential theft) là một mối đe dọa rất phổ biến và nghiêm trọng. Các cuộc tấn công lừa đảo (phishing), phần mềm độc hại hoặc sử dụng lại mật khẩu yếu có thể dẫn đến việc thông tin xác thực của người dùng bị lộ. Một khi kẻ tấn công chiếm được quyền truy cập vào tài khoản, chúng có thể toàn quyền khai thác mọi dữ liệu và tài nguyên được liên kết với tài khoản đó trên nền tảng, gây ra thiệt hại không lường. Một rủi ro bảo mật khác xuất phát từ lỗi cấu hình sai (misconfiguration) từ phía người dùng. Tính đơn giản và linh hoạt trong chia sẻ dữ liệu đôi khi đã trở thành một lỗ hổng. Chẳng hạn, một nhân viên có thể vô tình chia sẻ một tệp tin chứa thông tin mật trên Google Drive hoặc Microsoft SharePoint ở chế độ "public" thay vì "private" hoặc chỉ giới hạn cho một số người cụ thể, dẫn đến việc dữ liệu công khai ra bên ngoài. Hơn nữa, SaaS còn tiềm ẩn rủi ro từ việc thiếu khả năng giám sát (lack of visibility) đối với doanh nghiệp sử dụng. Vì người dùng không có quyền truy cập trực tiếp hoặc quyền can thiệp vào hạ tầng vật lý bên dưới, khả năng theo dõi nhật ký truy cập (log), giám sát hoạt động bất thường, kiểm tra chi tiết các lần đăng nhập và kịp thời phát hiện sự cố bị hạn chế một cách đáng kể. Doanh nghiệp phải phụ thuộc phần lớn vào các công cụ và báo cáo mà nhà cung cấp cung cấp. Cuối cùng, vấn đề tuân thủ các quy định pháp lý cũng đặt ra những thách thức không nhỏ. Dữ liệu trong mô hình SaaS thường có thể được lưu trữ phân tán tại nhiều trung tâm dữ liệu đặt ở các quốc gia và khu vực pháp lý khác nhau. Điều này khiến việc đảm bảo tuân thủ chặt chẽ các khung quy định về bảo vệ dữ liệu như GDPR (General Data Protection Regulation) của châu Âu, HIPAA (Health Insurance Portability and Accountability Act) cho lĩnh vực chăm sóc sức khỏe tại Mỹ, hay các tiêu chuẩn trong nước trở nên vô cùng phức tạp và đòi hỏi sự minh bạch tuyệt đối từ phía nhà cung cấp dịch vụ.

1.2.4.2. Rủi ro trong mô hình dịch vụ PaaS

Mô hình dịch vụ PaaS cung cấp một môi trường phát triển và triển khai ứng dụng hoàn chỉnh được đóng gói sẵn, bao gồm toàn bộ hạ tầng tính toán cơ bản (máy chủ, lưu trữ, mạng), hệ điều hành, hệ quản trị cơ sở dữ liệu, các phần mềm middleware, cùng với bộ công cụ phát triển (SDK, IDE) và các dịch vụ quản lý. Trong mô hình này, nhà cung cấp dịch vụ đám mây hoàn toàn chịu trách nhiệm cho việc bảo trì, nâng cấp, vá lỗi và vận hành toàn bộ lớp hạ tầng phức tạp bên dưới. Điều này cho phép các nhà phát triển và doanh nghiệp (người dùng) có thể dồn toàn bộ tâm sức và tài nguyên vào việc viết mã, kiểm thử, triển khai và vận hành ứng dụng của chính mình một cách nhanh chóng và hiệu quả mà không cần lo lắng về các vấn đề phần cứng.

Trong đó đi kèm với một loạt các rủi ro bảo mật đặc thù, phần lớn phát sinh từ việc kiểm soát được phân chia giữa nhà cung cấp và khách hàng như:

- **Giao diện Lập trình Ứng dụng (API) không an toàn:** Các API là cầu nối giao tiếp chính giữa ứng dụng của người dùng với các dịch vụ cốt lõi của nền tảng PaaS. Chúng quản lý mọi thứ từ triển khai mã, quản lý cơ sở dữ liệu đến điều phối các dịch vụ. Nếu các API này không được thiết kế với nguyên tắc bảo mật tối ưu ngay từ đầu như thiếu cơ chế xác thực mạnh mẽ (ví dụ: OAuth, API keys), ủy quyền yếu, mã hóa kém hoặc dễ bị tổn thương bởi các cuộc tấn công phổ biến như SQL Injection hay Cross-Site Scripting (XSS) – chúng sẽ trở thành điểm đầu vào lý tưởng cho kẻ tấn công. Thông qua các lỗ hổng này, kẻ xấu có thể chiếm quyền điều khiển dịch vụ, đánh cắp dữ liệu nhạy cảm, thao túng cấu hình, hoặc thậm chí là tấn công từ chối dịch vụ (DoS) vào toàn bộ nền tảng.
- **Rủi ro từ các thư viện và Framework của bên thứ ba:** Các thư viện, framework và phần mềm mã nguồn mở được tích hợp sẵn, cho phép nhà phát triển tăng tốc độ xây dựng ứng dụng. Tuy nhiên, điều này cũng đồng nghĩa với việc ứng dụng kế thừa mọi lỗ hổng bảo mật tồn tại trong các thành phần phụ thuộc đó. Một lỗ hổng nghiêm trọng (như trong Log4j) trong một thư viện được sử dụng rộng rãi có thể ngay lập tức biến thành một cuộc khủng hoảng tấn công chuỗi cung ứng trên quy mô lớn, ảnh hưởng đến hàng nghìn ứng dụng được triển khai trên nền tảng. Trách nhiệm cập nhật và vá các lỗ hổng này thường thuộc về người dùng, nhưng việc thiếu sự minh bạch và cảnh báo kịp thời từ nhà cung cấp PaaS có thể khiến các nhà phát triển không biết rằng ứng dụng của họ đang gặp nguy hiểm.
- **Rủi ro của mô hình đa người dùng (Multi-tenancy):** Về mặt kinh tế, hiệu quả của PaaS dựa trên mô hình đa người dùng, nơi nhiều ứng dụng của nhiều khách hàng khác nhau cùng chia sẻ chung một nền tảng hạ tầng vật lý cơ bản (CPU, bộ nhớ, mạng). Mặc dù các nhà cung cấp lớn sử dụng các công nghệ ảo hóa và cách ly tiên tiến, nhưng về mặt lý thuyết, việc cách ly không hoàn hảo vẫn có thể xảy ra. Một kẻ tấn công tinh vi có thể nhắm mục tiêu vào một "tenant" (khách hàng) yếu hơn trên cùng một máy chủ vật lý và thực hiện các kỹ thuật tấn công side-channel (kênh kề) hoặc khai thác lỗ hổng trong hypervisor để vượt qua ranh giới cách ly, từ đó truy cập trái phép hoặc làm rò rỉ dữ liệu nhạy cảm từ các ứng dụng của khách hàng khác. Đây là mối lo ngại hàng đầu về quyền riêng tư dữ liệu.
- **Leo thang đặc quyền (Privilege Escalation):** Trong môi trường PaaS, mỗi ứng dụng thường được chạy với một tập hợp các đặc quyền (permissions) nhất định để tương tác với các dịch vụ của nền tảng. Nếu ứng dụng ban đầu được cấp quá nhiều đặc quyền không cần thiết hoặc chứa lỗ hổng cho phép thực thi mã tùy ý, kẻ tấn công có thể lợi dụng để thực hiện leo thang đặc quyền. Chúng có thể chiếm quyền điều khiển ứng dụng và sử dụng các đặc quyền đó để tấn công sâu hơn

vào các dịch vụ nền tảng khác, kiểm soát các ứng dụng khác, hoặc thậm chí là giành quyền truy cập vào chính hệ thống quản lý của nhà cung cấp PaaS, dẫn đến hậu quả thảm khốc trên diện rộng.

- Khóa nhà cung cấp (Vendor Lock-In): Về lâu dài, một rủi ro chiến lược không kém phần quan trọng là tình trạng phụ thuộc quá mức vào một nhà cung cấp PaaS duy nhất. Các nền tảng này thường sử dụng các API, dịch vụ quản lý, công cụ triển khai và định dạng dữ liệu độc quyền. Một khi một ứng dụng đã được xây dựng và vận hành trên một nền tảng cụ thể, việc di chuyển nó sang một nhà cung cấp khác vô cùng khó khăn, tốn kém và mất thời gian. Về mặt bảo mật, nếu nhà cung cấp hiện tại có những lỗ hổng hoặc không đáp ứng được các yêu cầu tuân thủ mới, khách hàng sẽ gặp rất ít lựa chọn thay thế khả thi.

1.2.4.3. Rủi ro trong mô hình dịch vụ IaaS

Mô hình dịch vụ IaaS đại diện cho lớp cơ sở của điện toán đám mây, nơi các nhà cung cấp như Amazon Web Services (AWS), Microsoft Azure hay Google Cloud Platform (GCP) cung cấp các tài nguyên điện toán cốt lõi dưới dạng được ảo hóa hoàn toàn. Các tài nguyên này bao gồm sức mạnh xử lý (máy chủ ảo - VMs), không gian lưu trữ và các thành phần mạng như switch, router ảo và địa chỉ IP. Ưu điểm chính của IaaS là nó trao cho người dùng sự linh hoạt và kiểm soát gần như tuyệt đối; họ có toàn quyền cài đặt, cấu hình và quản lý hệ điều hành, middleware, môi trường runtime và các ứng dụng của riêng mình. Tuy nhiên, chính đặc tính “ảo hóa và chia sẻ tài nguyên” trên một hạ tầng vật lý dùng chung (multi-tenancy) này lại là nguồn gốc phát sinh một loạt các mối đe dọa bảo mật phức tạp và đặc thù, đòi hỏi một mô hình trách nhiệm được chia sẻ (Shared Responsibility Model) giữa nhà cung cấp và khách hàng.

Đầu tiên rủi ro tấn công thoát khỏi máy ảo (VM Escape) được coi là một trong những mối đe dọa nghiêm trọng và đặc thù nhất của môi trường ảo hóa. Hypervisor (hay Virtual Machine Monitor - VMM) là lớp phần mềm quản lý và phân phối tài nguyên vật lý cho các máy ảo, đồng thời đảm bảo sự cách ly giữa chúng. Một cuộc tấn công VM Escape xảy ra khi kẻ tấn công, sau khi đã xâm nhập được vào một máy ảo, có thể khai thác các lỗ hổng zero-day hoặc chưa được vá trong chính hypervisor để "thoát ra" khỏi môi trường bị cô lập của máy ảo đó. Khi thoát ra thành công, kẻ tấn công có quyền truy cập trực tiếp vào lớp hạ tầng vật lý cơ bản hoặc host OS. Điều này cho phép kẻ tấn công không chỉ chiếm đoạt toàn bộ máy chủ vật lý mà còn có thể giám sát, kiểm soát và đánh cắp dữ liệu từ tất cả các máy ảo khác đang chạy trên cùng một server, gây ra mối đe dọa thảm khốc đến tính toàn vẹn, tính bảo mật và tính sẵn sàng của toàn bộ hệ thống.

Thứ hai, các tấn công kênh phụ (side-channel attacks) là một dạng tấn công tinh vi, khó phát hiện và phòng ngừa. Khác với các cuộc tấn công trực tiếp, hình thức này khai thác các đặc điểm vật lý hoặc thời gian thực thi của các tài nguyên phần cứng dùng chung (như cache CPU, bộ nhớ, các đơn vị xử lý đồ họa - GPU) để suy luận và trích xuất thông tin nhạy cảm từ một máy ảo khác. Ví dụ, bằng cách phân tích các mẫu truy cập bộ nhớ cache hoặc thời gian thực thi các lệnh nhất định, kẻ tấn công có thể dần dần tái tạo khóa mã hóa (encryption key) hoặc dữ liệu thô từ

máy ảo nạn nhân. Nguy hiểm hơn, những cuộc tấn công này có thể được thực hiện mà không cần kẻ tấn công phải xâm nhập trực tiếp vào máy ảo mục tiêu, khiến cho các công cụ giám sát bảo mật lỗi thời không còn hiệu quả.

Tiếp theo cấu hình lỗi được xem là nguyên nhân hàng đầu dẫn đến các sự cố rò rỉ dữ liệu và vi phạm bảo mật trong môi trường IaaS. Sự phức tạp và linh hoạt của các dịch vụ đám mây thường dẫn đến những sai sót của con người trong việc thiết lập các chính sách bảo mật. Các lỗi phổ biến bao gồm: để mở các cổng dịch vụ nhạy cảm (như SSH - port 22, RDP - port 3389) ra địa chỉ Internet, cấu hình sai các nhóm bảo mật hoặc danh sách kiểm soát truy cập mạng, cho phép bất kỳ ai cũng có thể truy cập vào các bucket lưu trữ (ví dụ: Amazon S3) chứa dữ liệu nhạy cảm; hoặc sử dụng các thông tin xác thực mặc định và yếu. Hậu quả là, các tài nguyên quan trọng vô tình công khai ra Internet mà không có bất kỳ sự bảo vệ nào, trở thành mục tiêu dễ dàng cho các bot tự động quét mạng và các hacker. Rất nhiều vụ rò rỉ dữ liệu lớn được công bố trên truyền thông đều bắt nguồn từ những lỗi cấu hình tưởng chừng rất đơn giản này.

Cuối cùng các rủi ro liên quan đến vòng đời dữ liệu và tính sẵn sàng cũng là mối quan tâm lớn. Hiện tượng dữ liệu tồn lưu (Data Persistence) xảy ra khi một khối lưu trữ hoặc một máy ảo bị xóa bỏ nhưng dữ liệu trên đó không được xóa sạch một cách an toàn. Nhà cung cấp có thể tái sử dụng tài nguyên này cho một khách hàng khác, dẫn đến nguy cơ khách hàng mới có thể khôi phục lại dữ liệu nhạy cảm của người dùng trước đó. Mặt khác, các cuộc tấn công từ chối dịch vụ (DoS/DDoS) nhằm vào hạ tầng IaaS có thể làm nghẽn hệ thống mạng hoặc tài nguyên máy chủ bằng một lượng lớn lưu lượng truy cập độc hại. Điều này làm cạn kiệt tài nguyên, khiến các dịch vụ hợp pháp không thể truy cập được, gây gián đoạn nghiêm trọng đến hoạt động kinh doanh và trực tiếp tấn công vào khả năng sẵn sàng của hệ thống.

1.3. Kết luận chương 1

Chương 1 của đề án đã thực hiện một nghiên cứu toàn diện về điện toán đám mây và các rủi ro bảo mật đặc thù đi kèm, từ việc khảo cứu lịch sử ra đời và khái niệm nền tảng, có thể thấy điện toán đám mây không phải là một công nghệ đột phá mà là sự phát triển tất yếu của các mô hình phân phối điện toán, mang lại một cuộc cách mạng trong cách thức các tổ chức tiêu thụ và quản lý tài nguyên CNTT. Điện toán đám mây ra đời là kết quả của sự phát triển liên tục trong các lĩnh vực ảo hóa, điện toán phân tán và công nghệ mạng. Từ những mô hình mainframe những năm 1960 đến các dịch vụ đám mây hiện đại như AWS, Azure hay Google Cloud ngày nay, điện toán đám mây đã chứng minh được vai trò không thể thiếu trong việc cung cấp tài nguyên CNTT một cách linh hoạt và tiết kiệm. Khái niệm cốt lõi của điện toán đám mây là cung cấp các dịch vụ tính toán qua Internet theo nhu cầu, giúp người dùng có thể truy cập tài nguyên mọi lúc, mọi nơi mà không cần quan tâm đến hạ tầng vật lý phía sau. Ưu điểm nổi bật của điện toán đám mây bao gồm khả năng giảm thiểu chi phí đầu tư ban đầu nhờ mô hình trả phí theo nhu cầu, khả năng mở rộng hoặc thu hẹp tài nguyên linh hoạt, và tính sẵn sàng cao với hệ thống được phân bố trên nhiều trung tâm dữ liệu toàn cầu. Tuy nhiên, mô hình này cũng

tồn tại một số hạn chế như rủi ro về bảo mật dữ liệu, sự phụ thuộc vào nhà cung cấp dịch vụ và yêu cầu kết nối Internet ổn định.

Thông qua việc phân tích các mô hình triển khai (Public, Private, Hybrid, Community) và đặc biệt là ba mô hình dịch vụ chủ chốt (IaaS, PaaS, SaaS), chương này đã làm rõ sự phân chia trách nhiệm rõ ràng giữa nhà cung cấp và người dùng – một yếu tố then chốt quyết định đến phạm vi kiểm soát và trách nhiệm bảo mật của mỗi bên. Các ưu điểm vượt trội về tính kinh tế, khả năng mở rộng linh hoạt và tốc độ triển khai là động lực chính thúc đẩy sự chấp nhận rộng rãi điện toán đám mây. Tuy nhiên, những nhược điểm tiềm ẩn, đặc biệt là các thách thức về bảo mật, quyền riêng tư dữ liệu và sự phụ thuộc vào nhà cung cấp, đặt ra những bài toán phức tạp cho các tổ chức.

Trọng tâm của chương nằm ở việc đi sâu phân tích chi tiết các mối đe dọa và rủi ro an toàn thông tin trong điện toán đám mây. Các rủi ro này không tập trung vào một điểm duy nhất mà xuất hiện xuyên suốt toàn bộ kiến trúc và vòng đời dịch vụ:

- Rủi ro từ kiến trúc nổi bật với mô hình đa người dùng (multi-tenancy) và các giao diện quản lý công cộng, làm gia tăng bề mặt tấn công.
- Rủi ro từ quản lý truy cập và xác thực cho thấy sự nguy hiểm của việc quản lý danh tính kém, leo thang đặc quyền và thỏa hiệp thông tin xác thực, có thể dẫn đến mất mát dữ liệu trên diện rộng.
- Rủi ro từ dữ liệu nhấn mạnh các thách thức trong việc bảo vệ tính bí mật, toàn vẹn của dữ liệu cả khi lưu trữ (at rest) và truyền tải (in transit), cũng như các vấn đề về thu hồi và xóa bỏ dữ liệu triệt để.

Cuối cùng, việc phân tích rủi ro theo từng mô hình dịch vụ (SaaS, PaaS, IaaS) đã chỉ ra rằng mỗi mô hình đều có những điểm yếu bảo mật đặc thù. Trong khi SaaS chủ yếu đối mặt với rủi ro về quyền riêng tư dữ liệu và quản lý quyền truy cập, thì PaaS lại dễ bị tổn thương bởi các API không an toàn và lỗ hổng trong các thư viện bên thứ ba. Ở cấp độ IaaS, mặc dù người dùng có quyền kiểm soát cao nhất, nhưng cũng phải đối mặt với những mối đe dọa phức tạp nhất, từ các cuộc tấn công vào lớp ảo hóa (VM Escape, Side-channel) cho đến gánh nặng trong việc tự quản lý, cấu hình và vá lỗi toàn bộ hạ tầng ảo.

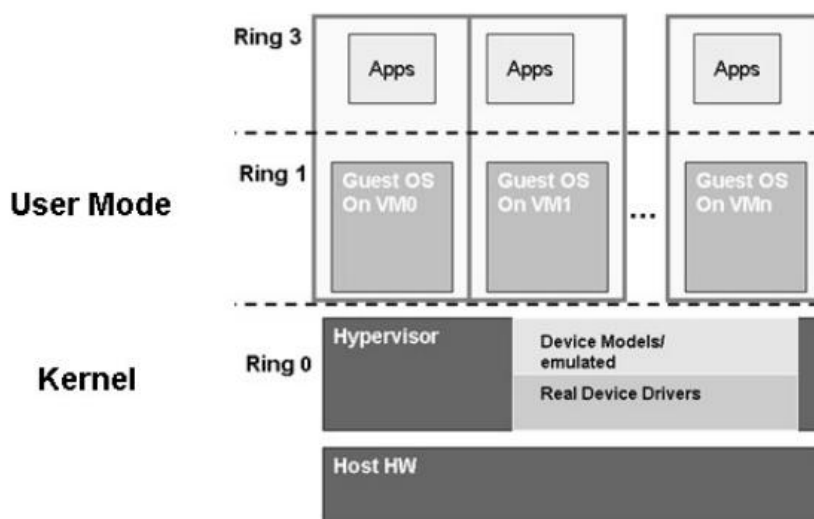
CHƯƠNG 2. GIẢI PHÁP ĐẢM BẢO AN TOÀN DỊCH VỤ TRONG ĐIỆN TOÁN Đám Mây

2.1. Giải pháp đảm bảo an toàn dịch vụ điện toán đám mây

2.1.1. Giải pháp đảm bảo kiến trúc đám mây

Bảo mật ảo hóa (Virtualization Security)

Hypervisor cung cấp khả năng cô lập giữa các hệ điều hành khách, đồng thời quản lý quyền truy cập của chúng vào phần cứng ảo hóa. Việc cô lập này là mối quan tâm lớn đối với bảo mật máy ảo (VM), bởi vì đây là một kỹ thuật mạnh mẽ để ngăn chặn hệ điều hành khách khỏi các cuộc tấn công có thể lây nhiễm toàn bộ hệ điều hành khách. Điều này có thể mang lại lợi ích cho các nhà bảo mật; mặt khác, nó cũng có thể mang lại lợi ích cho kẻ tấn công và bằng cách khai thác bảo mật cho toàn bộ hệ thống. Nếu một kẻ tấn công chiếm ưu thế trong trình quản lý giám sát, tại thời điểm này, kẻ tấn công có toàn quyền kiểm soát tất cả các tài nguyên trong trình quản lý siêu giám sát bao gồm cả hệ điều hành của khách chạy trên đó. Điều này có nghĩa là kẻ tấn công đã khai thác thành công vòng 0 trên máy chủ mà không cần leo thang thêm, tuy nhiên khả năng xảy ra cuộc tấn công này rất phức tạp vì trình quản lý siêu giám sát có ít mã hơn và chạy ở mức bảo mật đặc quyền nhất.



Hình 2.1: Kiến trúc Hypervisor (Type 1)

Kiểu tấn công này rất quan trọng đối với các công ty có kiến trúc đám mây. Ví dụ: Một cuộc tấn công gần đây vào một công ty Anh có tên là Vaserv.com là bằng chứng rõ ràng về mối đe dọa bảo mật như vậy đối với trình quản lý ảo hóa. Kẻ tấn công đã sử dụng lỗ hổng zero-day trong Hypervisor để khởi chạy cuộc tấn công vào một ứng dụng ảo hóa do công ty phát triển. 100.000 trang web được lưu trữ trên veserv.com đã bị phá hủy. Lỗ hổng zero-day này cho phép tin tặc chạy các lệnh UNIX đặc quyền trên hệ thống mục tiêu, bao gồm các lệnh (rm -rf), gây ra việc xóa đệ quy tất cả các tệp. Cuộc tấn công đã gây ra thiệt hại lớn cho công ty, 50% khách hàng của Vaserv đã bị mất dữ liệu [6].

Các nhà nghiên cứu bảo mật Tom Liston và Ed Skoudis đã trình diễn một số công cụ có thể được phát triển để tạo ra các cuộc tấn công thoát khỏi máy ảo (VM Escape) [7]. Các công cụ này là:

- VMchat: Phần mềm chat đơn giản này sử dụng kênh giao tiếp ảo hóa VMware làm cửa sau để gửi tin nhắn qua lại giữa các hệ điều hành của máy khách hoặc giữa hệ điều hành của máy khách và máy chủ. Phần mềm đơn giản này không yêu cầu cài đặt bất kỳ mã đặc biệt nào. Một cuộc tấn công tiêm DLL có thể khai thác VMware trên hệ điều hành máy chủ, cho phép ứng dụng đang chạy trên máy chủ truy cập vào bộ nhớ của máy khách VMware. Khi điều này xảy ra, bộ đệm bộ nhớ sẽ được sử dụng làm kênh trao đổi giữa máy chủ và máy khách như một bộ đệm dùng chung. Công cụ này không hoàn toàn thoát khỏi máy ảo; tuy nhiên, nó khai thác ranh giới giữa máy chủ và VMware. [7].
- VMcat: Tiện ích mở rộng công cụ này cho ý tưởng VMchat để gửi đầu ra đơn giản của (stdin) và (stdout) giữa kênh giao tiếp được tạo bằng VMchat, có thể được sử dụng để tạo đường hầm cho shell lệnh giữa máy chủ và khách[7].
- VM Drag-n-Sploit: Bằng cách thay đổi thành phần VMware trên máy khách (VMwareService.exe), các nhà nghiên cứu đã thành công trong việc giám sát và thay đổi tất cả dữ liệu truyền qua kênh truyền thông. Điều này cho phép chạy mã trong hệ điều hành máy khách, cho phép thay thế tệp đang được kéo-thả bằng tệp tùy ý [7].
- VMftp: Người dùng trên bất kỳ hệ điều hành khách nào có bất kỳ cấp độ đặc quyền nào đều có thể đọc và ghi dữ liệu vào hệ điều hành máy chủ trong suốt quá trình thư mục chia sẻ được bật và một thư mục được chia sẻ với máy ảo khách [7].

Có ba loại tấn công phần mềm độc hại có thể được sử dụng để khai thác máy ảo:

- Tấn công dễ nhất, có thể được thực hiện bằng cách sử dụng phần mềm độc hại được dùng để phát hiện trình giả lập máy ảo. Mã độc hại như thế này rất nhạy cảm với sự tồn tại của máy ảo (VM). Mục đích của việc phát hiện nền tảng máy ảo là làm cho việc phân tích phần mềm độc hại trở nên khó khăn hơn và thậm chí không thể phát hiện được đối với các nhà nghiên cứu phần mềm độc hại.
- Tấn công phức tạp, chẳng hạn như từ chối dịch vụ (DDOS), có thể khiến trình giả lập máy ảo bị sập.
- Tấn công phức tạp nhất là tấn công thoát khỏi máy ảo (Escape Attack).

2.1.2. Giải pháp quản lý truy cập và xác thực

Mục tiêu của quản lý truy cập và xác thực là ngăn chặn sự xâm nhập của người dùng trái phép. Do đó người dùng cần có quyền riêng biệt để truy cập được dữ liệu, tài nguyên. Dưới đây là các thuật toán được sử dụng trong quá trình mã hóa:

Thuật toán RSA

Giao tiếp được bảo vệ thông qua thuật toán mã hóa RSA[8]. Thông thường, khi các yêu cầu của người dùng được gửi đến hệ thống CSP, chúng sẽ được mã hóa. Thuật toán RSA sử dụng khóa công khai của hệ thống để mã hóa. Thuật toán mã hóa RSA mã hóa hệ thống tệp thông qua khóa công khai của người dùng bất cứ khi nào họ yêu cầu. Sau đó, khi đăng nhập vào hệ thống, với sự trợ giúp của thuật toán RSA, một tệp đã mã hóa sẽ được trình duyệt của người dùng giải mã sau khi tệp được nhận từ hệ thống. Tương tự như vậy, khi hệ thống nhận được một tệp được mã hóa bằng khóa riêng của nó, nó sẽ giải mã ngay lập tức. Cuối cùng, sẽ có giao tiếp an toàn giữa người dùng và hệ thống.

Mã hóa nâng cao (Advanced Encryption Standard - AES) và MD5

Thuật toán mã hóa nâng cao (AES) tạo điều kiện thuận lợi cho việc mã hóa tệp bởi máy chủ hệ thống khi người dùng tải tệp lên. Các bit khóa như 128, 192, 256 có thể được sử dụng trong AES. Máy chủ hệ thống tạo khóa ngẫu nhiên. Mỗi khóa chỉ được sử dụng một lần. Ví dụ, tệp của người dùng được mã hóa và giải mã bằng một khóa duy nhất. Sau đó, trong bất kỳ trường hợp nào, khóa này không còn được sử dụng nữa. Bên cạnh tên tài khoản người dùng, khóa được lưu giữ trong bảng cơ sở dữ liệu của máy chủ hệ thống. Hàm băm Message Digest 5 (MD5) [9] được sử dụng để băm tên tài khoản người dùng trước khi chèn. Điều này đảm bảo rằng chỉ bằng cách truy cập và theo dõi bảng cơ sở dữ liệu của máy chủ hệ thống, một người không được ủy quyền sẽ không bao giờ có thể lấy lại khóa để giải mã một khóa cụ thể cho một người dùng cụ thể. Kết quả là, khóa của tệp cụ thể được ẩn và bảo mật.

Sử dụng mật khẩu dùng một lần (Open Time Password - OTP)

Trong thuật toán này, người dùng được xác thực bằng mật khẩu dùng một lần (OTP)[10]. Trong mô hình bảo mật đề xuất, người dùng được xác thực bằng mật khẩu dùng một lần (OTP) để bảo vệ tài khoản khỏi truy cập trái phép. Mỗi lần đăng nhập, hệ thống tạo ngẫu nhiên một OTP mới và gửi đến email đã được ủy quyền của người dùng, thay thế OTP cũ. OTP chỉ dùng một lần cho mỗi phiên đăng nhập, đồng thời xác minh tính hợp lệ của người dùng trước khi cho phép kết nối với hệ thống đám mây.

Tiêu chuẩn mã hóa dữ liệu (Data Encryption Standard - DES)

Thuật toán Tiêu chuẩn Mã hóa Dữ liệu (DES) là thuật toán mã hóa khóa đối xứng, sử dụng một khóa bí mật duy nhất cho cả mã hóa và giải mã. Trong DES, khóa bí mật đóng vai trò then chốt, được tạo bởi bộ tạo khóa động có khả năng thay đổi và không lặp lại, giúp tăng tốc độ xử lý và giảm độ phức tạp logic.

Mã hóa Rijndael

Việc mã hóa thông tin nhạy cảm được thực hiện bằng thuật toán mã hóa khóa đối xứng tiêu chuẩn được gọi là Rijndael, một thuật toán mã hóa khối lặp. Việc lặp lại một phép biến đổi cụ thể sẽ hoàn tất việc mã hóa một khối dữ liệu. Rijndael sử dụng các mảng byte 8 bit một chiều, tạo ra các khối dữ liệu, làm đầu vào. Đầu vào là văn bản thuần túy, và sau đó được ánh xạ vào các byte trạng thái. Ngoài ra, khóa mã hóa hoạt động như một mảng byte 8 bit một chiều. Các phép biến đổi nhiều lần hoạt động trong một mảng trên các trạng thái mã hóa tạm thời và một mã hóa khối lặp [11].

Một số giao thức xác thực:

Xác thực thách thức-phản hồi (challenge-response) dựa trên mật khẩu. Về bảo mật máy tính, xác thực thách thức-phản hồi là một giao thức khởi nguồn, trong đó một truy vấn được mô hình hóa bởi một bên ("thách thức"), và bên kia phải đưa ra câu trả lời được ủy quyền ("phản hồi") để được xác thực. Với mật khẩu, thách thức là yêu cầu nhập mật khẩu và phản hồi đúng là mật khẩu hợp lệ. Mỗi mã định danh có thể gắn với nhiều mật khẩu được chọn riêng, giúp ngăn dự đoán phản hồi và làm gián đoạn quy trình xác thực.

Giao thức đăng nhập một lần (Single Sign-On - SSO)

Trong môi trường đám mây, giao thức SAML (Security Assertion Markup Language)[12] hỗ trợ đăng nhập một lần (SSO) cho phép người dùng truy cập nhiều tài nguyên từ các nhà cung cấp ứng dụng khác nhau mà không cần xác thực lại. Máy chủ SAML phát hành vé xác minh danh tính, đảm bảo chỉ người dùng đã đăng ký mới được truy cập theo vai trò và cấp độ quyền hạn. Quá trình xác thực và ủy quyền xác định danh tính người dùng, các tài nguyên được phép truy cập và hành động có thể thực hiện. Mô hình này cũng được áp dụng phổ biến trên các nền tảng như Facebook hay Google, cho phép đăng nhập nhiều dịch vụ bằng cùng một bộ thông tin nhận dạng. Tương tự, cùng với các liên kết đến các trang mạng nội bộ liên quan đến bảo hiểm y tế, bảng chấm công hoặc tin tức tổ chức, bất kỳ doanh nghiệp nào cũng nên sở hữu một công thông tin nội bộ dành cho nhân viên. Đây là một cách tốt hơn để nhân viên đăng nhập vào một công thông tin tự động xác thực người dùng với các trang mạng nội bộ khác thay vì phải đăng nhập bởi một nhân viên tại nhiều trang web khác nhau. Khái niệm cho phép người dùng nhập một tên người dùng và mật khẩu để truy cập các ứng dụng khác nhau được gọi là đăng nhập một lần (SSO). Người dùng được hưởng lợi rất nhiều. Họ chỉ quản lý một tên người dùng và mật khẩu để sử dụng các danh tính được liên kết với trang web liên quan. Vì người dùng có thể ngăn chặn nhiều lần đăng nhập, có trải nghiệm tốt hơn. Thay vì lưu trữ nhiều xác thực trên nhiều cơ sở dữ liệu, xác thực người dùng (một bộ duy nhất) sẽ nằm trong một cơ sở dữ liệu. Điều này đơn giản có nghĩa là các nhà phát triển của nhiều ứng dụng không cần phải lưu trữ mật khẩu. Ngoài ra, từ một nguồn đã được xác thực, họ có thể chấp nhận bằng chứng nhận dạng hoặc ủy quyền. Việc triển khai SSO có nhiều giải pháp. SAML, Open Authorization (OAuth) và Open-ID là ba giao thức bảo mật web được sử dụng thường xuyên. Hiện đã có nhiều triển khai và thư viện bằng nhiều ngôn ngữ, và thay vì một giải pháp tùy chỉnh, việc áp dụng một giao thức được hệ thống hóa mang lại khả năng tương tác tốt hơn.

Chuẩn xác thực OpenID (O-ID)

OpenID là một tiêu chuẩn mở và là một giao thức authen được phân cấp. Được phát triển bởi tổ chức phi lợi nhuận OpenID Foundation, OpenID cho phép user có thể được authen bởi rất nhiều website (Relying Parties hoặc RP) sử dụng service của bên thứ 3. Nó giảm được việc phải thiết lập riêng logic sign up/login cho mỗi website, cho phép các user có thể login tới nhiều webstie ko hề liên quan tới nhau mà ko cần phải có những định danh và password riêng cho mỗi site. Với OpenID, chỉ duy nhất identity provider quản lý password, và provider này sẽ

confirm identity tới các website đã truy cập, ko có một website nào có thể biết được password - đây là một yếu tố bảo mật rất cao.

Giao thức OAuth2 (OA-2)

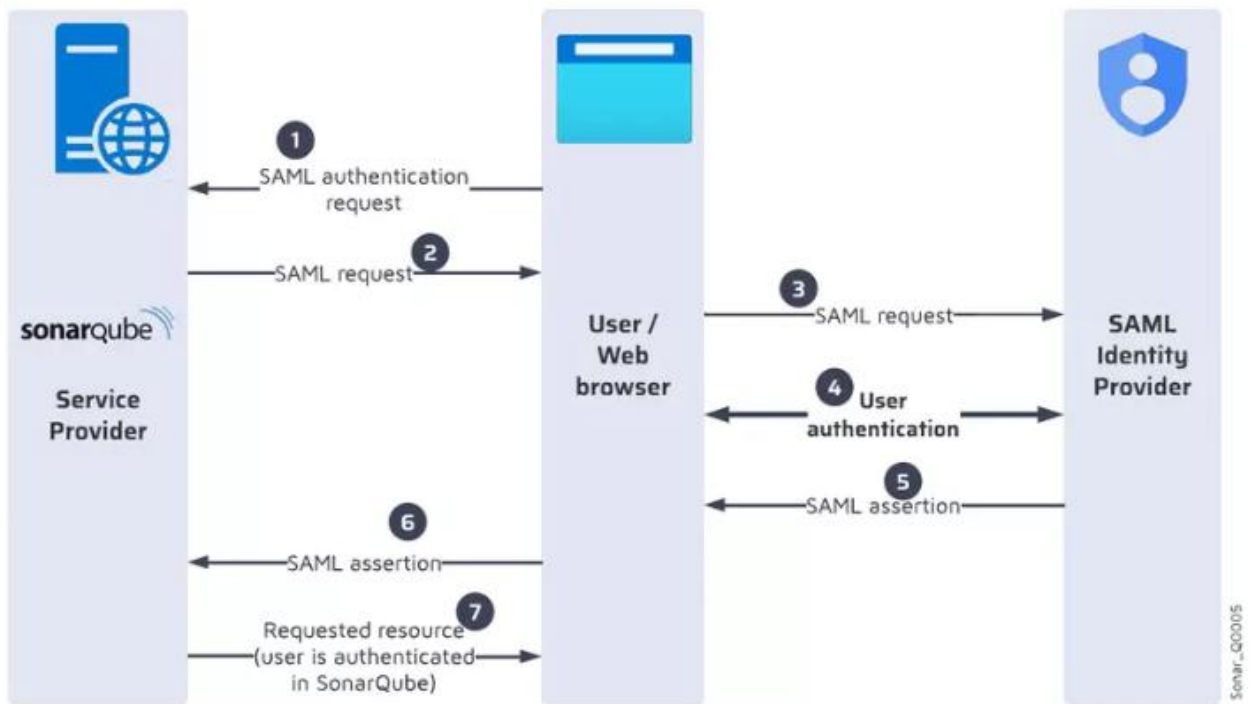
OAuth2 là bản nâng cấp của OAuth1.0, là một giao thức chứng thực cho phép các ứng dụng chia sẻ một phần tài nguyên với nhau mà không cần xác thực qua username và password như cách truyền thống từ đó giúp hạn chế được những phiền toái khi phải nhập username, password ở quá nhiều nơi hoặc đăng ký quá nhiều tài khoản mật khẩu mà không thể nhớ hết. Trong OAuth2 định nghĩa 4 vai trò:

- Resource owner: Là những người dùng có khả năng cấp quyền truy cập, chủ sở hữu của tài nguyên mà ứng dụng muốn lấy.
- Resource server: Nơi lưu trữ các tài nguyên, có khả năng xử lý yêu cầu truy cập đến các tài nguyên được bảo vệ.
- Client: Là những ứng dụng bên thứ 3 muốn truy cập vào phần tài nguyên được chia sẻ với tư cách của người sở hữu (resource owner) và tất nhiên trước khi truy cập ứng dụng cần được sự ủy quyền của user.
- Authorization server: Làm nhiệm vụ xác thực, kiểm tra thông tin mà user gửi đến từ đó cấp quyền truy cập cho ứng dụng bằng việc sinh ra các đoạn mã access token. Đôi khi authorization server cũng chính là resource server.

Security Assertion Markup Language (SAML)

SAML là một chuẩn dựa trên XML dùng để trao đổi thông tin xác thực (authentication) và ủy quyền (authorization) giữa các bên, thường được sử dụng cho Single Sign-On (SSO) trong các ứng dụng doanh nghiệp. SAML gồm các thành phần:

- Users: người dùng muốn truy cập vào ứng dụng/dịch vụ được liên kết với một bên xác thực
- Service Providers (SP): Ứng dụng/dịch vụ mà người dùng muốn sử dụng, SP dựa vào IdP để xác minh danh tính người dùng thông qua SAML và cấp cho User quyền truy cập dựa trên thông tin được cấp
- Identity Providers (IdP): Bên thứ ba đáng tin cậy xác nhận thông tin đăng nhập của người dùng và lưu giữ thông tin về đặc tính nhận dạng, quyền truy cập của người dùng



Hình 2.2: Mô hình hoạt động SAML

1. User truy cập trang web hoặc ứng dụng của (SP), kích hoạt quá trình xác thực SAML.
2. SP tạo yêu cầu SAML (cho IdP) và gửi lại cho User.
3. User tự động chuyển tiếp yêu cầu SAML đến cho (IdP).
4. (IdP) xác thực người dùng và tạo xác nhận SAML chứa thông tin và quyền của người dùng. Dựa vào cấu hình được thống nhất mà xác nhận SAML được mã hóa theo phương pháp đã chọn.
5. (IdP) gửi xác nhận SAML cho User.
6. User tự động chuyển tiếp xác nhận SAML tới (SP) để được xác thực và phân quyền.
7. (SP) phản hồi với người dùng những thông tin họ được truy cập.

2.1.3. Giải pháp bảo vệ dữ liệu lưu trữ và truyền tải

Dữ liệu trên đám mây có thể ở nhiều trạng thái khác nhau: đang lưu trữ, đang sử dụng, đang truyền tải do đó không có cùng mức độ yêu cầu bảo mật. Dữ liệu đang được xử lý không thể được bảo vệ bằng các phương tiện tương tự như dữ liệu đang truyền tải hoặc dữ liệu đang lưu trữ.

Phương pháp chính được sử dụng để bảo vệ dữ liệu được truyền và lưu trữ là mã hóa. Phương pháp này vẫn còn hiệu lực cho môi trường đám mây hiện nay. Tuy nhiên, giải pháp này không phải lúc nào cũng khả thi đối với dữ liệu tĩnh, thực tế, việc mã hóa dữ liệu đơn giản trong dịch vụ IaaS là khả thi nhưng việc mã hóa dữ liệu trong ứng dụng PaaS hoặc SaaS không phải lúc nào cũng khả thi. Dữ liệu tĩnh được sử dụng bởi các ứng dụng đám mây thường không được mã hóa vì mã hóa ngăn chặn việc lập chỉ mục và tìm kiếm dữ liệu. Điều này đúng với dữ liệu đang sử dụng, phải ở dạng rõ ràng đối với nhiều ứng dụng. Năm 2009, IBM đã công bố việc phát triển mã hóa đồng hình (Homomorphic Encryption - HE) hoàn

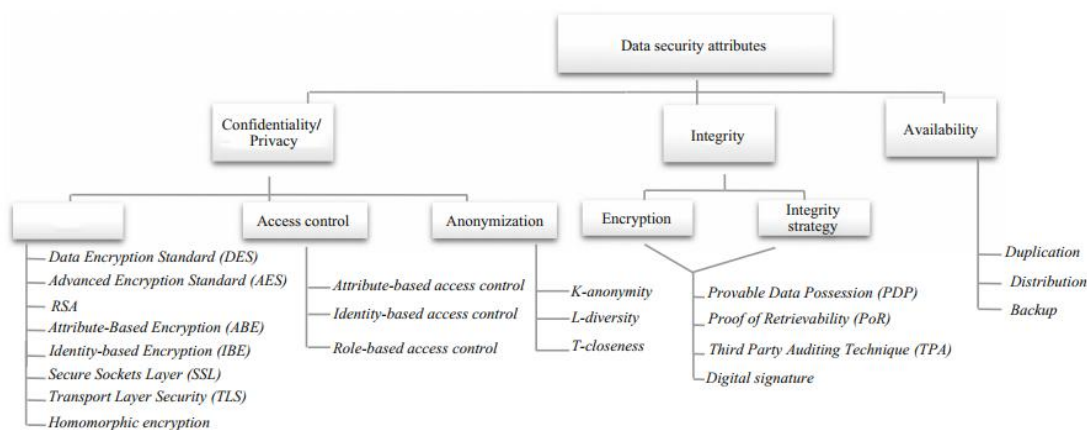
chính cho phép dữ liệu được xử lý bởi các ứng dụng mà không cần giải mã. Nhược điểm lớn nhất của kỹ thuật này là chi phí và độ phức tạp về mặt tính toán. Đối với dữ liệu đang truyền, việc sử dụng mã hóa đơn thuần là không đủ để bảo mật loại dữ liệu này, mã hóa phải đảm bảo tính bảo mật nhưng không đảm bảo tính toàn vẹn. Do đó, các thuật toán mã hóa thường được kết hợp với các giao thức bảo mật cũng như thiết bị bảo mật mạng. Hơn nữa, các kỹ thuật mã hóa cho dữ liệu tĩnh và dữ liệu đang truyền có thể khác nhau. Ví dụ, khóa mã hóa cho dữ liệu đang truyền có thể có thời hạn ngắn, trong khi khóa cho dữ liệu tĩnh có thể được bảo quản trong thời gian dài hơn. Ngoài ra, các giải pháp bảo mật dữ liệu phụ thuộc vào các thông số khác như: kích thước dữ liệu và kiểu dữ liệu. Các giải pháp thông thường để bảo mật một tập dữ liệu nhỏ có thể không phù hợp với khối lượng dữ liệu lớn, chẳng hạn như mã hóa và ẩn danh. Ví dụ, về kiểu dữ liệu, dữ liệu nhạy cảm yêu cầu tính bảo mật trong khi dữ liệu cá nhân yêu cầu quyền riêng tư; thông tin cần được bảo vệ trong dữ liệu nhạy cảm là nội dung dữ liệu thường được thực hiện bằng các kỹ thuật mã hóa. Thông tin cần được bảo vệ trong dữ liệu cá nhân là danh tính người dùng thường được thực hiện bằng các kỹ thuật ẩn danh. Tất cả các kiểu dữ liệu đều ít nhiều yêu cầu tính khả dụng và tính toàn vẹn.

Từ bảng 1.1 các giải pháp phổ biến được sử dụng để bảo mật dữ liệu trong điện toán đám mây. Từ bảng này, có thể kết luận rằng các đặc điểm của đám mây có tác động đến dữ liệu tĩnh, dữ liệu đang sử dụng và dữ liệu đang truyền. Tác động này có thể ảnh hưởng đến tính bảo mật, tính toàn vẹn cũng như tính khả dụng của chúng. Trong bảng đã thiết lập một bảng phân loại các kỹ thuật bảo mật phổ biến theo các thuộc tính bảo mật dữ liệu, như được thể hiện trong Hình 2.3 Các kỹ thuật này, chủ yếu dựa trên mã hóa đơn giản (đối xứng và bất đối xứng), thường được kết hợp và điều chỉnh để tạo thành các mô hình khác nhằm đáp ứng các yêu cầu bảo mật.

Bảng 1.1: Các giải pháp bảo mật dữ liệu phổ biến chính theo đặc điểm của đám mây, vòng đời dữ liệu và thuộc tính bảo mật dữ liệu

Đặc điểm	Trạng thái dữ liệu			Thuộc tính bảo mật dữ liệu			Giải pháp chung cho đặc điểm dữ liệu
	Dữ liệu lưu trữ	Dữ liệu đang sử dụng	Dữ liệu đang truyền tải	Tính bảo mật, riêng tư	Tính toàn vẹn	Tính khả dụng	
Cơ sở hạ tầng thuê	Ảnh hưởng	Ảnh hưởng	Ảnh hưởng	Ảnh hưởng	Ảnh hưởng	Ảnh hưởng	Mã hóa, kiểm soát truy cập, minh bạch với nhà cung cấp dịch vụ

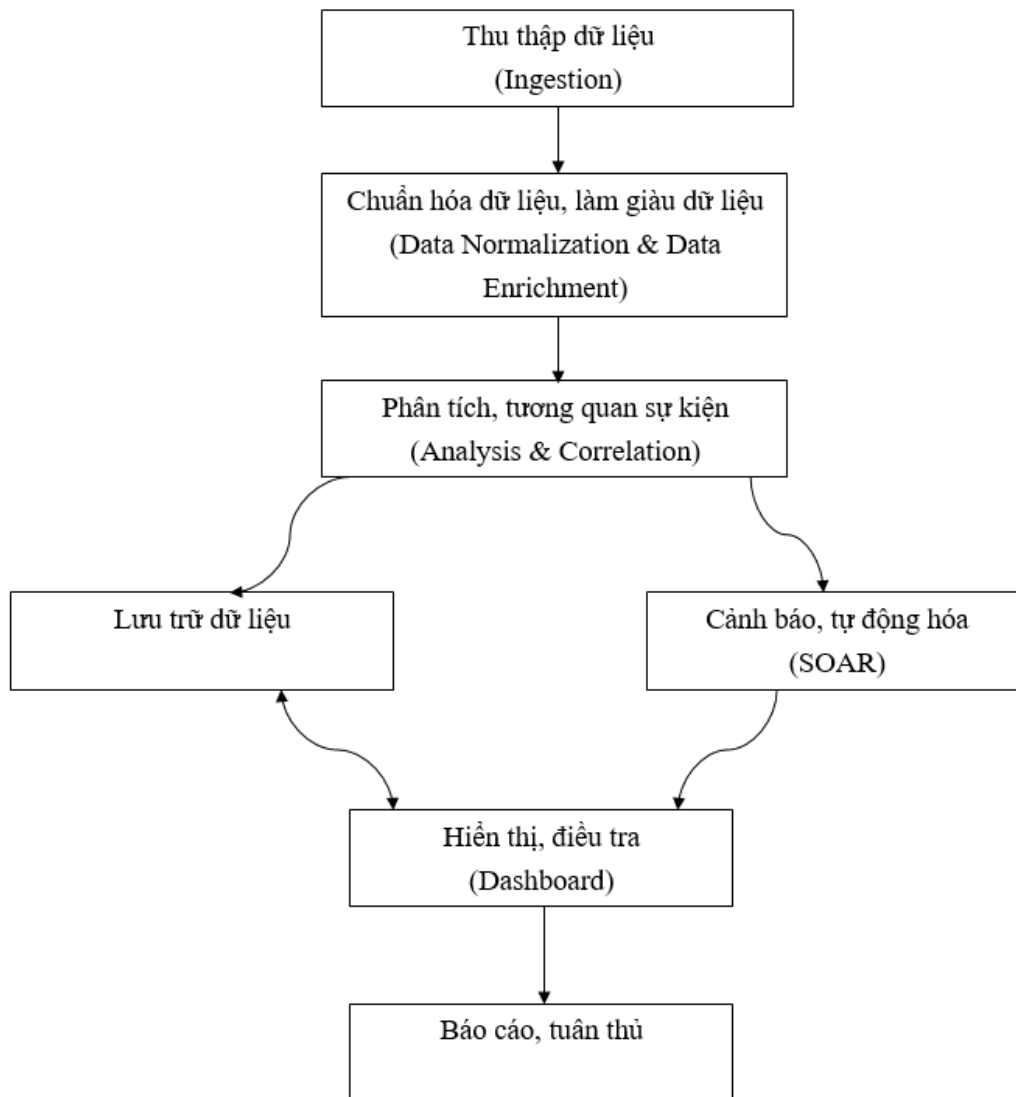
Cơ sở hạ tầng mở	Ảnh hưởng	Ảnh hưởng	Ảnh hưởng	Ảnh hưởng	Ảnh hưởng	Ảnh hưởng	Mã hóa, kiểm soát truy cập
Cơ sở hạ tầng sử dụng chung	Ảnh hưởng	Ảnh hưởng	Ảnh hưởng	Ảnh hưởng	Ảnh hưởng	Ảnh hưởng	Mã hóa, kiểm soát truy cập
Cơ sở hạ tầng Elastic	Ảnh hưởng	Ảnh hưởng	Ảnh hưởng	Ảnh hưởng	Ảnh hưởng	Ảnh hưởng	Mã hóa
Ảo hóa	Ảnh hưởng	Ảnh hưởng	Ảnh hưởng	Ảnh hưởng	Ảnh hưởng	Ảnh hưởng	Bảo mật VM, bảo mật trình quản lý ảo hóa (hypervisor), VPN
Cơ sở hạ tầng phân tán	Ảnh hưởng	Ảnh hưởng	Ảnh hưởng	Ảnh hưởng	Ảnh hưởng	Ảnh hưởng	Tăng cường tính minh bạch của nhà cung cấp dịch vụ, kỹ thuật ẩn danh
Các giải pháp chung cho thuộc tính trạng thái bảo mật dữ liệu	Mã hóa, kiểm soát truy cập	Mã hóa, ẩn danh	Mã hóa, bảo mật thiết bị mạng, giao thức bảo mật	Mã hóa, kiểm soát truy cập, ẩn danh, ẩn giấu dữ liệu	Tính toán vụn kỹ thuật xác minh, mã hóa	Sao lưu tài nguyên, dữ liệu	



Hình 2.3: Các kỹ thuật bảo mật dữ liệu phổ biến liên quan đến các thuộc tính bảo mật dữ liệu [13]

2.1.4. Giải pháp giám sát và phát hiện đe dọa

Giải pháp Security Information and Event Management (SIEM) là giải pháp kết hợp chức năng thu thập, phân tích, lưu trữ và hiển thị dữ liệu nhật ký (log) từ nhiều nguồn khác nhau. Trong môi trường đám mây, SIEM được triển khai nhằm đáp ứng nhu cầu xử lý khối lượng dữ liệu khổng lồ phát sinh liên tục từ máy ảo, ứng dụng SaaS, dịch vụ lưu trữ, và mạng ảo hóa. Quy trình hoạt động của một SIEM đám mây như Hình 2.4 có thể được mô tả chi tiết qua 5 bước trung tâm, với dữ liệu di chuyển qua từng giai đoạn để được chuyển hóa từ thông tin thô thành hành động có ý nghĩa.



Hình 2.4: Quy trình hoạt động của SIEM đám mây

2.1.4.1. Thu thập dữ liệu nhật ký tập trung

Đây là bước nền tảng và quan trọng nhất trong toàn bộ quy trình hoạt động của SIEM đám mây. Nếu dữ liệu không được thu thập đầy đủ, chính xác và kịp thời, tất cả các bước phân tích phía sau sẽ trở nên vô nghĩa. Mục này phân tích sâu các phương pháp, nguồn dữ liệu, công nghệ và thách thức của quá trình thu thập log. Trong môi trường đám mây, có ba phương thức thu thập chính, mỗi phương thức có ưu nhược điểm và phù hợp với các loại dữ liệu khác nhau.

Bảng 1.2: Phương thức thu thập dữ liệu chính

Phương thức	Cơ chế	Ưu điểm	Nhược điểm	Ví dụ
API-Based (Push/Pull)	SIEM kết nối trực tiếp đến API dịch vụ của nhà cung cấp cloud (AWS, Azure, GCP)	- Không cần agent: Giảm thiểu overhead trên tài nguyên tính toán. - Toàn diện:	- Độ trễ: Có thể có độ trễ nhỏ (vài phút) so với thời gian sự kiện thực tế. - Giới hạn	AWS CloudTrail → Amazon S3 → SIEM (pull) Azure Activity Log → Azure Event Hubs → SIEM (push)

	đề kéo (pull) hoặc nhận (push) log.	Thu thập được log ở cấp control plane. - Đáng tin cậy: Nhà cung cấp cloud đảm bảo tính khả dụng của API.	API: Cần quản lý giới hạn về số lần gọi API (rate limiting).	
Agent-Based	Cài đặt một phần mềm nhẹ (agent) lên máy ảo (VM), container hoặc server vật lý để thu thập log cục bộ và gửi về SIEM.	- Chi tiết: Thu thập log chi tiết ở cấp OS và ứng dụng. - Thời gian thực: Dữ liệu được gửi gần như ngay lập tức. - Offline support: Một số agent có thể lưu log tạm nếu mất kết nối.	- Overhead: Tiêu tốn tài nguyên (CPU, RAM, network) trên máy chủ. - Quản lý phức tạp: Cần quản lý, cập nhật agent trên số lượng lớn máy chủ.	Cài đặt Fluentd, Fluent Bit, Logstash, hoặc agent của hãng SIEM (Splunk UF, Wazuh agent) lên EC2 instance.
Network-Based	Thu thập lưu lượng mạng (network traffic) thông qua các giao thức hoặc log được xuất ra từ các thiết bị mạng ảo.	- Bị động, an toàn: Không can thiệp vào hoạt động của server. - Phát hiện tấn công mạng: Hiểu rõ hành vi liên lạc giữa các tài nguyên.	- Khó khăn trong mã hóa: Khó phân tích nội dung lưu lượng đã mã hóa (HTTPS). - Không thấy được nội dung server: Chỉ thấy lưu lượng, không thấy log chi tiết trên server.	Bật VPC Flow Logs (AWS) hoặc NSG Flow Logs (Azure) và gửi đến SIEM.

Các nguồn dữ liệu quan trọng cần thu thập:

Lớp điều khiển (Control Plane Logs): Đây là các log ghi lại mọi tương tác để thay đổi trạng thái và cấu hình của hạ tầng đám mây. Một sự thay đổi bất thường ở lớp này thường là dấu hiệu của một vụ tấn công nghiêm trọng.

- AWS CloudTrail: Ghi lại mọi lệnh gọi API đến các dịch vụ AWS (ví dụ: RunInstances, CreateUser, DeleteBucket). Phải được bắt buộc kích hoạt.
- Azure Activity Log: Cung cấp cái nhìn sâu vào các hoạt động trên Azure subscription (ví dụ: ai đã tạo VM, xóa resource group).
- Google Cloud Audit Logs: Bao gồm Admin Activity Logs và Data Access Logs cho GCP.

Lớp Dữ Liệu (Data Plane Logs): Các log ghi lại hoạt động truy cập vào dữ liệu

- AWS S3 Access Logs, Azure Storage Analytics Logs, Cloud Storage Access Logs: Ghi lại mọi yêu cầu đọc/ghi đối với object storage.
- Database Logs: Log truy vấn từ AWS RDS, Azure SQL Database.

Lớp Mạng (Network Logs): Giúp phân tích hành vi lưu lượng mạng, phát hiện quét port, tấn công DDoS, hoặc liên lạc bất thường.

- Flow Logs: VPC Flow Logs (AWS), NSG Flow Logs (Azure). Cung cấp metadata về lưu lượng IP (source/destination IP/port, số byte, action accept/deny).
- DNS Query Logs: AWS Route 53 Query Logs, Azure DNS Analytics. Phát hiện máy chủ bị nhiễm malware đang liên lạc với domain C&C.
- Web Application Firewall (WAF) Logs: AWS WAF Logs, Azure Application Gateway WAF Logs. Ghi lại các yêu cầu web bị chặn hoặc cho phép.

Lớp Máy Chủ và Ứng Dụng (Workload Logs): Các log truyền thống từ hệ điều hành và ứng dụng đang chạy trên các máy ảo hoặc container.

- Hệ điều hành: Linux syslog, Windows Event Log (đặc biệt là Security logs cho sự kiện đăng nhập).
- Ứng dụng: Log từ web server (Apache, Nginx), application log (JSON, text files).

Lớp Bảo Mật (Security Logs): Log từ các dịch vụ bảo mật native hoặc bên thứ ba.

- Native Cloud Security Services: Log từ AWS GuardDuty (cảnh báo phát hiện đe dọa), Azure Security Center, Google Cloud Security Command Center.
- Third-party Security Tools: Log từ tường lửa thế hệ mới (NGFW), hệ thống ngăn chặn xâm nhập (IPS) triển khai trên cloud.

Quá trình thu thập thường không diễn ra trực tiếp từ nguồn đến SIEM mà thông qua một lớp trung gian để đệm dữ liệu và xử lý sơ bộ.

- Message Brokers / Streaming Platforms: Các nền tảng truyền tải sự kiện theo dòng (streaming) như Amazon Kinesis Data Streams, Azure Event Hubs, hoặc Apache Kafka thường được triển khai ở vị trí trung gian giữa nguồn log và hệ thống SIEM. Chúng hoạt động như một bộ đệm có độ trễ thấp, cho phép hấp thụ khối lượng dữ liệu lớn được tạo ra với tốc độ cao. Nhờ đó, SIEM không phải xử lý trực tiếp tất cả dữ liệu ngay tức thì mà có thể tiêu thụ log theo tốc độ phù hợp với khả năng xử lý.

năng. Cách tiếp cận này giúp tránh mất mát dữ liệu trong trường hợp SIEM gặp sự cố, bị quá tải hoặc tạm thời dừng hoạt động. Một ưu điểm quan trọng khác của message brokers là hỗ trợ phân phối dữ liệu song song đến nhiều hệ thống. Ngoài việc gửi log đến SIEM, các luồng dữ liệu này còn có thể được chia sẻ cho hệ thống giám sát hiệu năng, phân tích dữ liệu lớn hoặc lưu trữ lâu dài.

- **Data Buckets:** Nhiều dịch vụ đám mây cung cấp sẵn tùy chọn xuất log trực tiếp vào dịch vụ lưu trữ đối tượng (object storage) như Amazon S3 hay Azure Blob Storage. Đây được gọi là Data Buckets. Phương pháp này đơn giản và tiết kiệm chi phí vì object storage thường rẻ hơn nhiều so với lưu trữ dữ liệu trực tiếp trong hệ thống SIEM. Thay vì gửi log theo thời gian thực, dịch vụ đám mây sẽ định kỳ ghi log vào các file (thường theo định dạng JSON hoặc CSV) trong bucket. SIEM sau đó sẽ kết nối đến bucket và kéo dữ liệu về theo lịch trình (pull-based) hoặc thông qua cơ chế sự kiện (event-based). Ưu điểm của cách tiếp cận này là khả năng lưu trữ log lâu dài với chi phí thấp, đồng thời giảm tải cho SIEM trong quá trình xử lý dữ liệu trực tuyến. Tuy nhiên, hạn chế là độ trễ cao hơn, do dữ liệu thường chỉ được phân tích sau một khoảng thời gian kể từ khi phát sinh. Do vậy, mô hình data buckets thường được kết hợp với streaming để cân bằng giữa chi phí và khả năng phát hiện theo thời gian thực.
- **Log Collectors & Forwarders:** Ngoài hai cơ chế trên, một phương pháp phổ biến khác là sử dụng các công cụ thu thập và chuyển tiếp log như Fluentd, Fluent Bit (phiên bản nhẹ hơn), hoặc Logstash. Các công cụ này thường được triển khai dưới dạng container sidecar trong môi trường Kubernetes, hoặc cài đặt trên các máy chủ chuyên dụng. sử dụng collectors/forwarders giúp giảm tải cho SIEM, đồng thời đảm bảo dữ liệu được lọc bỏ nhiễu, chuẩn hóa và phân loại trước khi đến hệ thống phân tích. Vì vậy, SIEM có thể tập trung tài nguyên cho các tác vụ phân tích nâng cao thay vì xử lý dữ liệu thô.

2.1.4.2. Chuẩn hóa và làm giàu dữ liệu

Chuẩn hóa là quá trình chuyển đổi dữ liệu log từ nhiều định dạng khác nhau về một lược đồ thống nhất (schema). Quá trình này thường bao gồm:

- **Phân tích cú pháp (Parsing):** Hệ thống SIEM thực hiện tách và nhận diện các trường thông tin trong log. Ví dụ, trong log truy cập web dạng JSON, hệ thống sẽ trích xuất các trường timestamp, source_ip, user, event_name, result. Trong khi đó, log tường lửa lại có định dạng khác, nhưng vẫn chứa các thông tin tương tự như địa chỉ nguồn, địa chỉ đích, cổng kết nối, kết quả cho phép hoặc từ chối.
- **Ánh xạ vào lược đồ chung (Normalization):** Sau khi parsing, các trường dữ liệu sẽ được ánh xạ vào một lược đồ chuẩn, điển hình như Common Information Model (CIM). Lược đồ này quy định tập hợp trường chung, cho phép SIEM hiểu và so sánh sự kiện bất kể chúng đến từ hệ thống nào.

Sau khi dữ liệu được chuẩn hóa, SIEM tiếp tục thực hiện làm giàu (enrichment) bằng cách bổ sung thêm ngữ cảnh (context) để gia tăng ý nghĩa và độ chính xác trong phân tích. Quá trình này thường bao gồm các hoạt động sau:

- Geo-IP: Địa chỉ IP được ánh xạ ra vị trí địa lý (quốc gia, khu vực, thành phố). Ví dụ, một tài khoản thường đăng nhập từ Việt Nam nhưng đột ngột đăng nhập từ quốc gia khác sẽ được hệ thống đánh dấu là hành vi bất thường.
- Threat Intelligence: Các trường như IP, domain, hoặc file hash được kiểm tra đối chiếu với cơ sở dữ liệu threat intelligence từ các nguồn uy tín (AlienVault OTX, VirusTotal, MISP, hoặc nguồn nội bộ doanh nghiệp). Nếu giá trị được phát hiện trong danh sách đen (blacklist), sự kiện sẽ được nâng mức cảnh báo. Điều này giúp phát hiện nhanh các kết nối đến máy chủ hoặc việc tải xuống phần mềm độc hại.
- Thông tin tài sản (Asset Information): Log sự kiện được gắn với thông tin tài sản liên quan, chẳng hạn: máy chủ nào sinh ra log, máy chủ đó thuộc nhóm hệ thống nào, chủ sở hữu là ai, mức độ quan trọng đối với hoạt động kinh doanh. Nhờ vậy, một sự kiện bất thường xảy ra trên máy chủ cơ sở dữ liệu tài chính sẽ được ưu tiên cảnh báo cao hơn so với sự kiện tương tự xảy ra trên máy thử nghiệm.

2.1.4.3. Phân tích, tương quan sự kiện

Giai đoạn phân tích và tương quan sự kiện được coi là quyết định hiệu quả phát hiện đe dọa. Nếu các giai đoạn trước chỉ tập trung thu thập, chuẩn hóa và làm giàu dữ liệu, thì tại bước này, SIEM tiến hành so sánh, kết nối và suy luận logic từ nhiều sự kiện riêng lẻ để xây dựng nên một bức tranh toàn cảnh về các hoạt động bất thường hoặc tấn công có chủ đích. Điều này đặc biệt quan trọng trong môi trường điện toán đám mây, nơi mà dữ liệu phát sinh liên tục từ hàng ngàn dịch vụ và hạ tầng khác nhau.

Tương quan dựa trên luật (Rule-based Correlation): Cách tiếp cận truyền thống và phổ biến nhất trong SIEM là sử dụng các luật (rules) được định nghĩa trước để phát hiện hành vi tấn công đã biết. Các luật này thường được xây dựng dựa trên:

- Ngôn ngữ truy vấn (tương tự SQL hoặc DSL – Domain Specific Language của từng nền tảng).
- Mẫu tấn công đã ghi nhận trong các tiêu chuẩn như MITRE ATT&CK, OWASP, hay các playbook sự cố bảo mật.

Phân tích hành vi người dùng và thực thể (UEBA – User and Entity Behavior Analytics): Trong khi rule-based correlation hiệu quả với các mẫu tấn công đã biết, nó lại kém linh hoạt với các mối đe dọa chưa từng được ghi nhận (zero-day attack hoặc hành vi nội gián). Để khắc phục, SIEM hiện đại tích hợp thêm thành phần UEBA, sử dụng các kỹ thuật machine learning để học hành vi “bình thường” của người dùng, thiết bị và dịch vụ.

- Xây dựng baseline: Hệ thống theo dõi các hoạt động trong khoảng thời gian dài để xác định hành vi chuẩn mực, ví dụ: thời gian đăng nhập, khối lượng dữ liệu tải xuống, vị trí địa lý thường xuyên.

- Phát hiện bất thường: Khi hành vi lệch khỏi baseline, cảnh báo sẽ được kích hoạt.

Phân tích theo ngữ cảnh (Contextual Analysis): Một cảnh báo chỉ thực sự có ý nghĩa khi được đặt trong ngữ cảnh của hệ thống. Phân tích theo ngữ cảnh cho phép SIEM kết hợp nhiều nguồn dữ liệu (log, threat intelligence, thông tin tài sản, hệ thống quản lý cấu hình) để đưa ra đánh giá chính xác và có con số cụ thể.

2.1.4.4. Cảnh báo và Tự động hóa phản ứng

Cảnh báo thông minh (Smart Alerting): Một cảnh báo có giá trị khi giảm thiểu cảnh báo giả (false positives) và xác định đúng mức độ ưu tiên để đội ngũ vận hành tập trung xử lý sự kiện quan trọng trước. Cơ chế này dựa trên:

- Phân loại mức độ ưu tiên: Cảnh báo được gắn nhãn High, Medium, Low dựa trên ngữ cảnh. Ví dụ, cảnh báo đăng nhập bất thường vào hệ thống thử nghiệm có thể xếp mức Low, trong khi cảnh báo tương tự trên hệ thống cơ sở dữ liệu khách hàng cần xếp mức High.
- Hợp nhất cảnh báo (Alert Aggregation): Thay vì gửi 100 cảnh báo rời rạc cho 100 lần đăng nhập thất bại, SIEM có thể gộp chúng thành một cảnh báo duy nhất kèm theo thống kê.
- Giảm nhiễu (Noise Reduction): Cảnh báo không quan trọng hoặc đã được nhận diện là an toàn (benign) có thể tự động hạ cấp hoặc loại bỏ.

Nhờ vậy, hệ thống giúp giảm áp lực cho analyst, đồng thời nâng cao độ tin cậy của mỗi cảnh báo.

Security Orchestration, Automation, and Response (SOAR): SOAR là lớp công nghệ bổ sung cho SIEM, đóng vai trò “cánh tay tự động” trong xử lý sự cố. Thay vì analyst phải thực hiện thủ công nhiều bước (điều tra, cô lập, ghi nhận), SOAR cho phép xây dựng các playbook – kịch bản phản ứng tự động theo từng loại sự cố. Cơ chế hoạt động gồm 3 phần:

- Orchestration (Điều phối): SOAR kết nối với nhiều công cụ bảo mật và nền tảng đám mây thông qua API (như AWS, Azure, GCP, firewall, EDR).
- Automation (Tự động hóa): Khi có cảnh báo, playbook sẽ thực hiện một chuỗi hành động định sẵn (cách ly máy, reset mật khẩu, thu thập bằng chứng).
- Response (Phản ứng): Analyst nhận kết quả cùng ngữ cảnh đầy đủ, chỉ cần tập trung vào phân tích nguyên nhân gốc rễ thay vì thao tác thủ công.

2.1.4.5. Lưu trữ, Hiển thị và Báo cáo

Sau các bước thu thập, chuẩn hóa, phân tích và cảnh báo, dữ liệu log trong hệ thống SIEM đám mây cần được lưu trữ lâu dài, hiển thị trực quan và báo cáo tuân thủ. Đây là giai đoạn cuối cùng nhưng có vai trò quan trọng trong việc đảm bảo khả năng điều tra, quản trị an ninh và đáp ứng yêu cầu pháp lý.

Lưu trữ (Storage): Trong môi trường đám mây, dữ liệu log phát sinh với khối lượng rất lớn (hàng TB đến PB mỗi tháng). Do đó, việc lưu trữ cần khả năng mở rộng linh hoạt và chi phí hợp lý. Giải pháp phổ biến là sử dụng data lake như:

- Amazon S3, Azure Blob Storage, hoặc Google Cloud Storage để lưu trữ log thô.
- Kết hợp với công cụ quản lý vòng đời dữ liệu (data lifecycle management) để phân loại dữ liệu theo mức độ Hot storage/Cold storage:
 - Hot storage: Lưu trữ dữ liệu trong 30 ngày gần nhất để phục vụ tìm kiếm và điều tra nhanh với độ trễ thấp.
 - Cold storage: Lưu trữ dài hạn (6–12 tháng hoặc hơn) với chi phí thấp, chủ yếu phục vụ điều tra chuyên sâu, pháp y số hoặc tuân thủ.

Ngoài ra, SIEM hiện đại thường tích hợp cơ chế indexing và metadata tagging, cho phép tìm kiếm nhanh ngay cả trên dữ liệu cold storage, giảm thời gian điều tra.

Hiển thị (Visualization & Dashboard): Một trong những thách thức lớn của phân tích an ninh là làm thế nào để biến dữ liệu phức tạp thành thông tin dễ hiểu. Dashboard của SIEM cung cấp giao diện trực quan, thường được gọi là Single Pane of Glass, giúp đội ngũ an ninh:

Theo dõi tổng quan tình hình an ninh theo thời gian thực (real-time). Giám sát các chỉ số hiệu suất chính (KPIs) như:

- MTTD (Mean Time To Detect): Thời gian trung bình để phát hiện sự cố.
- MTTR (Mean Time To Respond): Thời gian trung bình để phản ứng và xử lý.

Phân loại và hiển thị cảnh báo theo mức độ ưu tiên để analyst dễ dàng nhận biết sự kiện quan trọng. Cung cấp khả năng tùy biến cho từng vai trò: quản trị viên hệ thống, nhà quản lý an ninh, hay lãnh đạo cấp cao.

Báo cáo tuân thủ (Compliance Reporting): Ngoài chức năng giám sát, SIEM còn là công cụ hỗ trợ quan trọng trong việc đáp ứng các chuẩn mực và yêu cầu pháp lý. Hệ thống có thể tự động tạo các báo cáo định kỳ theo các tiêu chuẩn an toàn thông tin phổ biến:

- PCI-DSS (Payment Card Industry – Data Security Standard): Cho các tổ chức xử lý dữ liệu thẻ thanh toán.
- ISO/IEC 27001: Cho hệ thống quản lý an toàn thông tin.
- HIPAA (Health Insurance Portability and Accountability Act): Cho lĩnh vực y tế và dữ liệu bệnh nhân.

Các báo cáo này không chỉ giúp tổ chức giảm công sức chuẩn bị tài liệu cho kiểm toán, mà còn đảm bảo tính minh bạch trong quản lý an ninh. Nhiều SIEM hiện đại còn cung cấp tính năng tùy chỉnh báo cáo theo yêu cầu cụ thể của từng doanh nghiệp hoặc quy định nội bộ.

2.1.5. Giải pháp bảo mật cho từng loại dịch vụ đám mây

Trong an toàn thông tin nói chung và an toàn đám mây nói riêng, con người và quy trình luôn là mắt xích yếu nhất nhưng lại có ảnh hưởng quyết định đến hiệu quả của toàn bộ hệ thống bảo mật. Một tổ chức có thể đầu tư nhiều vào công nghệ hiện đại nhưng nếu chính sách không rõ ràng, người dùng thiếu nhận thức, hoặc quy trình vận hành lỏng lẻo, thì nguy cơ rò rỉ và thất thoát dữ liệu vẫn luôn tồn tại. Nhóm giải pháp này có phạm vi bao quát và áp dụng đồng thời cho ba mô hình

dịch vụ SaaS, PaaS và IaaS, bởi dù mức độ trách nhiệm giữa nhà cung cấp và khách hàng khác nhau, thì người sử dụng, quản trị hệ thống và quy trình vận hành đều có ảnh hưởng trực tiếp đến rủi ro bảo mật.

Thiết lập chính sách sử dụng dịch vụ đám mây rõ ràng:

- SaaS: Xác định ứng dụng SaaS nào được phép sử dụng, cơ chế phê duyệt ứng dụng mới, cùng với quy định phân loại dữ liệu để quyết định loại dữ liệu nào được phép lưu trữ. Ví dụ: chỉ dữ liệu công khai được lưu trên ứng dụng SaaS chưa được chứng nhận bảo mật.
- PaaS: Chính sách cần quy định môi trường phát triển nào được phép triển khai, quy tắc về mã nguồn, kiểm thử bảo mật ứng dụng, cũng như trách nhiệm quản lý bản vá và cập nhật thư viện.
- IaaS: Tổ chức cần đưa ra quy định về cấu hình hạ tầng (như mạng ảo, firewall, vùng lưu trữ), chính sách sao lưu, và quy định nghiêm ngặt về việc ai có quyền khởi tạo hay thay đổi tài nguyên IaaS.

Đào tạo và nâng cao nhận thức bảo mật:

- SaaS: Người dùng cuối cần được đào tạo cách nhận diện phishing, bảo vệ tài khoản, cấu hình quyền chia sẻ dữ liệu phù hợp, và sử dụng xác thực đa yếu tố.
- PaaS: Các nhà phát triển ứng dụng cần được huấn luyện về lập trình an toàn, nhận thức về lỗ hổng OWASP Top 10, và tuân thủ quy trình kiểm thử bảo mật trước khi phát hành.
- IaaS: Các quản trị viên hạ tầng phải nắm rõ các nguyên tắc cấu hình an toàn, phân tách mạng, thiết lập kiểm soát truy cập và vận hành hệ thống log/giám sát.

Quản lý vòng đời tài khoản người dùng (User Lifecycle Management): Quản lý tài khoản và quyền truy cập là trọng tâm trong mọi môi trường đám mây, đặc biệt khi nhân sự thay đổi hoặc khi tổ chức sử dụng nhiều loại dịch vụ cùng lúc:

- SaaS: Cần áp dụng cơ chế tự động hóa onboarding/offboarding tài khoản nhân viên. Tích hợp SaaS với hệ thống quản lý danh tính tập trung để đảm bảo tài khoản được cấp phát và thu hồi đồng bộ.
- PaaS: Đối với các lập trình viên và đội DevOps, tài khoản cần được quản lý theo nguyên tắc đặc quyền tối thiểu (least privilege). Các token/API key phải được cấp phát có thời hạn, lưu trữ an toàn và thu hồi ngay khi không còn sử dụng.
- IaaS: Với hạ tầng, tài khoản quản trị có mức độ rủi ro cao nhất. Do đó, cần áp dụng nguyên tắc phân tách nhiệm vụ (segregation of duties), sử dụng quyền tạm thời (just-in-time access), và ghi log đầy đủ mọi hoạt động quản trị.

Tích hợp Quy trình Vận hành Chuẩn (Standard Operating Procedures – SOPs): Ngoài chính sách và đào tạo, việc chuẩn hóa quy trình vận hành là cần thiết để đảm bảo tính nhất quán:

- SaaS: Có quy trình xử lý khi phát hiện tài khoản SaaS bị xâm nhập hoặc dữ liệu bị chia sẻ sai phạm.

- PaaS: Có quy trình tích hợp liên tục/triển khai liên tục CI/CD (Continuous Integration/Continuous Deployment) kèm bước kiểm thử bảo mật (security gates) để đảm bảo ứng dụng phát hành an toàn.
- IaaS: Có quy trình chuẩn cho việc khởi tạo máy ảo, cấu hình mạng, triển khai bản vá, và khôi phục sau sự cố (disaster recovery).

2.1.5.1. Giải pháp bảo mật cho dịch vụ SaaS

CASB (Cloud Access Security Broker) – Cổng Bảo mật Trung gian: CASB được xem là công cụ then chốt nhất khi triển khai bảo mật SaaS, đóng vai trò như một “cổng an ninh” đặt giữa người dùng và ứng dụng SaaS.

- Visibility (Hiển thị): CASB có khả năng phát hiện toàn bộ lưu lượng SaaS đang được sử dụng trong tổ chức, kể cả các dịch vụ ngoài kiểm soát CNTT. Nhờ vậy, doanh nghiệp có thể lập bản đồ chính xác về mức độ sử dụng SaaS thực tế.
- Data Security (Bảo vệ dữ liệu): CASB triển khai các chính sách Data Loss Prevention (DLP), ngăn chặn hành vi tải lên hoặc tải xuống dữ liệu nhạy cảm từ những ứng dụng SaaS không được phép hoặc thiếu an toàn.
- Threat Protection (Bảo vệ khỏi đe dọa): CASB theo dõi hành vi đăng nhập và truy cập, phát hiện bất thường như đăng nhập từ hai quốc gia khác nhau trong thời gian ngắn, hoặc dấu hiệu chiếm quyền tài khoản (Account Takeover – ATO).
- Compliance (Tuân thủ): CASB hỗ trợ đánh giá cấu hình ứng dụng SaaS theo tiêu chuẩn và chính sách nội bộ (ví dụ: PCI-DSS, ISO 27001), giúp tổ chức duy trì sự tuân thủ và tránh các rủi ro pháp lý.

SSPM (SaaS Security Posture Management) – Quản lý Tư thế Bảo mật SaaS: Trong khi CASB tập trung vào giám sát luồng truy cập, thì SSPM lại đi sâu vào việc kiểm soát cấu hình chính của ứng dụng SaaS. Đây là lớp bảo mật quan trọng nhằm ngăn ngừa các rủi ro phát sinh từ cấu hình sai.

- Đánh giá tự động: SSPM thường xuyên quét và so sánh cấu hình ứng dụng SaaS (Microsoft 365, Google Workspace, Salesforce, v.v.) với các phương pháp bảo mật tốt nhất đã được khuyến nghị.
- Phát hiện sai lệch: Hệ thống cảnh báo khi phát hiện cấu hình rủi ro, chẳng hạn chia sẻ tệp công khai trên Internet, hoặc ứng dụng bên thứ ba có quyền truy cập quá mức.
- Khắc phục: SSPM cung cấp khả năng khắc phục tự động hoặc đưa ra hướng dẫn chi tiết cho quản trị viên để xử lý kịp thời.

IAM (Identity and Access Management) & SSO (Single Sign-On): Quản lý danh tính và truy cập (IAM) là nền tảng bảo mật trọng yếu trong mọi dịch vụ đám mây. Khi được kết hợp với Single Sign-On (SSO), hệ thống giúp tổ chức kiểm soát tập trung việc xác thực và ủy quyền.

- Bắt buộc sử dụng SSO: Người dùng chỉ cần đăng nhập một lần để truy cập tất cả ứng dụng SaaS. Điều này giúp đơn giản hóa trải nghiệm, đồng thời cho phép quản lý tập trung chính sách xác thực.

- Nguyên tắc đặc quyền tối thiểu (Least Privilege): IAM bảo đảm chỉ cấp cho người dùng quyền tối thiểu cần thiết để hoàn thành công việc, tránh lạm dụng hoặc sai sót.
- Xác thực đa yếu tố (MFA): Mọi truy cập tới ứng dụng SaaS, đặc biệt ứng dụng chứa dữ liệu nhạy cảm, đều phải kèm theo bước xác thực bổ sung (ví dụ: OTP qua ứng dụng, khóa bảo mật vật lý).

Sao lưu Dữ liệu SaaS (Backup and Recovery): Trong khi các nhà cung cấp SaaS chịu trách nhiệm tính sẵn sàng dịch vụ thì trách nhiệm bảo vệ dữ liệu thuộc về người dùng. Từ đó cần triển khai công cụ sao lưu SaaS như AvePoint, Backupify, Spanning, nhằm tự động sao lưu dữ liệu trên Microsoft 365, Google Workspace, Salesforce. Các giải pháp này giúp khôi phục nhanh dữ liệu trong các trường hợp như: Người dùng vô tình xóa tệp tin, bị tấn công ransomware mã hóa dữ liệu SaaS, lỗi đồng bộ hoặc lỗi cấu hình gây mất dữ liệu. Đảm bảo tuân thủ theo chuẩn mực pháp lý (ví dụ: HIPAA, GDPR).

2.1.5.2. Giải pháp bảo mật cho dịch vụ PaaS

Quản lý truy cập và danh tính (Identity and Access Management - IAM): IAM đóng vai trò như hệ thống cổng kiểm soát, xác định ai được phép truy cập tài nguyên nào, với quyền hạn ra sao, và trong điều kiện nào. Bất kỳ sai sót nào trong việc cấp quyền hay bảo vệ danh tính đều có thể trở thành cửa ngõ cho kẻ tấn công chiếm quyền kiểm soát toàn bộ hạ tầng.

Nguyên tắc đặc quyền tối thiểu (Least Privilege): Nguyên tắc đặc quyền tối thiểu quy định rằng mỗi người dùng hoặc dịch vụ chỉ nên được cấp quyền cần thiết để hoàn thành công việc, không hơn.

- Tránh sử dụng tài khoản root/owner: Các tài khoản này có quyền tối thượng trên toàn bộ hệ thống, nếu bị lộ sẽ gây hậu quả nghiêm trọng. Tài khoản “root” chỉ nên được giữ cho những tình huống khẩn cấp, không dùng trong vận hành hằng ngày.
- Sử dụng Roles và Groups: Thay vì gán quyền trực tiếp cho từng cá nhân, nên tổ chức người dùng vào nhóm hoặc sử dụng IAM Roles. Cách này vừa đơn giản hóa quản trị, vừa giảm thiểu sai sót khi thêm hoặc xóa người dùng.

Xác thực Đa yếu tố (Multi-Factor Authentication – MFA): MFA là cơ chế bắt buộc trong IAM hiện đại, đặc biệt đối với các tài khoản có đặc quyền cao. Ngoài mật khẩu, hệ thống yêu cầu thêm một yếu tố xác thực khác, chẳng hạn:

- OTP từ ứng dụng (Google Authenticator, Authy).
- Tin nhắn SMS hoặc cuộc gọi điện thoại.
- Khóa bảo mật vật lý (YubiKey, FIDO2).

Quản lý Secrets an toàn: Secrets bao gồm mật khẩu, API keys, certificates, token dịch vụ. Đây là tài sản có độ nhạy cảm rất cao và thường là mục tiêu ưu tiên của kẻ tấn công. Sai lầm phổ biến là lưu secrets trực tiếp trong mã nguồn, file cấu hình hoặc script, dẫn đến rò rỉ khi mã được chia sẻ công khai (ví dụ: GitHub leak). Nguyên tắc tuyệt đối không được nhúng secrets vào code, secrets cần được luân chuyển định kỳ, ghi log khi truy cập và cấp quyền theo nguyên tắc đặc quyền tối thiểu.

Bảo mật Cấu hình dịch vụ PaaS (Secure Configuration): Một trong những nguyên nhân phổ biến dẫn đến sự cố bảo mật trên đám mây là cấu hình sai (misconfiguration). Với PaaS, nhà cung cấp chịu trách nhiệm về hạ tầng vật lý và hệ điều hành, nhưng người dùng vẫn phải tự quản lý cấu hình dịch vụ (database, storage, network, container platform). Do đó, việc đảm bảo cấu hình an toàn là yếu tố tiên quyết.

Sử dụng công cụ CSPM (Cloud Security Posture Management): Là công cụ trung tâm trong việc giám sát và bảo mật cấu hình PaaS. CSPM liên tục quét và so sánh cấu hình dịch vụ với bộ quy chuẩn an ninh (NIST, ISO) cũng như chính sách nội bộ. Khi phát hiện rủi ro, CSPM sẽ tự động cảnh báo và thậm chí có thể sửa chữa tự động.

Bảo mật trong quá trình phát triển (DevSecOps): Là phương pháp tích hợp DevOps với quy trình kiểm thử bảo mật ở mọi giai đoạn của quá trình phát triển phần mềm. Phương pháp này nhằm mục đích tự động hóa, giám sát và áp dụng các biện pháp bảo mật ở tất cả các giai đoạn của quá trình phát triển phần mềm, từ lúc lên kế hoạch, phát triển, xây dựng, thử nghiệm, phát hành, phân phối, đến bước triển khai, giám sát phần mềm. So với giải pháp DevOps truyền thống chỉ tích hợp phát triển phần mềm và vận hành để tạo ra ứng dụng không có lỗi thì DevSecOps mang đến sự chuyển đổi văn hóa, khiến cho việc bảo mật trở thành trách nhiệm chung đối với tất cả các cá nhân xây dựng phần mềm, thêm một bước nữa để đảm bảo các ứng dụng đó được an toàn.

- **SAST (Static Application Security Testing):** Phương pháp phân tích mã nguồn tĩnh (static code analysis) để tìm lỗ hổng mà không cần chạy ứng dụng. Phương pháp này được thực hiện sớm ngay trong giai đoạn viết code và build giúp phát hiện lỗi trong code (SQLi, XSS, Buffer Overflow...)
- **DAST (Dynamic Application Security Testing):** Phương pháp phân tích ứng dụng đang chạy từ bên ngoài để tìm lỗ hổng. Thực hiện muộn khi ứng dụng đã được build và chạy trên môi trường staging/test/production. Giúp phát hiện các lỗi trong runtime (các lỗ hổng chỉ xuất hiện khi ứng dụng chạy)
- **SCA (Software Composition Analysis):** Phương pháp quản lý và phân tích các thư viện, mã nguồn mở bên thứ ba được sử dụng trong dự án. Được áp dụng có thể thực hiện sớm (khi check-in code) hoặc muộn (khi scan bản build), giúp phát hiện ra lỗ hổng trong các thư viện bên thứ ba đã biết (theo các CVE), giấy phép phần mềm rủi ro.

Sử dụng Web Application Firewall (WAF): WAF đóng vai trò tuyến phòng thủ tiên phong tại tầng ứng dụng, giúp tổ chức ngăn chặn các tấn công như SQL Injection, Cross-Site Scripting (XSS), File Inclusion, hoặc API Abuse. WAF hoạt động như một Reverse Proxy. Thay vì kết nối trực tiếp đến máy chủ ứng dụng, người dùng sẽ kết nối đến WAF. WAF đóng vai trò trung gian, nhận toàn bộ request, phân tích kỹ lưỡng, và chỉ chuyển tiếp các request "sạch" đến ứng dụng. Các kỹ thuật phân tích và lọc như:

- **Signature-based Detection (Phát hiện dựa trên chữ ký):** Phương pháp cổ điển và phổ biến nhất, hoạt động tương tự như cơ chế phát hiện virus trong antivirus. WAF so sánh từng request với một cơ sở dữ liệu các mẫu tấn công đã biết (chữ ký – signature). Ví dụ, các chuỗi truy vấn như "OR 1=1", "UNION SELECT", hay các script `<script>alert(1)</script>` sẽ được nhận diện là dấu hiệu SQL Injection hoặc XSS.
- **Heuristic-based / Anomaly-based Detection (Phát hiện dựa trên phỏng đoán hoặc bất thường):** Khắc phục hạn chế của phương pháp chữ ký, nhiều WAF hiện đại sử dụng kỹ thuật phân tích hành vi dựa trên phỏng đoán (heuristic) hoặc phát hiện bất thường (anomaly). Cơ chế là hệ thống xây dựng một “baseline” về lưu lượng và hành vi hợp lệ, sau đó phát hiện các request vượt ra ngoài ngưỡng cho phép.
- **Parsing và Validation (Phân tích cú pháp và xác thực dữ liệu):** Kỹ thuật chuyên sâu nhằm đảm bảo dữ liệu đầu vào tuân thủ định dạng hợp lệ và loại bỏ nội dung độc hại. WAF parse (phân tích cú pháp) các thành phần của HTTP request: URL, headers, query parameters, cookies, body, so sánh cấu trúc và giá trị với các tiêu chuẩn hợp lệ (ví dụ: JSON phải có cấu trúc đúng, field không được vượt quá độ dài cho phép). Loại bỏ payload có chứa mã lệnh nguy hiểm hoặc ký tự đặc biệt.

2.1.5.3. Giải pháp bảo mật cho dịch vụ IaaS

Quản lý Truy cập và Danh tính (Identity and Access Management – IAM): Trong mô hình IaaS, quản lý truy cập và danh tính (IAM) đóng vai trò quan trọng trong toàn bộ chiến lược an ninh. Bởi lẽ, hầu hết các cuộc tấn công nhắm vào hạ tầng đám mây đều xuất phát từ thông tin xác thực bị lộ lọt hoặc lạm dụng quyền truy cập. Nếu IAM không được thiết kế chặt chẽ, kẻ tấn công có thể chiếm quyền kiểm soát toàn bộ hệ thống, gây ra hậu quả nghiêm trọng như xóa dữ liệu, triển khai mã độc hoặc chiếm dụng tài nguyên. Một số nguyên tắc quản lý truy cập và danh tính:

- **Nguyên tắc Đặc quyền tối thiểu (Least Privilege):** Một trong những nguyên tắc bảo mật quan trọng nhất đảm bảo người dùng và dịch vụ chỉ được cấp quyền tối thiểu cần thiết để thực hiện công việc. Không sử dụng tài khoản root/owner cho công việc hàng ngày, mỗi người dùng hoặc dịch vụ cần được gán quyền rõ ràng giới hạn trong công việc. Sử dụng nhóm để gán quyền giúp giảm thiểu lỗi cấu hình và dễ dàng chỉnh quyền khi thay đổi nhân sự.
- **Bắt buộc Xác thực Đa yếu tố (Multi-Factor Authentication – MFA):** Mật khẩu có thể bị lộ qua phishing hoặc brute-force, do đó MFA trở thành cơ chế bắt buộc để bổ sung một lớp bảo mật. Kích hoạt bắt MFA cho tất cả người dùng, đặc biệt quan trọng đối với tài khoản quản trị và tài khoản truy cập tới các tài nguyên nhạy cảm. Các hình thức MFA như: Sử dụng OTP qua ứng dụng (Google Authenticator, Microsoft Authenticator), thiết bị vật lý (Yubikey), hoặc qua

SMS/Email từ đó giảm thiểu nguy cơ bị xâm nhập trái phép ngay cả khi mật khẩu bị đánh cắp.

- Sử dụng IAM Roles thay vì Access Keys: Nhiều dịch vụ (EC2 instance truy cập S3) cần quyền để hoạt động. Nếu lưu trữ access key trực tiếp trong file cấu hình hoặc mã nguồn sẽ dẫn đến rủi ro bị lộ. Vì vậy sử dụng IAM Role gán trực tiếp cho dịch vụ.
- Quản lý Secrets an toàn: Các thông tin nhạy cảm như mật khẩu, API keys, database credentials không được hardcode trong ứng dụng hoặc lưu trong repository. Sử dụng một số công cụ như: AWS Secrets Manager, Azure Key Vault, Google Secret Manager để lưu trữ secrets mã hóa, tự động xoay vòng khóa định kỳ hay kiểm soát truy cập chi tiết theo chính sách IAM.
- Đánh giá và thu hồi quyền truy cập định kỳ: Nguyên nhân phổ biến mất an toàn là việc cấp quyền nhưng không thu hồi khi người dùng không còn nhu cầu sử dụng. Một số công cụ hỗ trợ như: AWS IAM Access Analyzer, Azure Access Reviews, Google Policy Analyzer có chức năng định kỳ rà soát quyền của từng user/role, thu hồi quyền dư thừa hoặc không cần thiết, áp dụng chính sách “just-in-time access” để cấp quyền tạm thời khi cần.

Bảo vệ mạng (Network Security) và phân đoạn (Segmentation):

- Áp dụng mô hình Zero Trust Network (ZTN) dựa trên nguyên tắc “Không tin tưởng, luôn xác minh”. Điều này có nghĩa là mọi yêu cầu truy cập dù đến từ bên trong hay bên ngoài đều cần được kiểm tra và xác thực.
- Thiết lập mạng riêng ảo (VPC/VNet) an toàn: Các nhà cung cấp đám mây như AWS, Azure, GCP cung cấp mô hình mạng riêng ảo (Virtual Private Cloud – VPC hoặc Virtual Network – VNet) cho phép doanh nghiệp xây dựng kiến trúc mạng tách biệt, giống như trong hạ tầng on-premise.
- Sử dụng Security Group và NACLs: Hai cơ chế bảo mật chính trong IaaS là Security Groups (SGs) và Network Access Control Lists (NACLs). Trong đó: SGs là tường lửa ở cấp độ instance, kiểm soát lưu lượng inbound/outbound dựa trên IP, port, protocol. SGs thường được dùng để bảo vệ từng máy ảo hoặc dịch vụ cụ thể. NACLs là tường lửa ở cấp subnet, áp dụng quy tắc cho toàn bộ nhóm tài nguyên trong subnet.
- Kiểm soát kết nối an toàn: Kết nối giữa hạ tầng on-premise và môi trường đám mây cần đảm bảo tính bảo mật và độ tin cậy
- Bảo vệ tầng ứng dụng: Mạng không chỉ cần an toàn ở tầng truyền thông mà còn ở tầng ứng dụng. Các mối đe dọa phổ biến như SQL Injection, Cross-Site Scripting (XSS) hay tấn công DDoS có thể gây thiệt hại lớn nếu không được ngăn chặn kịp thời.

Bảo mật Workload (Máy ảo, Container, Serverless): Trong mô hình IaaS, workload (bao gồm máy ảo – Virtual Machine, container và serverless function)

chính là nơi trực tiếp xử lý dữ liệu và chạy ứng dụng của doanh nghiệp. Vì vậy, chúng trở thành mục tiêu tấn công hàng đầu của tin tặc. Một khi workload bị xâm nhập, kẻ tấn công có thể kiểm soát toàn bộ hệ thống, di chuyển ngang (lateral movement), đánh cắp dữ liệu nhạy cảm hoặc cài mã độc phá hoại. Do đó, việc bảo mật workload cũng là một phần trong chiến lược bảo mật IaaS.

- **Cập nhật và quản lý bản vá (Patch Management):** Doanh nghiệp cần triển khai cơ chế tự động để quét và phát hiện các bản vá còn thiếu cho hệ điều hành, phần mềm nền tảng và ứng dụng. Các công cụ như AWS Systems Manager Patch Manager, Azure Update Management, hoặc Google OS Config có thể được sử dụng để triển khai bản vá trên quy mô lớn. Cập nhật ngay lập tức đối với các bản vá bảo mật nghiêm trọng. Đối với bản vá có mức độ rủi ro thấp hơn, nên có giai đoạn thử nghiệm trước khi triển khai vào môi trường production để tránh ảnh hưởng đến hoạt động kinh doanh.
- **Tăng cường bảo mật hệ điều hành (OS Hardening):** Workload trên cloud thường khởi chạy từ các image mặc định, vốn chứa nhiều dịch vụ và cấu hình không cần thiết. OS Hardening là bước làm gọn hệ điều hành để giảm thiểu tấn công. Các bước thực hiện bao gồm loại bỏ các dịch vụ dư thừa không sử dụng (FTP, telnet, SNMP v1...), thiết lập tường lửa nội bộ (host-based firewall), cơ chế ghi log và giám sát.
- **Sử dụng Cloud Workload Protection Platform (CWPP):** CWPP là lớp bảo mật chuyên dụng cho workload trong môi trường cloud, cung cấp khả năng giám sát và bảo vệ theo thời gian thực. Các nền tảng như Microsoft Defender for Cloud, AWS GuardDuty, Trend Micro Deep Security có thể tích hợp trực tiếp vào workload để nâng cao mức độ an ninh. Các chức năng chính bao gồm: Phát hiện và ngăn chặn xâm nhập (IDS/IPS), chống malware, giám sát tính toàn vẹn file, hỗ trợ container và serverless
- **Quét Lỗ hổng (Vulnerability Scanning):** Khi đã vá lỗi và hardening, workload vẫn có thể tồn tại lỗ hổng mới hoặc do phần mềm bên thứ ba. Quét lỗ hổng định kỳ giúp nhận diện và xử lý kịp thời trước khi bị khai thác. Một số công cụ phổ biến như: AWS Inspector, Azure Security Center, Qualys, Nessus, thực hiện quét bao gồm hệ điều hành, middleware, thư viện bên thứ ba và ứng dụng cài đặt. Ngoài ra chu kỳ thực hiện quét nên theo định kỳ (hàng tuần, hàng tháng) và sau mỗi lần thay đổi hệ thống quan trọng. Từ đó đảm bảo workload luôn trong trạng thái an toàn, hạn chế tối đa rủi ro từ lỗ hổng phần mềm và cấu hình.

Bảo vệ dữ liệu (Data Protection): Dữ liệu là tài sản quan trọng nhất của doanh nghiệp và cũng là mục tiêu bị tấn công nhiều nhất. Do đó, mọi giải pháp bảo mật cần lấy bảo vệ dữ liệu làm trọng tâm. Bảo vệ dữ liệu bao gồm cả việc mã hóa, sao lưu, và đảm bảo khả năng phục hồi sau thảm họa.

- Mã hóa dữ liệu ở trạng thái nghỉ (Encryption at Rest): Toàn bộ dữ liệu lưu trữ trong đám mây cần được mã hóa ở tầng lưu trữ, một số dịch vụ hỗ trợ mã hóa như Amazon EBS, S3, RDS, Azure Storage, Google Cloud Storage. Nên sử dụng customer-managed keys (CMK) thông qua các dịch vụ như AWS KMS, Azure Key Vault, Google Cloud KMS, cho phép doanh nghiệp kiểm soát vòng đời, luân chuyển và thu hồi khóa mã hóa. Điều này đặc biệt quan trọng trong các ngành yêu cầu tuân thủ (PCI-DSS, HIPAA, ISO 27001).
- Mã hóa trên đường truyền (Encryption in Transit): Hiện nay, giao thức phổ biến nhất được sử dụng để mã hóa dữ liệu trên đường truyền là Transport Layer Security (TLS), với yêu cầu tối thiểu là phiên bản TLS 1.2 hoặc cao hơn. TLS cung cấp cơ chế bắt tay (handshake) để thiết lập phiên làm việc an toàn giữa hai thực thể, sử dụng các thuật toán mã hóa đối xứng và bất đối xứng, cùng với chứng chỉ số để xác thực danh tính. Trong môi trường IaaS, TLS được áp dụng ở nhiều lớp khác nhau:
 - Lớp ứng dụng: Các dịch vụ web, API và giao diện người dùng cần được triển khai qua HTTPS thay vì HTTP.
 - Lớp cơ sở dữ liệu: Các kết nối đến cơ sở dữ liệu như Amazon RDS, Azure SQL hoặc các máy chủ tự quản lý cần được cấu hình để chỉ chấp nhận kết nối mã hóa.
 - Lớp mạng nội bộ: Trong một số trường hợp, tổ chức có thể triển khai VPN hoặc IPsec để mã hóa lưu lượng giữa các vùng mạng nội bộ hoặc giữa các trung tâm dữ liệu.
- Sao lưu và khôi phục dữ liệu sau sự cố: Trong mô hình IaaS, việc đảm bảo tính liên tục của dịch vụ và khả năng phục hồi sau sự cố là một yêu cầu thiết yếu. Khác với các mô hình SaaS hay PaaS, IaaS trao quyền kiểm soát trực tiếp cho người dùng đối với tài nguyên hạ tầng như máy chủ ảo, lưu trữ, mạng và hệ điều hành. Vì vậy, trách nhiệm xây dựng và duy trì chiến lược sao lưu và khôi phục thảm họa phần lớn thuộc về phía khách hàng sử dụng dịch vụ. Một số phương pháp sao lưu trong IaaS:
 - Sao lưu toàn bộ máy ảo (VM snapshot): Đây là phương pháp phổ biến, cho phép tạo bản sao trạng thái hiện tại của máy chủ ảo, bao gồm hệ điều hành, ứng dụng và dữ liệu. Các nhà cung cấp như AWS (EC2 snapshot), Azure (VM backup) đều hỗ trợ tính năng này với khả năng tự động hóa và lập lịch định kỳ.
 - Sao lưu ổ đĩa lưu trữ (block-level backup): Đối với các ổ đĩa như EBS (AWS) hoặc Managed Disks (Azure), người dùng có thể tạo snapshot riêng biệt, giúp phục hồi dữ liệu mà không cần khôi phục toàn bộ máy ảo.
 - Sao lưu cơ sở dữ liệu: Với các hệ thống quản lý cơ sở dữ liệu tự triển khai (ví dụ: MySQL, PostgreSQL trên VM), việc

sao lưu cần được thực hiện thông qua công cụ chuyên biệt như mysqldump, pg_dump, hoặc sử dụng các dịch vụ hỗ trợ như AWS Backup, Azure Backup để tự động hóa quy trình.

- Sao lưu file hệ thống và ứng dụng: Trong một số trường hợp, người dùng có thể triển khai các công cụ sao lưu truyền thống như Veeam, Commvault hoặc sử dụng script tùy chỉnh để sao lưu dữ liệu lên các kho lưu trữ như Amazon S3, Azure Blob Storage.

Giám sát và Ghi nhận (Monitoring & Logging): Một hệ thống cloud an toàn không thể thiếu cơ chế giám sát liên tục và ghi nhận đầy đủ các hoạt động. Các hoạt động diễn ra trên nhiều lớp – từ API, mạng, hệ điều hành đến các dịch vụ container và serverless – do đó cần triển khai ghi nhận ở tất cả các cấp độ:

- AWS CloudTrail là công cụ ghi lại toàn bộ các lời gọi API trong tài khoản AWS, bao gồm thông tin chi tiết về người thực hiện, thời gian, địa chỉ IP và hành động cụ thể. Đây là nguồn dữ liệu quan trọng để truy vết các thay đổi cấu hình, hành vi quản trị và các thao tác có thể dẫn đến rủi ro bảo mật.
- AWS VPC Flow Logs và Azure NSG Flow Logs cung cấp thông tin về lưu lượng mạng đi qua các thành phần hạ tầng. Việc phân tích các luồng dữ liệu này giúp phát hiện các kết nối bất thường, các hành vi quét cổng, hoặc các truy cập trái phép từ bên ngoài.
- Log ở cấp hệ điều hành như syslog trên Linux và Windows Event Log trên Windows ghi nhận các hoạt động nội bộ của hệ thống, bao gồm đăng nhập, khởi động dịch vụ, lỗi ứng dụng và các hành vi tiềm ẩn nguy cơ.
- Trong các kiến trúc hiện đại sử dụng container và serverless, việc ghi log trở nên phức tạp hơn do tính phân tán và ngắn hạn của các thực thể. Các dịch vụ như CloudWatch Logs (AWS), Azure Monitor Logs, hoặc GCP Logging được sử dụng để tập trung hóa log từ các microservices, giúp đảm bảo tính toàn vẹn và khả năng phân tích tập trung.

Tích hợp với hệ thống SIEM (Security Information and Event Management): Việc ghi log chỉ thực sự phát huy hiệu quả khi được tích hợp vào một hệ thống phân tích tập trung. Các nền tảng SIEM như Splunk, Elastic Stack, hoặc Azure Sentinel cho phép tập hợp log từ nhiều nguồn khác nhau, chuẩn hóa dữ liệu, và thực hiện phân tích bảo mật nâng cao. SIEM đóng vai trò như một trung tâm tình báo an ninh, nơi dữ liệu thô được chuyển hóa thành thông tin có giá trị. Các chức năng chính bao gồm:

- Chuẩn hóa dữ liệu (Normalization): Giúp so sánh và phân tích sự kiện từ các nguồn khác nhau một cách nhất quán.
- Phát hiện bất thường: Thông qua các quy tắc tương quan (rule-based correlation) hoặc các thuật toán học máy như UEBA (User and Entity Behavior Analytics), SIEM có thể nhận diện các hành vi bất thường

nếu truy cập trái phép, tấn công nội bộ, hoặc hành vi xâm nhập tình vi.

- Kích hoạt cảnh báo: Khi phát hiện dấu hiệu vi phạm chính sách hoặc tấn công, hệ thống SIEM có thể tự động gửi cảnh báo đến đội ngũ vận hành để kịp thời phản ứng.

Thiết lập cơ chế cảnh báo: Các cảnh báo nên được phân loại theo mức độ ưu tiên (High/Medium/Low) và tập trung vào các sự kiện có khả năng gây rủi ro cao, ví dụ:

- Đăng nhập thất bại nhiều lần: Dấu hiệu của tấn công brute-force nhằm dò mật khẩu.
- Thay đổi Security Group hoặc NACLs: Có thể mở các cổng nguy hiểm như SSH (22) hoặc RDP (3389) cho toàn Internet.
- Bucket S3 bị đặt thành public hoặc blob container trong Azure có quyền truy cập công khai: Làm lộ dữ liệu nhạy cảm ra bên ngoài.

Các cảnh báo cần được gửi đến nhiều kênh như email, hệ thống nhắn tin nội bộ (Slack, Microsoft Teams), hoặc tích hợp với các hệ thống quản lý sự cố như Jira, ServiceNow để đảm bảo phản ứng nhanh chóng. Việc cảnh báo kịp thời giúp đội ngũ SOC (Security Operations Center) hoặc Blue Team giảm thiểu thời gian phát hiện sự cố và thời gian xử lý, từ đó nâng cao hiệu quả bảo vệ hệ thống.

Quản lý Cấu hình và Tuân thủ (Configuration & Compliance): Các lỗi cấu hình dù lớn hay nhỏ đều có thể dẫn đến những hậu quả nghiêm trọng như rò rỉ dữ liệu, mất quyền kiểm soát tài nguyên, hoặc vi phạm các quy định pháp lý. Do đó, quản lý cấu hình và tuân thủ không chỉ là một hoạt động kỹ thuật, mà còn là một phần quan trọng trong chiến lược bảo mật tổng thể của tổ chức.

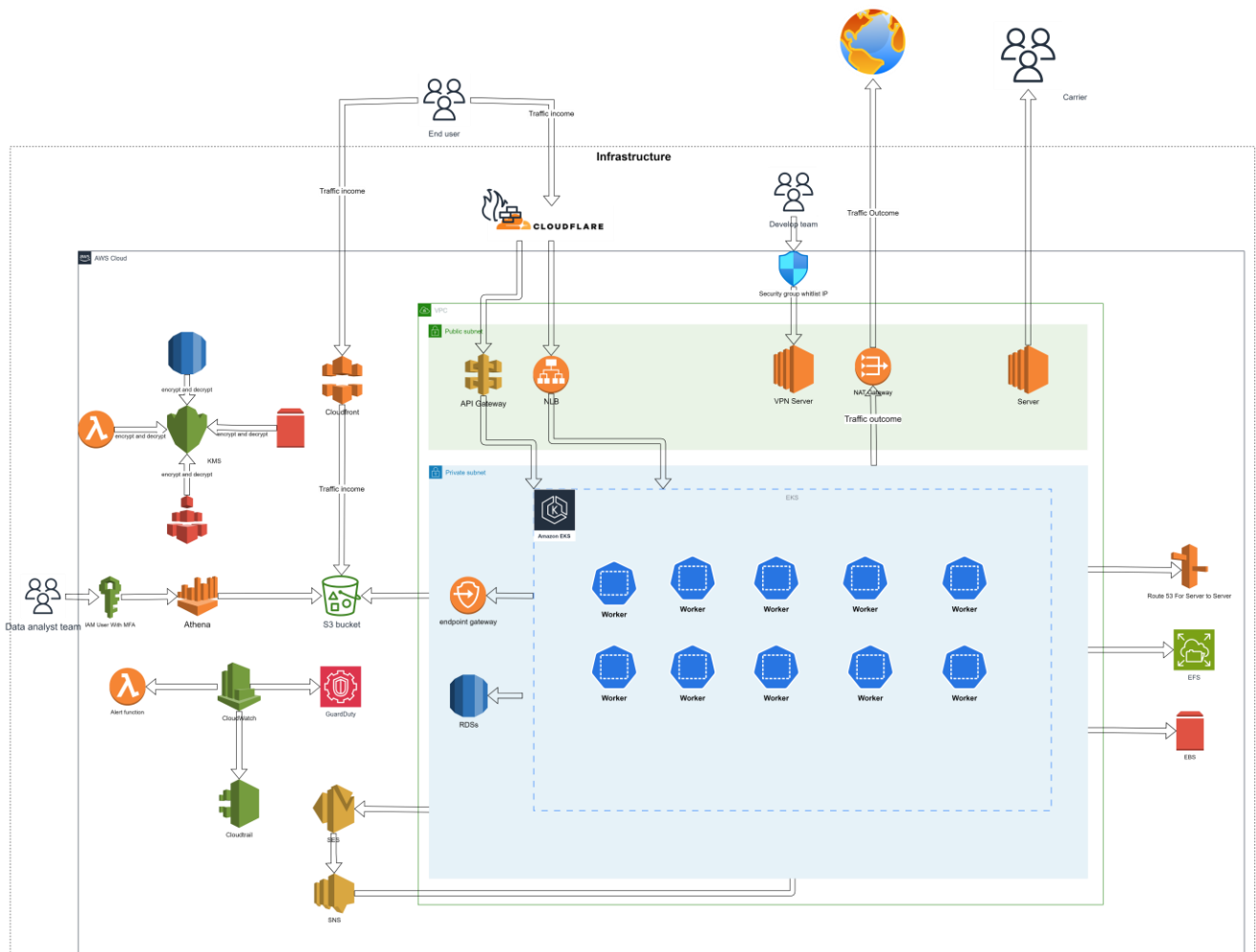
- Quản lý tư thế bảo mật với CSPM (Cloud Security Posture Management): Là một lớp công cụ chuyên biệt được thiết kế để giám sát, đánh giá và cải thiện tư thế bảo mật của hệ thống cloud. Các giải pháp CSPM như AWS Security Hub, Azure Defender for Cloud, hay Palo Alto Prisma Cloud có khả năng quét liên tục toàn bộ môi trường cloud để phát hiện các lỗi cấu hình, so sánh với các best practices đã được công nhận, và trong một số trường hợp, tự động khắc phục các sai lệch. CSPM hoạt động dựa trên các chính sách bảo mật được định nghĩa sẵn, ví dụ như yêu cầu mã hóa dữ liệu, giới hạn quyền truy cập, hoặc kiểm tra trạng thái của các bucket lưu trữ. Khi phát hiện một tài nguyên không tuân thủ, hệ thống sẽ đưa ra cảnh báo hoặc thực hiện hành động khắc phục như vô hiệu hóa quyền truy cập công khai, bật mã hóa, hoặc gỡ bỏ cấu hình nguy hiểm. Việc sử dụng CSPM giúp tổ chức duy trì trạng thái bảo mật ổn định, giảm thiểu rủi ro do lỗi cấu hình thủ công, và đáp ứng các yêu cầu tuân thủ như ISO 27001, GDPR, HIPAA, hoặc PCI-DSS. Ngoài ra, CSPM còn hỗ trợ tạo báo cáo định kỳ phục vụ kiểm toán nội bộ và bên ngoài.
- Triển khai hạ tầng an toàn với IaC (Infrastructure as Code): IaC là phương pháp định nghĩa và triển khai hạ tầng thông qua mã nguồn, thay vì thực hiện thủ công qua giao diện quản trị. Các công cụ phổ

biến như Terraform, AWS CloudFormation, và Ansible cho phép người dùng mô tả toàn bộ kiến trúc hệ thống từ máy chủ, mạng, lưu trữ đến quyền truy cập dưới dạng các tệp cấu hình có thể kiểm soát phiên bản, kiểm thử và tái sử dụng. Một số công cụ IaC phổ biến: Terraform (đa cloud), AWS CloudFormation (AWS), Azure ARM Templates, Bicep (Azure), Ansible, Pulumi (đa môi trường).

2.2. Trình bày mô hình doanh nghiệp đang sử dụng

Softel Solutions là công ty con tại Việt Nam của HTH Communications, một tập đoàn cung cấp dịch vụ viễn thông tại Mỹ với các thương hiệu như AirVoice Wireless và AirTalk Wireless. Softel Solutions được thành lập năm 2021 tại Hà Nội để tập trung nguồn lực về IT, Marketing và Chăm sóc khách hàng, phát triển các sản phẩm và dịch vụ cốt lõi cho HTH Communications.

Dưới đây là mô hình tổng quan của công ty Softel Solutions:



Hình 2.5. Mô hình tổng quan doanh nghiệp đang sử dụng

Người dùng, luồng truy cập:

Người dùng cuối (End user) khi sử dụng dịch vụ sẽ gửi request từ trình duyệt hoặc ứng dụng đi qua Cloudflare, đóng vai trò lớp bảo mật bên ngoài với chức năng chống tấn công DDoS, tường lửa ứng dụng web (WAF) và lọc lưu lượng độc hại. Sau đó, request được chuyển tiếp đến CloudFront, dịch vụ CDN (Content

Delivery Network) giúp phân phối nội dung tới người dùng, giảm độ trễ và tối ưu tốc độ phản hồi.

Trong dịch vụ Amazon Virtual Private Cloud (Amazon VPC) bao gồm có Public Subnet và Private Subnet

Lớp mạng con công cộng (Public Subnet) gồm các thành phần chính:

- API Gateway: Là điểm vào trung tâm cho các request từ bên ngoài vào hệ thống, giúp định tuyến, xác thực và giới hạn request.
- NLB (Network Load Balancer): Thực hiện cân bằng tải, phân phối lưu lượng truy cập đến các dịch vụ backend để đảm bảo hiệu năng và khả năng mở rộng.
- VPN Server: Cho phép nhóm phát triển (Developer Team) truy cập an toàn vào hệ thống thông qua whitelist IP.
- NAT Gateway: Hỗ trợ các instance trong private subnet có thể truy cập ra Internet (ví dụ tải bản cập nhật, kết nối API bên ngoài) mà vẫn đảm bảo an toàn.
- Server: Xử lý các nghiệp vụ đặc thù hoặc kết nối trực tiếp đến Carrier (nhà mạng) để truyền/nhận dữ liệu.

Lớp mạng con riêng tư (Private Subnet):

- Amazon EKS (Elastic Kubernetes Service): Triển khai cụm Kubernetes để điều phối container.
- Bên trong EKS có nhiều Worker Node, chịu trách nhiệm chạy các ứng dụng containerized.
- Endpoint Gateway: Cho phép kết nối từ private subnet đến các dịch vụ AWS khác mà không cần thông qua Internet công cộng.
- Amazon RDS: Lưu trữ cơ sở dữ liệu quan hệ, là nơi chứa dữ liệu nghiệp vụ và phục vụ các ứng dụng trong EKS.

Khả năng lưu trữ và các dịch vụ hỗ trợ:

- Amazon S3 Bucket: Lưu trữ dữ liệu lớn, dữ liệu thô hoặc kết quả phân tích.
- EFS (Elastic File System) và EBS (Elastic Block Store): Cung cấp không gian lưu trữ mở rộng, chia sẻ cho các Worker Node hoặc dữ liệu ứng dụng.
- Amazon Route 53: Dịch vụ DNS giúp định tuyến request từ người dùng tới server hoặc dịch vụ phù hợp.

Phân tích dữ liệu, bảo mật: Trong mô hình tích hợp nhiều công cụ phân tích và giám sát

- Amazon Athena: cho phép truy vấn trực tiếp dữ liệu trên S3 thông qua ngôn ngữ SQL, hỗ trợ các nhóm phân tích dữ liệu.
- IAM với MFA: đảm bảo đội ngũ phân tích dữ liệu (Data Analyst Team) truy cập vào Athena và S3 một cách an toàn.
- AWS KMS (Key Management Service): cung cấp cơ chế mã hóa và giải mã dữ liệu, đảm bảo tính bảo mật trong suốt vòng đời dữ liệu.

- AWS CloudTrail, CloudWatch, GuardDuty: giám sát toàn bộ hoạt động của hệ thống, phát hiện bất thường và cảnh báo các nguy cơ tiềm ẩn.
- Amazon SNS (Simple Notification Service): gửi cảnh báo tức thời đến quản trị viên khi phát sinh sự cố.
- AWS Lambda (Alert Function): thực thi các hành động tự động khi có sự kiện bảo mật hoặc sự cố được ghi nhận.

Luồng dữ liệu tổng thể:

1. Người dùng gửi yêu cầu → request được xử lý lần lượt qua Cloudflare → CloudFront → API Gateway/NLB.
2. Các yêu cầu được đưa vào EKS Cluster, nơi các ứng dụng containerized xử lý.
3. Ứng dụng trong EKS có thể đọc/ghi dữ liệu từ RDS, S3, EFS, EBS, đồng thời kết nối Internet ra ngoài thông qua NAT Gateway khi cần thiết.
4. Đội ngũ phát triển (Develop team) truy cập an toàn vào hệ thống thông qua VPN Server.
5. Đội ngũ phân tích dữ liệu (Data analyst team) sử dụng Athena để truy vấn dữ liệu trong S3 với sự hỗ trợ bảo mật từ KMS.
6. Toàn bộ hoạt động được giám sát liên tục bởi CloudWatch, GuardDuty, SNS và Lambda, nhằm bảo đảm an toàn và ổn định của hệ thống.

2.3. Ưu, nhược điểm rủi ro bảo mật của mô hình

Ưu và nhược điểm rủi ro bảo mật của mô hình được trình bày qua bảng sau:

Tiêu chí	Ưu điểm	Nhược điểm / Rủi ro bảo mật
Bảo mật nhiều lớp	Cloudflare (WAF, chống DDoS), CloudFront, API Gateway, IAM MFA, KMS tạo hệ thống phòng thủ đa tầng.	Cấu hình phức tạp, dễ xảy ra sai sót (misconfiguration) gây lỗ hổng bảo mật.
Phân tách mạng	Public Subnet và Private Subnet tách biệt, giảm nguy cơ truy cập trái phép vào tài nguyên nhạy cảm.	Sai sót trong Security Group hoặc ACL S3 có thể dẫn đến rò rỉ dữ liệu.
Mã hóa dữ liệu	KMS hỗ trợ mã hóa dữ liệu trên RDS, S3, EFS, EBS, đảm bảo bí mật và toàn vẹn dữ liệu.	Rủi ro khi sử dụng thuật toán cũ, cấu hình không đồng bộ có thể làm suy yếu bảo mật dữ liệu.

Giám sát hệ thống	CloudWatch, CloudTrail, GuardDuty kết hợp SNS và Lambda cảnh báo tức thời sự cố.	Quá tải cảnh báo (alert fatigue) có thể khiến quản trị viên bỏ sót sự kiện quan trọng.
Quyền truy cập	IAM với MFA tăng cường an toàn khi Data Analyst Team và Developer Team truy cập hệ thống.	Rủi ro từ người nội bộ (insider threats) hoặc lạm dụng quyền truy cập qua VPN/IAM.
Hạ tầng AWS	Dịch vụ AWS cung cấp khả năng mở rộng, sẵn sàng cao và cập nhật bảo mật liên tục.	Phụ thuộc mạnh vào AWS/Cloudflare (vendor lock-in); nếu nhà cung cấp gặp sự cố, hệ thống bị ảnh hưởng.
Ứng dụng Container	EKS quản lý container hiệu quả, hỗ trợ cô lập môi trường ứng dụng.	Rủi ro từ container image có lỗ hổng, nguy cơ VM Escape hoặc chiếm quyền kiểm soát cluster.

2.4. Kết luận chương 2

Trong chương 2, đề án đã tập trung phân tích và xây dựng các giải pháp nhằm đảm bảo an toàn dịch vụ trong môi trường điện toán đám mây. Các giải pháp được tiếp cận theo hướng đa lớp (defense-in-depth), đồng thời tuân thủ nguyên tắc chia sẻ trách nhiệm giữa nhà cung cấp dịch vụ và khách hàng. Nội dung chính được trình bày xoay quanh năm nhóm giải pháp chủ yếu, kết hợp với phân tích mô hình doanh nghiệp đang áp dụng, từ đó đánh giá ưu, nhược điểm và rủi ro tiềm ẩn. Về giải pháp đảm bảo kiến trúc đám mây, đã đề xuất nhấn mạnh việc thiết kế phân tầng, tách biệt các vùng mạng public và private, triển khai các công cụ bảo mật mạng như tường lửa, VPN, WAF và NAT gateway. Cách tiếp cận này giúp hạn chế nguy cơ truy cập trái phép từ bên ngoài và giảm thiểu bề mặt tấn công. Ngoài ra, việc tuân thủ các tiêu chuẩn thiết kế bảo mật ngay từ giai đoạn đầu sẽ tạo nền tảng vững chắc cho việc triển khai các lớp bảo mật tiếp theo. Ở quản lý truy cập và xác thực, việc triển khai cơ chế quản lý danh tính tập trung (IAM), phân quyền theo vai trò (RBAC), cùng nguyên tắc tối thiểu quyền hạn (least privilege) giữ vai trò then chốt. Đặc biệt, xác thực đa yếu tố (MFA) và phân tách nhiệm vụ (SoD) góp phần nâng cao độ an toàn, hạn chế rủi ro rò rỉ thông tin từ nội bộ. Các biện pháp này không chỉ bảo vệ tài nguyên mà còn giúp kiểm soát, giám sát và minh bạch hóa hoạt động của người dùng. Đối với bảo vệ dữ liệu lưu trữ và truyền tải, giải pháp tập trung vào mã hóa dữ liệu toàn diện, bao gồm cả dữ liệu khi lưu trữ (at-rest) và khi truyền tải (in-transit). Công cụ quản lý khóa mã hóa (KMS) đảm bảo việc quản lý và sử dụng khóa được kiểm soát chặt chẽ. Đồng thời, các chính sách DLP được triển khai để ngăn chặn rò rỉ dữ liệu nhạy cảm, đảm bảo tính toàn

vẹn và bí mật của thông tin. Trong phần giám sát và phát hiện đe dọa đóng vai trò quan trọng trong duy trì an ninh liên tục. Đề xuất bao gồm thu thập dữ liệu nhật ký tập trung từ nhiều nguồn, chuẩn hóa và làm giàu dữ liệu để tăng giá trị khai thác, phân tích và tương quan sự kiện nhằm phát hiện bất thường, đồng thời phát sinh cảnh báo kịp thời. Việc kết hợp với cơ chế tự động hóa phản ứng (SOAR) giúp rút ngắn thời gian xử lý sự cố, giảm thiểu thiệt hại. Bên cạnh đó, việc lưu trữ, hiển thị và báo cáo định kỳ giúp đáp ứng yêu cầu tuân thủ và nâng cao khả năng quản trị rủi ro. Cuối cùng ở giải pháp bảo mật cho từng loại dịch vụ đám mây, nội dung đã chỉ rõ trách nhiệm và biện pháp đặc thù cho ba mô hình: SaaS, PaaS và IaaS. Với SaaS, trọng tâm là quản lý tài khoản và bảo vệ dữ liệu của người dùng. Với PaaS, giải pháp nhấn mạnh kiểm soát API, bảo mật ứng dụng và cấu hình nền tảng. Trong khi đó, với IaaS, khách hàng phải chịu trách nhiệm nhiều hơn về bảo mật hạ tầng, hệ điều hành và mạng, đồng thời tận dụng các công cụ giám sát từ nhà cung cấp.

Ngoài các giải pháp chung, chương 2 cũng đã trình bày mô hình triển khai thực tế của doanh nghiệp, trong đó kết hợp các dịch vụ đám mây phổ biến với những lớp bảo mật như Cloudflare, VPN, IAM, KMS và hệ thống giám sát tập trung. Phân tích thực tế cho thấy mô hình này mang lại nhiều lợi ích về tính linh hoạt, hiệu quả chi phí và khả năng mở rộng, nhưng đồng thời cũng đặt ra các thách thức về năng lực quản trị bảo mật, phụ thuộc nhà cung cấp và yêu cầu tuân thủ pháp lý. Từ việc đánh giá, có thể rút ra rằng mô hình bảo mật đám mây hiện nay có ưu điểm là giảm chi phí đầu tư hạ tầng, nâng cao khả năng sẵn sàng và tăng tốc triển khai dịch vụ. Tuy nhiên, vẫn tồn tại nhược điểm như chi phí vận hành bảo mật cao, thiếu nhân lực chuyên môn và nguy cơ lộ lọt dữ liệu do cấu hình sai. Đồng thời, các rủi ro như tấn công DDoS, khai thác lỗ hổng ứng dụng hay mối đe dọa nội bộ cần được xem xét kỹ lưỡng.

CHƯƠNG 3. TRIỂN KHAI THỬ NGHIỆM GIẢI PHÁP ĐẢM BẢO AN TOÀN DỊCH VỤ TRONG ĐIỆN TOÁN Đám Mây

3.1. Mô hình triển khai

3.1.1. Mục tiêu

Mô hình triển khai thử nghiệm được xây dựng trên nền tảng điện toán đám mây Google Cloud Platform (GCP), với mục tiêu chính là kiểm chứng hiệu quả của giải pháp phòng thủ đa lớp (Defense-in-Depth) trong việc bảo vệ dịch vụ web trước các mối đe dọa an ninh mạng phổ biến. Cụ thể, mô hình hướng tới:

- Xác minh khả năng ngăn chặn lưu lượng độc hại tại biên bằng Google Cloud Armor.
- Đánh giá năng lực phát hiện và giám sát nội bộ thông qua Packet Mirroring và Suricata IDS.
- Kiểm chứng việc ghi nhận bằng chứng tập trung và khả năng truy vấn phân tích bằng Cloud Logging.
- Định lượng mức độ hiệu quả bằng các chỉ số (ví dụ: tỉ lệ phát hiện, tỉ lệ false positive, thời gian phản ánh log).
- Phạm vi & giả định thử nghiệm:
- Môi trường thử nghiệm chỉ sử dụng giao thức HTTP (không thực hiện TLS interception) trừ khi được ghi chú riêng.
- Packet Mirroring cấu hình 100% cho mục đích đánh giá; trong môi trường production có thể điều chỉnh sampling.
- Kiểm thử được thực hiện từ một nguồn tấn công bên ngoài (public IP) và từ các nút trong cùng VPC để mô phỏng các kịch bản nội bộ.

3.1.2 Nội dung chi tiết:

Hệ thống được tổ chức thành nhiều lớp bảo vệ độc lập, hoạt động liên kết và bổ trợ lẫn nhau, tạo thành một “vòng tròn an ninh khép kín” cho ứng dụng web triển khai trên GCP. Các khía cạnh chính cần có trong mô tả:

- Phòng ngừa chủ động (Preventive Defense)
 - Triển khai Google Cloud Armor làm WAF ở lớp biên để chặn các yêu cầu có dấu hiệu tấn công (OWASP Top 10, rate-limit, IP/geo block).

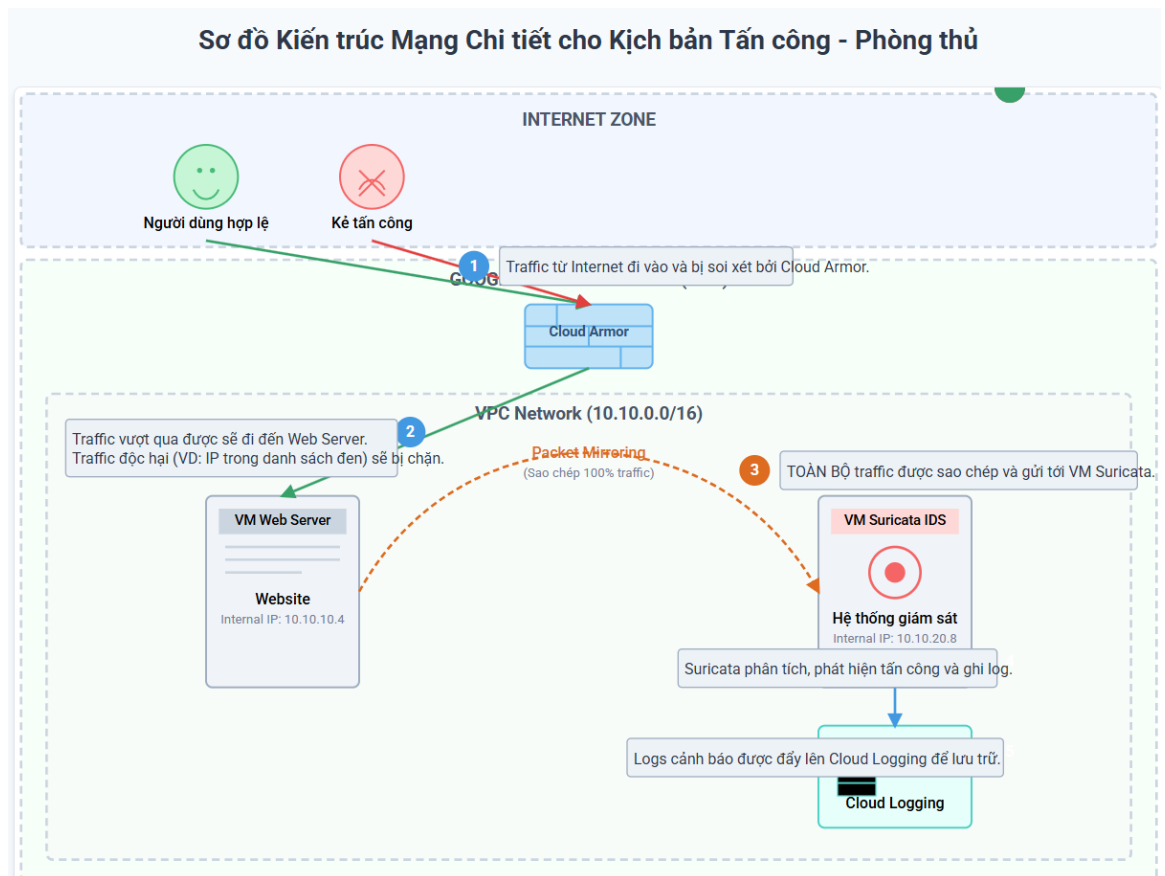
- Load Balancer (HTTP(S) LB) đóng vai trò điểm tiếp nhận công cộng và tích hợp Cloud Armor.
- Giám sát và phát hiện (Detection & Monitoring)
 - Packet Mirroring sao chép lưu lượng từ VM Web tới VM Suricata cho phân tích thụ động (IDS).
 - Suricata phân tích lưu lượng theo ruleset (Emerging Threats + local rules) để phát hiện pattern bất thường.
- Ghi nhận và phân tích (Evidence Logging & Analysis)
 - Ops Agent / Suricata đẩy log (ví dụ eve.json) lên Cloud Logging với logName = suricata-eve.
 - Logs Explorer dùng để truy vấn, chụp bằng chứng và làm nguồn cho phân tích sau sự cố hoặc tích hợp SIEM.
- Mục tiêu đánh giá (KPI đề xuất):
 - Tỷ lệ phát hiện (Detection Rate) cho các kịch bản mẫu $\geq 90\%$ (kịch bản quét, SQLi).
 - Tỷ lệ false positive $< 5\%$ trong bộ test chuẩn.
 - Thời gian từ event $\rightarrow$ log hiển thị trên Cloud Logging $< 5s$ (mục tiêu thử nghiệm).
 - Cloud Armor chặn $\geq 90\%$ các request thử nghiệm mang payload exploit.

Công cụ & môi trường: liệt kê tóm tắt các thành phần và phiên bản (ví dụ: Suricata vX.Y, Nginx 1.xx, sqlmap, nmap, Curl, GCP services: Cloud Armor, Packet Mirroring, Cloud Logging)

3.2. Mô tả mô hình triển khai

3.2.1 Mô hình tổng quan

Mô hình được chia thành các vùng (zone) và các lớp (layer) chức năng riêng biệt, thể hiện rõ luồng lưu thông dữ liệu (traffic flow) và vai trò của từng thành phần.



Hình 3.1: Sơ đồ kiến trúc tổng thể hệ thống phòng thủ đa lớp trên nền tảng GCP.

3.2.1.1. Vùng Internet (Internet Zone)

Đây là vùng ngoài cùng, là nguồn của mọi truy cập hướng đến hệ thống. Trong vùng này, chúng ta xác định hai tác nhân chính:

- **Người dùng hợp lệ (Legitimate Users):** Là những người dùng cuối có nhu cầu truy cập và sử dụng dịch vụ do website cung cấp. Luồng traffic từ nhóm người dùng này được biểu diễn bằng mũi tên màu xanh lá, tượng trưng cho các truy cập an toàn và được mong đợi.
- **Kẻ tấn công (Attacker):** Là các cá nhân hoặc tổ chức có ý đồ xấu, thực hiện các hành vi gây hại cho hệ thống. Các hành vi này có thể bao gồm: tấn công từ chối dịch vụ (DDoS), dò quét lỗ hổng bảo mật (Vulnerability Scanning), tấn công vào ứng dụng web (Web Application Attacks) như SQL Injection, Cross-Site Scripting (XSS),... Luồng traffic từ tác nhân này được biểu diễn bằng mũi tên màu đỏ, tượng trưng cho các truy cập độc hại và cần được ngăn chặn.

3.2.1.2. Vùng Google Cloud Platform (GCP)

Toàn bộ hạ tầng của ứng dụng được triển khai trong môi trường GCP. Vùng này đóng vai trò là một pháo đài số, cung cấp các dịch vụ và công cụ để xây dựng nên các lớp phòng thủ kiên cố.

3.2.1.2.1. Lớp phòng thủ vòng ngoài: Google Cloud Armor

Mọi traffic từ Internet khi đi vào GCP đều phải đi qua chốt chặn đầu tiên và quan trọng nhất là Google Cloud Armor. Đây là dịch vụ tường lửa ứng dụng web (Web Application Firewall - WAF) và phòng chống DDoS do Google cung cấp.

- Chức năng (Annotation 1): Cloud Armor hoạt động như một bộ lọc thông minh ở biên mạng. Nó soi xét, phân tích từng yêu cầu (request) dựa trên một tập các quy tắc (rules) được định nghĩa trước.
- Cơ chế hoạt động (Annotation 2):
 - Chặn tấn công DDoS: Cloud Armor có khả năng tự động giảm thiểu các cuộc tấn công DDoS tầng 3, 4 (network layer) và tầng 7 (application layer).
 - Lọc theo địa chỉ IP và vị trí địa lý: Cho phép tạo các quy tắc để chặn (deny) hoặc cho phép (allow) truy cập từ những dải IP hoặc quốc gia cụ thể. Đây là biện pháp hiệu quả để ngăn chặn các cuộc tấn công có chủ đích từ một nguồn đã biết.
 - Bộ quy tắc WAF dựng sẵn: Cung cấp các bộ quy tắc được tinh chỉnh sẵn để chống lại Top 10 lỗ hổng bảo mật phổ biến nhất theo OWASP (ví dụ: SQLi, XSS), giúp bảo vệ ứng dụng mà không cần can thiệp sâu vào mã nguồn.
 - Giới hạn tần suất truy cập (Rate Limiting): Ngăn chặn các cuộc tấn công brute-force hoặc tấn công làm cạn kiệt tài nguyên bằng cách giới hạn số lượng request từ một client trong một khoảng thời gian nhất định.
- Kết quả: Traffic hợp lệ sẽ được phép đi qua, trong khi traffic độc hại sẽ bị chặn ngay tại lớp này, giúp giảm tải và bảo vệ cho các tài nguyên bên trong.

3.2.1.2.2. Vùng Mạng riêng ảo (VPC Network)

Sau khi vượt qua Cloud Armor, traffic sẽ đi vào VPC Network (Virtual Private Cloud). Đây là một không gian mạng logic, hoàn toàn tách biệt và được cô lập dành riêng cho dự án của người dùng trên GCP.

- Không gian địa chỉ: Trong sơ đồ, VPC được cấu hình với dải địa chỉ 10.10.0.0/16, cho phép phân chia thành các mạng con (subnet) khác nhau để cô lập tài nguyên theo chức năng.
- Vai trò: VPC đóng vai trò như một mạng LAN ảo trên đám mây, cho phép người dùng toàn quyền kiểm soát các quy tắc tường lửa nội bộ (Firewall Rules), bảng định tuyến (Route Tables), và luồng giao tiếp giữa các tài nguyên bên trong.

3.2.1.2.3. Các thành phần bên trong VPC

- VM Web Server (Máy chủ Nạn nhân):
 - Đây là tài nguyên cốt lõi cần được bảo vệ, nơi ứng dụng website được cài đặt và vận hành.
 - Máy chủ này có một địa chỉ IP nội bộ (10.10.10.3) và được cấu hình để nhận traffic từ Cloud Armor.
- VM Suricata IDS (Hệ thống Phát hiện Xâm nhập):
 - Vai trò: Đây là "trái tim" của hệ thống giám sát. Suricata là một hệ thống phát hiện xâm nhập (Intrusion Detection System - IDS) mã nguồn mở, mạnh mẽ. Nhiệm vụ của nó không phải là ngăn chặn, mà là phát hiện các hành vi bất thường hoặc độc hại đã lọt được vào mạng nội bộ.
 - Cơ chế hoạt động (Annotation 4): Suricata phân tích các gói tin dựa trên một bộ quy tắc (ruleset) khổng lồ, bao gồm hàng chục nghìn chữ ký của các loại tấn công đã biết. Khi một gói tin có dấu hiệu trùng khớp với một quy tắc, Suricata sẽ ngay lập tức tạo ra một cảnh báo (alert) và ghi vào file log.
 - Triển khai: Máy chủ này chỉ có IP nội bộ (10.10.20.7) và không thể truy cập trực tiếp từ Internet, đảm bảo an toàn cho chính hệ thống giám sát.
- Packet Mirroring (Cơ chế Phản chiếu Gói tin):
 - Công nghệ then chốt (Annotation 3): Đây là tính năng đặc biệt của GCP, cho phép sao chép toàn bộ 100% traffic (cả chiều vào

và chiều ra) của VM Web Server và gửi một bản sao đến VM Suricata IDS để phân tích.

- Ưu điểm vượt trội:
 - Giám sát thụ động (Passive Monitoring): Không cần cài đặt bất kỳ agent nào lên máy chủ web, do đó không làm ảnh hưởng đến hiệu năng hoặc gây ra rủi ro cho ứng dụng chính.
 - Tầm nhìn toàn diện: Suricata có thể "nhìn thấy" mọi thứ, kể cả các nỗ lực tấn công dù thành công hay thất bại, cung cấp một bức tranh đầy đủ về tình hình an ninh mạng.
- Cloud Logging (Dịch vụ Lưu trữ Nhật ký):
 - Vai trò (Annotation 5): Đây là nơi tập trung, lưu trữ an toàn và lâu dài các bằng chứng về an ninh.
 - Tích hợp: Các cảnh báo do Suricata tạo ra trên máy chủ giám sát sẽ được cấu hình để đẩy lên Cloud Logging. Việc này giúp tập trung hóa việc quản lý log, cho phép tìm kiếm, phân tích, và thiết lập các cảnh báo tự động (ví dụ: gửi email cho quản trị viên khi phát hiện một cuộc tấn công nghiêm trọng)

3.2.1. Cấu hình hạ tầng và môi trường triển khai

3.2.2.1. Project & API

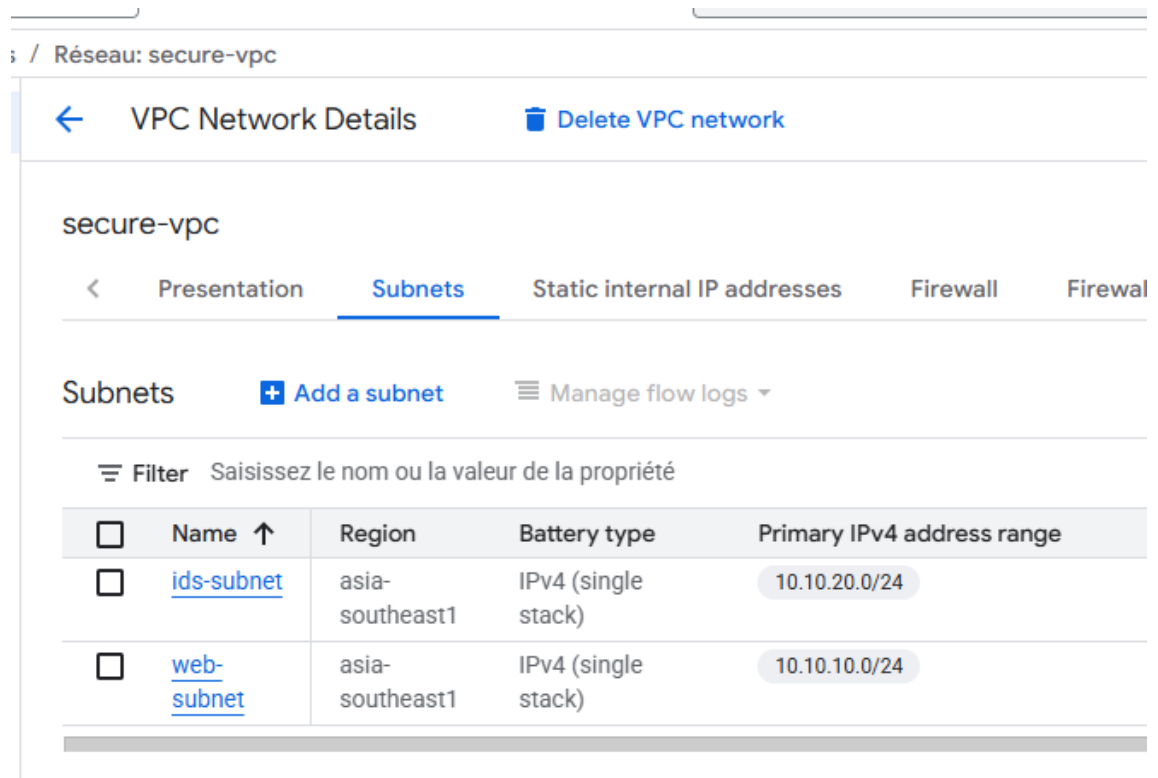
- Tạo Project GCP:
 - Tên project: cloud-secu (ví dụ).
 - Billing: bật billing account hợp lệ.
- APIs cần kích hoạt (bật trong Console → APIs & Services):
 - Compute Engine API
 - VPC API
 - Cloud Armor API
 - Cloud Logging API & Cloud Monitoring API
 - Packet Mirroring API (nếu tách)
 - Cloud DNS (nếu dùng custom DNS)

Name	↓ Requests	Erro
Cloud Logging API	9,803	
Cloud Monitoring API	1,610	
Compute Engine API	789	
Gemini for Google Cloud API	28	
Cloud Identity-Aware Proxy API	3	
Gemini Cloud Assist API	2	
Application Default Credentials API		

Hình 3.2: Tổng hợp các API cần bật

3.2.2.2. Mạng (VPC) và Subnet

- VPC chính
 - Tên: secure-vpc
 - CIDR: 10.10.0.0/16
- Subnets (kèm CIDR, mục đích)
 - web-subnet — 10.10.10.0/24 — chứa VM Web Server.
 - ids-subnet — 10.10.20.0/24 — chứa VM Suricata IDS.
- VPC Flow Logs
 - Bật cho secure-vpc, gửi tới Cloud Logging.
 - Retention: 30–90 ngày (tùy yêu cầu).
- NAT / Internet egress
 - Cloud NAT cấu hình cho các VM private muốn egress internet (update rules).



Hình 3.3: Cấu trúc mạng VPC và mạng con.

3.2.2.3. Firewall Rules (GCP Firewall)

- Luồng rule cơ bản (name / src / dst / ports / action):

Tên Rule	Loại	Cổng thức / Giao	Mục đích chính	Tag Target /
allow-egress-internet	Egress	TCP:443	Cho phép máy chủ Suricata IDS truy cập Internet để cập nhật ruleset và gửi log lên Cloud Logging.	suricata
allow-health-check	Ingress	TCP:22,80,443	Cho phép các yêu cầu health check từ Load Balancer hoặc Google Services đến Web Server.	http-server, https-server
allow-iap-ssh	Ingress	TCP:22	Cho phép quản trị viên SSH qua kênh IAP (Identity-Aware Proxy), tránh lộ IP công khai.	Áp dụng cho tất cả VM

allow-mirrored-traffic	Ingress	TCP,UDP,ICMP	Cho phép traffic mirrored từ Web Server đi vào máy Suricata IDS để phân tích.	suricata
secure-vpc-allow-http	Ingress	TCP:80	Cho phép truy cập HTTP vào Web Server từ Internet thông qua Cloud Armor.	http-server
secure-vpc-allow-https	Ingress	TCP:443	Cho phép truy cập HTTPS vào Web Server.	https-server

Bảng 3.1: chi tiết các rules firewall cần tạo

Filter Enter property name or value

Name	Type	Targets	Filters	Protocols / ports	Action	Priority	Network ↑
allow-egress-internet	Egress	suricata	IP ranges: 0.0.0.0/0	tcp:443	Allow	1000	secure-vpc
allow-health-check	Ingress	Apply to all	IP ranges:	tcp:22, 80, 443	Allow	1000	secure-vpc
allow-iap-ssh	Ingress	Apply to all	IP ranges:	tcp:22	Allow	1000	secure-vpc
allow-mirrored-traffic	Ingress	suricata	IP ranges:	tcp udp icmp	Allow	1000	secure-vpc
secure-vpc-allow-http	Ingress	http-server	IP ranges:	tcp:80	Allow	1000	secure-vpc
secure-vpc-allow-https	Ingress	https-server	IP ranges:	tcp:443	Allow	1000	secure-vpc
allow-internal	Ingress	Apply to all	IP ranges:	tcp udp icmp	Allow	65534	secure-vpc

Hình 3.4: Bảng firewall rules trong Console.

3.2.2.4. Google Cloud Armor (WAF & Rate-limit)

- Security policy
 - Tên: default-security-policy-for-backend-service-backend-web.
 - Custom rules:
 - IP deny list: danh sách IP/ASN block.
 - Geo-blocking: block countries theo danh sách (nếu cần).
 - Rate limiting: ví dụ 100 req / 10s / client (tùy SLA).

- Action default: allow (với logging), critical signatures deny(403).
- Khi tạo backend load balancer cho web-server nó sẽ có mục yêu cầu tạo rules cloud armor, sau đó ta sẽ nhấn vào và nó sẽ tự động tạo một security policy có sẵn, ta chỉ việc vào cloud armor và thêm rules.
- Dữ liệu cần điền: danh sách IP block, danh sách quốc gia, threshold rate-limit numeric.

☐	Action	Type	Match
☐	Deny (403)		evaluatePreconfiguredWaf('sqli-v33-stable', {'sensitivity': 1})
☐	Deny (403)		evaluatePreconfiguredWaf('xss-v33-stable', {'sensitivity': 1})
☐	Deny (403)		evaluatePreconfiguredWaf('lfi-v33-stable', {'sensitivity': 1})
☐	Deny (403)		evaluatePreconfiguredWaf('rfi-v33-stable', {'sensitivity': 1})
☐	Deny (403)		evaluatePreconfiguredWaf('rce-v33-stable', {'sensitivity': 1})
☐	Deny (403)		evaluatePreconfiguredWaf('java-v33-stable', {'sensitivity': 1})
☐	Deny (403)		evaluatePreconfiguredWaf('php-v33-stable', {'sensitivity': 1})
☐	Deny (403)		evaluatePreconfiguredWaf('methodenforcement-v33-stable', {'sensitivity': 1})
☐	Rate based ban	IP addresses/ranges	*

Hình 3.5 : cấu hình Cloud Armor policy & rule list.

3.2.2.5. Health check

Health check cho Web Server (web-hc)

- Phạm vi: Global
- Giao thức: HTTP
- Port: 80
- Đường dẫn kiểm tra: /
- Mục đích: Kiểm tra trạng thái hoạt động của backend backend-web, đảm bảo rằng Load Balancer chỉ phân phối lưu lượng đến các VM phản hồi hợp lệ.

Health check cho Suricata IDS (hc-suricata)

- Phạm vi: Regional (asia-southeast1)
- Giao thức: TCP
- Port: 22
- Mục đích: Kiểm tra khả năng phản hồi kết nối nội bộ của dịch vụ ilb-suricata-collector, đảm bảo IDS luôn sẵn sàng tiếp nhận luồng traffic phản chiếu.

Filter Saisissez le nom ou la valeur de la propriété ?								
☐	Name ↑	Scope of application	Region	Host	Access path	Protocol	Port	Used by
☐	hc-suricata	Regional	asia-southeast1			TCP	22	ilb-suricata-collector
☐	web-hc	Overall			/	HTTP	80	backend-web

Hình 3.6: Danh sách Health Checks gồm web-hc và hc-suricata

Các health check này giúp hệ thống tự động loại bỏ các instance gặp sự cố khỏi backend pool, duy trì tính ổn định và độ tin cậy cao cho toàn bộ mô hình phòng thủ đa lớp.

3.2.2.6. Load Balancer / Backend Service

Hệ thống sử dụng hai Load Balancer riêng biệt, đảm nhận hai vai trò khác nhau trong mô hình phòng thủ đa lớp:

- Load Balancer bảo vệ ứng dụng Web – gắn Cloud Armor:
- Tên: web-lb
- Loại: HTTP(S) Load Balancer (Global)
- Frontend: Public IP – tiếp nhận toàn bộ lưu lượng truy cập từ Internet.
- Backend Service: Nhóm các máy chủ web (vm-webserver) trong subnet web-subnet.
- Chính sách bảo vệ: Gắn policy Google Cloud Armor (default-security-policy-for-backend-service-backend-web) để lọc và chặn các request độc hại trước khi đến backend.
- Health Check: Kiểm tra endpoint /health của web server, interval 10s, timeout 5s.
- Chức năng chính:
 - Lọc truy cập, bảo vệ chống tấn công DDoS, SQLi, XSS,...
 - Chuyển tiếp lưu lượng “đã qua lọc” đến backend web server.

Frontend

Protocol 	IP:Port	Certificate	Certificate Map	SSL Policy	Ne
HTTP	34.110.231.252:80	-			Pr

Routing rules

Hosts 	Paths	Backend
All unmatched (default)	All unmatched (default)	backend-web

Backend

Backend services

1. backend-web

Endpoint protocol	HTTP
Named port	http
Timeout	30 seconds
IP address selection policy 	Only IPv4
Health check	web-hc
Cloud CDN	Disabled
Logging	Enabled (sample rate: 1) All optional fields excluded
Backend security policy	default-security-policy-for-backend-service-backend-web
 Show advanced	

Backends

Name 	Type	IP stack type	Scope	Healthy
web-server-group	Instance group	IPv4	asia-southeast1-b	 1 of 1

Hình 3.6 : Cấu hình của web-lb.

Load Balancer phản chiếu lưu lượng – phục vụ Packet Mirroring:

- Tên: ilb-suricata-collector
- Loại: Internal TCP/UDP Load Balancer
- Frontend: Internal IP trong mạng secure-vpc.
- Backend Service: Nhóm instance gồm vm-webserver và vm-suricata – trong đó Suricata đóng vai trò collector.
- Mục đích:
 - Thu thập và phân phối bản sao (mirror) của toàn bộ traffic từ máy chủ web.
 - Chuyển hướng gói phản chiếu đến máy Suricata IDS để phân tích hành vi xâm nhập.
- Health Check: ping nội bộ giữa web server và IDS để đảm bảo kết nối phản chiếu hoạt động ổn định.
- Không gắn Cloud Armor, nhằm đảm bảo lưu lượng được sao chép nguyên vẹn (bao gồm cả gói độc hại) phục vụ phát hiện tấn công.
- *Lưu ý:
 - Thêm route local khi cần bằng tải của suricata báo không hoạt động:
 - `sudo ip route add to local 10.10.20.11 dev ens4 proto 66`
 - Xác nhận lại:
 - `sudo ip route list table local | grep 10.10.20.11`

- Nhắc nhở: route thủ công sẽ mất sau reboot. Giải pháp chuẩn vẫn là để guest agent quản lý.

Load balancer details

Edit

Delete

View in Network Topolog

ilb-suricata-collector

Internal passthrough Network Load Balancer

Frontend

Protocol ↑	IP version	Scope	Subnetwork	IP:Ports
TCP	IPv4	asia-southeast1	ids-subnet	10.10.20.11:all

Backend

Region	asia-southeast1
Network	secure-vpc
Endpoint protocol	TCP
Session affinity	None
Health check	hc-suricata
Logging	Disabled

✓

Advanced configurations

Instance group ↑	Type	IP stack type	Scope	Autosc
ids-group	Instance group	IPv4	asia-southeast1-b	No con

Hình 3.7 : Cấu hình của ilb-suricata-collector.

3.2.2.7. Compute Engine — VM Web Server (target)

- Instance config (chỉ liệt kê)
 - Tên: web-server
 - Machine type: e2-medium (tối thiểu), tùy scale.
 - Subnet/Internal IP: 10.10.10.3 (static internal).
 - External IP: Chỉ bật lúc đầu để tải những gói quan trọng.
 - Tags: tag-web.
 - Disk: boot SSD 50GB (Ubuntu 24.04 LTS).
 - *Lưu ý: trong quá trình tạo phải tích bật ops argent

Details	Observability	OS Info	Screenshot
Name	web-server		
Instance Id	3249718356821989484		
Description	None		
Type	Instance		
Status	✔ Running		
Creation time	Oct 2, 2025, 12:36:03 AM UTC+07:00		
Location ?	asia-southeast1-b		
Boot disk source image	ubuntu-2404-noble-amd64-v20251001		
Boot disk architecture	X86_64		
Boot disk license type	Free		
Instance template	None		
In use by	web-server-group		
Physical host ?	None		
Maintenance status ?	—		
Reservations	Automatically choose		
Labels	goog-ops-a... : v2-x86-tem...		
Tags ?	—		
Deletion protection	Disabled		
Confidential VM service ?	Disabled		
Preserved state size	0 GB		

Machine configuration	
Machine type	e2-medium (2 vCPUs, 4 GB Memory)
CPU platform	Intel Broadwell
Minimum CPU platform	None
Architecture	x86_64

Hình 3.8: cấu hình VM web trong Console.

- Cài đặt Nginx chạy các lệnh sau:
 - Sudo apt update && sudo apt install nginx
- Cấu hình cho Nginx:
 - Chạy lệnh: sudo nano /etc/nginx/nginx.conf
 - thêm đoạn cấu hình dưới đây vào trong http{} có sẵn trong file:

```
ssl_protocols TLSv1 TLSv1.1 TLSv1.2 TLSv1.3; # Dropping SSLv3, ref: POODLE
ssl_prefer_server_ciphers on;

set_real_ip_from 35.191.0.0/16;
set_real_ip_from 130.211.0.0/22;
set_real_ip_from 34.96.0.0/12;

real_ip_header X-Forwarded-For;
real_ip_recursive on;
```

Hình 3.9: đoạn mã cần thêm vào file cấu hình nginx.conf

- Sau đó chạy lệnh dưới đây để kiểm tra và reload lại:
 - sudo nginx -t
 - sudo systemctl reload nginx

3.2.2.8. Compute Engine — VM Suricata IDS (collector)

- Instance config
 - Tên: vm-suricata
 - Machine type: e2-standard-4 (hoặc cao hơn tùy throughput).
 - Subnet/Internal IP: 10.10.20.7 (static).
 - Disk: boot 50GB + data disk 200–500GB cho logs.
 - Tags: tag-ids.
- Suricata-specific data/config
 - Log paths: /var/log/suricata/fast.log, /var/log/suricata/eve.json.
 - Local signatures (nếu có): file local.rules.
 - Retention policy: keep raw pcap/logs 7–30 days on-disk; push archive to Cloud Storage for long-term.
 - *Lưu ý: trong quá trình tạo phải tích bật ops argent

Name	suricata-ids
Instance Id	5291890355911841954
Description	None
Type	Instance
Status	Running
Creation time	Oct 2, 2025, 12:35:09 AM UTC+07:00
Location	asia-southeast1-b
Boot disk source image	ubuntu-2404-noble-amd64-v20251001
Boot disk architecture	X86_64
Boot disk license type	Free
Instance template	None
In use by	ids-group
Physical host	None
Maintenance status	—
Reservations	Automatically choose
Labels	goog-ops-a... : v2-x86-tem...
Tags	—
Deletion protection	Disabled
Confidential VM service	Disabled
Preserved state size	0 GB

Machine configuration	
Machine type	e2-medium (2 vCPUs, 4 GB Memory)
CPU platform	Intel Broadwell
Minimum CPU platform	None
Architecture	x86_64

Hình 3.11: bảng cấu hình VM IDS.

- Cài đặt suricata:
 - Ta chạy danh sách lệnh sau đây để cập nhật và cài đặt:
 - sudo apt update

- `sudo apt upgrade -y`
- `sudo apt install software-properties-common -y`
- `sudo add-apt-repository ppa:oisf/suricata-stable`
- `sudo apt update`
- `sudo apt install suricata -y`
- Cấu hình Suricata xuất log JSON:
 - Ta vào file `suricata.yaml` với lệnh:

`sudo vim /etc/suricata/suricata.yaml` và bật những mục cần thiết

```
outputs:
- eve-log:
    enabled: yes
    filetype: regular
    filename: /var/log/suricata/eve.json
    types:
      - alert
      - http
      - dns
      - tls
```

Hình 3.12: Những mục cần thiết nhất phải bật cho file `eve.log`

- Tìm section `af-packet` và sửa interface: → sửa thành `ens4` (hoặc đúng NIC của VM).
- Tìm section `vars` và sửa `HOME_NET` thành `10.10.0.0/16`.
- *Lưu ý: Nếu bạn cần nhiều thông tin hơn để phân tích thì có thể tìm phần type `alert` của `eve.log` và xóa “#” để bật các mục bạn cần ví dụ: `payload`, `metadata`, `http-body`,...
- Cấu hình Ops Agent để thu thập log Suricata
 - Mở file cấu hình của Ops Agent bằng lệnh:
 - `sudo nano /etc/google-cloud-ops-agent/config.yaml`
 - Thêm nội dung cấu hình dưới đây vào file. Cấu hình này sẽ chỉ cho Ops Agent biết cách tìm, đọc và gửi file log `eve.json` của Suricata lên Cloud Logging.

```
logging:
receivers:
  suricata-eve:
    type: files
    include_paths:
```

```
- /var/log/suricata/eve.json
```

```
processors:
```

```
  parse-eve:
```

```
    type: parse_json
```

```
service:
```

```
  pipelines:
```

```
    default_pipeline:
```

```
      receivers: [suricata-eve]
```

```
      processors: [parse-eve]
```

```
      exporters: [google]
```

- Lưu file và khởi động lại dịch vụ Ops Agent để áp dụng thay đổi:

- `sudo systemctl restart google-cloud-ops-agent`
- `sudo systemctl status google-cloud-ops-agent`

3.2.2.9. Packet Mirroring

- Policy
 - Tên: pm-web-to-suricata.
 - Source: NIC của vm-webserver / web-subnet (chỉ đường đi cần giám sát).
 - Collector: vm-suricata (10.10.20.7).
 - Mirrored traffic: ingress + egress, protocols: TCP, UDP, ICMP (hoặc any).
 - Sampling: 100% (đề xuất cho môi trường thử nghiệm).
- Dữ liệu cần điền: source instance/instance group, collector instance, mirror filter.

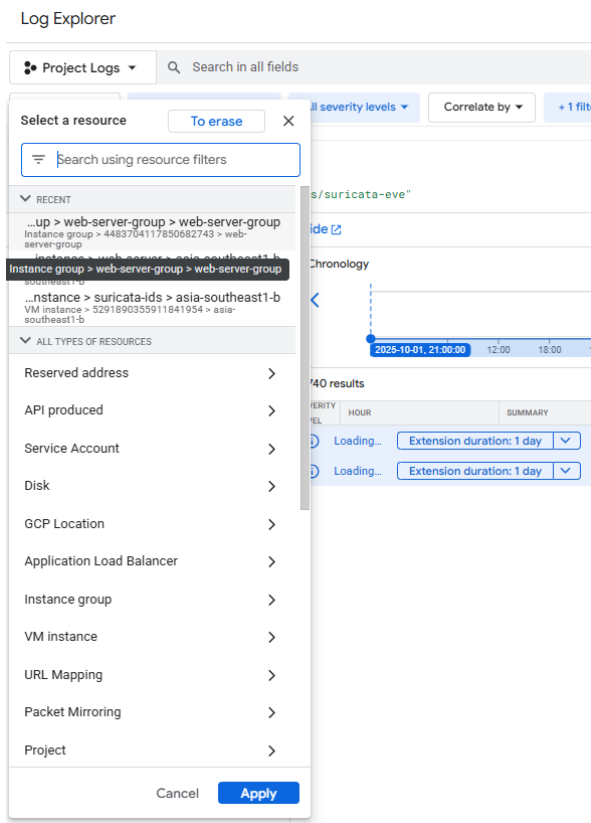


Hình 3.13: Cấu hình Packet Mirroring policy *pm-web-to-suricata*

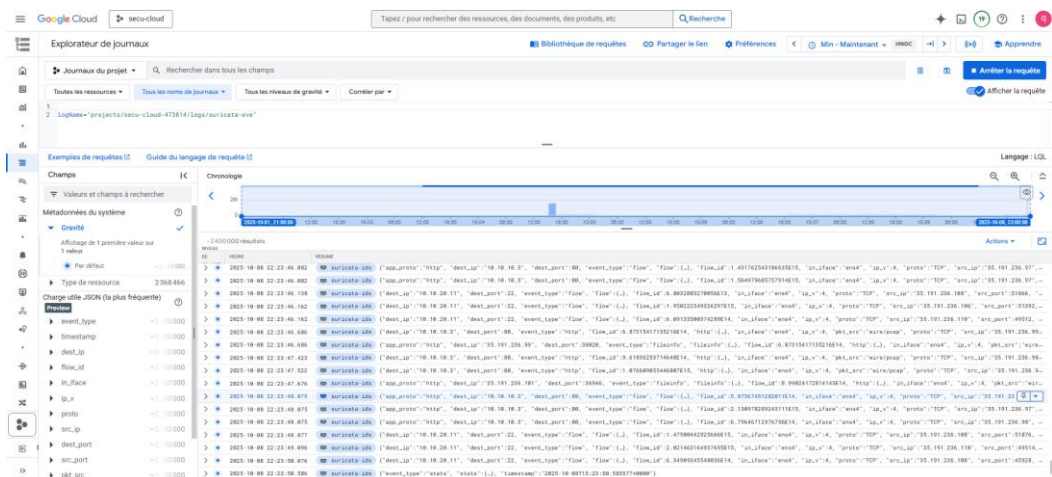
3.2.2.10. Cloud Logging

- Cấu hình thu thập log:
 - Khi khởi tạo máy ảo VM Suricata, bắt tùy chọn “Install Ops Agent” trong phần Management → Monitoring.
 - Ops Agent sẽ tự động thu thập log hệ thống (syslog, daemon.log, ...) và gửi về Cloud Logging mà không cần thao tác thủ công.
- Tích hợp log của Suricata:
 - Sau khi cài đặt Suricata, cấu hình để tệp log eve.json (log sự kiện an ninh của Suricata) được chuyển lên Cloud Logging thông qua Ops Agent.
 - Các bản ghi này được lưu với log name: suricata-eve
- Kiểm tra log trong Logs Explorer:
 - Để xác nhận hoạt động của hệ thống thu thập log, truy cập Cloud Logging → Logs Explorer và sử dụng truy vấn kiểm tra:
 - Ví dụ về một vài câu lệnh truy vấn:
 - `logName="projects/ID-PROJECT/logs/suricata-eve"`
 - `jsonPayload.alert.signature:*`

- *Lưu ý: bạn có thể sử dụng mục truy vấn nhanh mà cloud logging có sẵn:



Hình 3.14: Những truy vấn có sẵn trong cloud logging.



Hình 3.15: Giao diện cloud logging trong console

3.3. Thực nghiệm đánh giá mô hình

3.3.1. Mục tiêu thực nghiệm

Mục tiêu của phần thực nghiệm là kiểm chứng khả năng hoạt động và hiệu quả của mô hình phòng thủ đa lớp triển khai trên nền tảng Google Cloud Platform (GCP), bao gồm:

- Khả năng ngăn chặn tấn công tại lớp biên thông qua Cloud Armor (WAF).
- Khả năng giám sát, phát hiện và ghi nhận hành vi tấn công vượt qua lớp bảo vệ bởi hệ thống Suricata IDS.
- Kiểm chứng tính toàn vẹn của luồng phản chiếu gói tin (Packet Mirroring) và hiệu quả lưu trữ log tập trung (Cloud Logging).

3.3.2. Môi trường và cấu hình thử nghiệm

Thành phần	Thông số cấu hình
VM Web Server	10.10.10.3 – Public IP qua Load Balancer: 34.110.231.252
VM Suricata IDS	10.10.20.7
Attacker	IP công cộng: 171.250.164.174
Packet Mirroring	Sao chép 100% lưu lượng từ VM Web → Suricata
Cloud Armor	Gắn trên Load Balancer, lọc lưu lượng HTTP(S) ở biên
Cloud Logging	Thu thập log Suricata (eve.json) và log hệ thống

Bảng 3.2: tổng hợp cấu hình

3.3.3. Kịch bản thử nghiệm

Thực nghiệm bao gồm hai nhóm kịch bản:

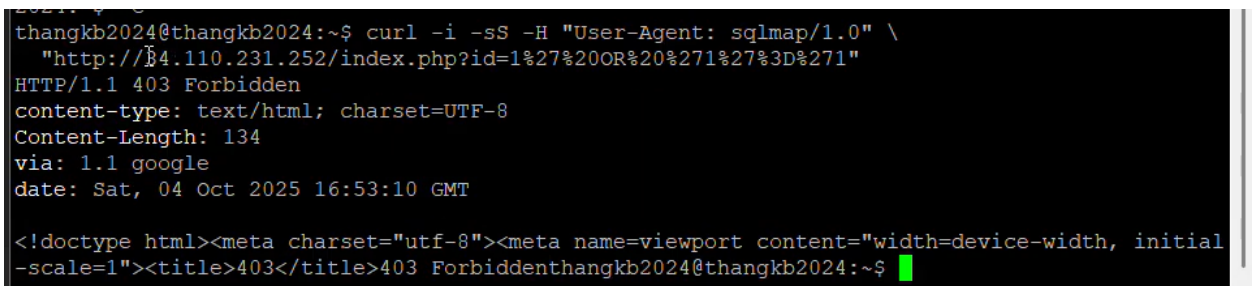
- Kịch bản A: Chặn tại biên (Cloud Armor)
 - Mục tiêu: xác nhận Cloud Armor chặn các request mang đặc trưng tấn công thuộc OWASP Top 10 trước khi request tới backend.
 - Phương pháp: gửi loạt request mô phỏng các lỗ hổng/độc hại (SQLi, XSS, LFI, quét cổng, brute-force, v.v.) đến địa chỉ public của hệ thống, quan sát hành vi rule matching trên Cloud Armor và kiểm tra không có bản ghi tương ứng xuất hiện trên Web Server hoặc Suricata collector.
 - Kết quả mong đợi: Cloud Armor trả về HTTP 403/deny; bản ghi DENY xuất hiện trong Cloud Logging; không có alert/log tương ứng trong Suricata hoặc web server logs.
- Kịch bản B: Cho phép & Giám sát (Packet Mirroring + Suricata)

- Mục tiêu: xác nhận traffic hợp lệ được forward đến backend trong khi Suricata nhận được bản sao để phát hiện/ghi nhận sự kiện.
- Phương pháp: gửi request hợp lệ (ví dụ truy cập trang chủ, POST login). Quan sát flow: Cloud Armor → Load Balancer → backend; đồng thời Packet Mirroring sao chép lưu lượng tới Suricata; Suricata sinh event/alert; event được đẩy lên Cloud Logging. Kiểm tra trường X-Forwarded-For để xác định IP client thật.
- Kết quả mong đợi: ALLOW ở Cloud Armor; alert/event đúng với nội dung request xuất hiện ở suricata-eve trên Logs Explorer.

3.3.4. Minh họa thử nghiệm

Kịch bản A – Tấn công bị chặn bởi Cloud Armor:

- Lệnh SQL Injection thử nghiệm:
 - `curl -i -sS -H "User-Agent: sqlmap/1.0" \ "http://34.110.231.252/index.php?id=1%27%20OR%20%271%27%3D%271"`



```
thangkb2024@thangkb2024:~$ curl -i -sS -H "User-Agent: sqlmap/1.0" \
  "http://34.110.231.252/index.php?id=1%27%20OR%20%271%27%3D%271"
HTTP/1.1 403 Forbidden
content-type: text/html; charset=UTF-8
Content-Length: 134
via: 1.1 google
date: Sat, 04 Oct 2025 16:53:10 GMT

<!doctype html><meta charset="utf-8"><meta name=viewport content="width=device-width, initial
-scale=1"><title>403</title>403 Forbiddenthangkb2024@thangkb2024:~$
```

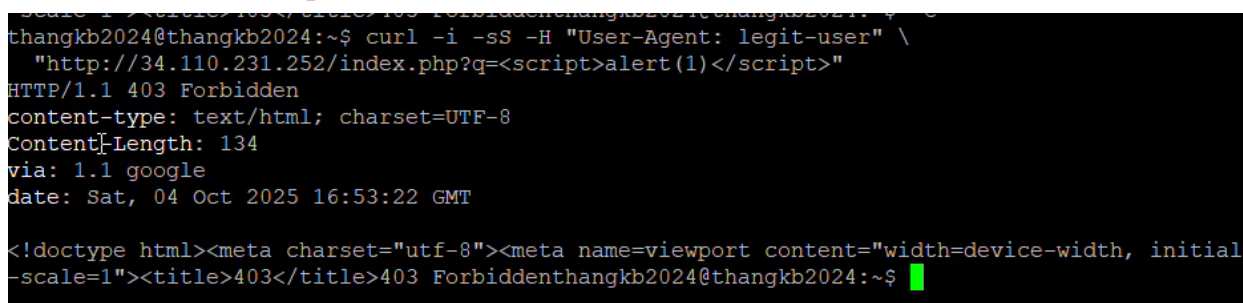
Hình 3.16: attacker tấn công và báo bị chặn SQLi

- Kết quả:
 - Cloud Armor chặn truy cập (HTTP 403).
 - Không xuất hiện log trên Suricata hay Web Server.
 - Log DENY ghi nhận tại Cloud Logging.



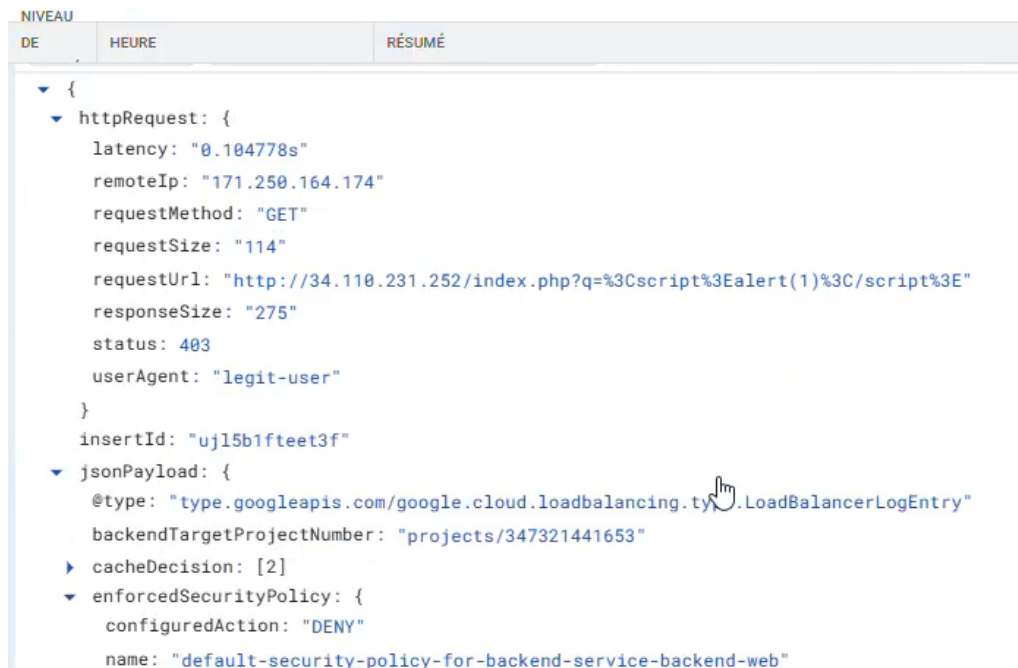
Hình 3.17: bản ghi log trong Cloud Logging ghi nhận request SQLi bị chặn bởi Cloud Armor.

- Lệnh XSS thử nghiệm:
 - `curl -i -sS -H "User-Agent: legit-user" \`
`"http://34.110.231.252/index.php?q=<script>alert(1)</script>"`



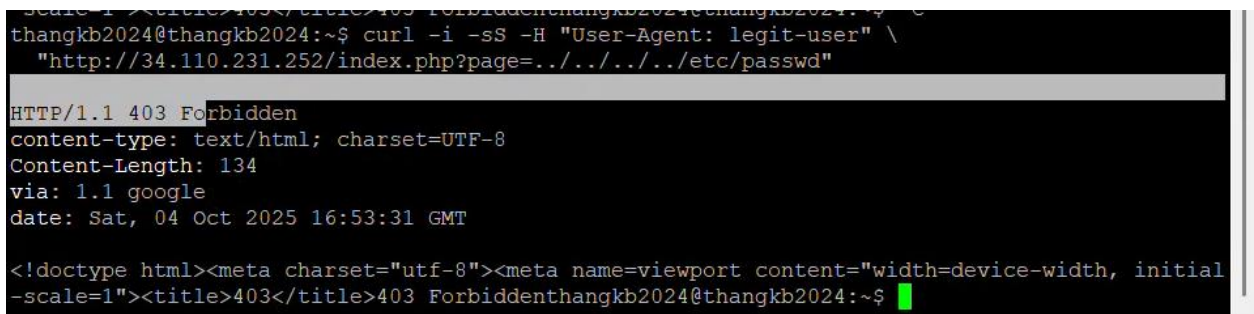
Hình 3.18: attacker tấn công và báo bị chặn XSS

- Kết quả:
 - Cloud Armor chặn truy cập (HTTP 403).
 - Không xuất hiện log trên Suricata hay Web Server.
 - Log DENY ghi nhận tại Cloud Logging.



Hình 3.19: bản ghi log trong Cloud Logging ghi nhận request XSS bị chặn bởi Cloud Armor.

- Lệnh LFI thử nghiệm:
 - `Curl -i -sS -H "User-Agent: legit-user" \`
`"http://34.110.231.252/index.php?page=../../../../etc/passwd"`



Hình 3.20: attacker tấn công và báo bị chặn LFI

- Kết quả:
 - Cloud Armor chặn truy cập (HTTP 403).
 - Không xuất hiện log trên Suricata hay Web Server.
 - Log DENY ghi nhận tại Cloud Logging.

```

{
  httpRequest: {
    latency: "0.104668s"
    remoteIp: "171.250.164.174"
    requestMethod: "GET"
    requestSize: "114"
    requestUrl: "http://34.110.231.252/index.php?page=../../../../etc/passwd"
    responseSize: "275"
    status: 403
    userAgent: "legit-user"
  }
  insertId: "7ju28efffq6cg"
  jsonPayload: {
    @type: "type.googleapis.com/google.cloud.loadbalancing.type.LoadBalancerLogEntry"
    backendTargetProjectNumber: "projects/347321441653"
  }
}

```

Hình 3.21 : bản ghi log trong Cloud Logging ghi nhận request LFI bị chặn bởi Cloud Armor.

Kịch bản B – Request hợp lệ (được phép)

- Lệnh hợp lệ thử nghiệm:
 - `curl -i -sS -H "User-Agent: legit-user" -d "username=user1&password=letmein" "http://34.110.231.252/login.php"`

```

2024:~$ curl -i -sS -H "User-Agent: legit-user" -d "username=user1&password=letmein" "http://34.110.231.252/login.php"
HTTP/1.1 404 Not Found
server: nginx/1.24.0 (Ubuntu)
date: Sat, 04 Oct 2025 16:56:33 GMT
content-type: text/html
Content-Length: 162
via: 1.1 google

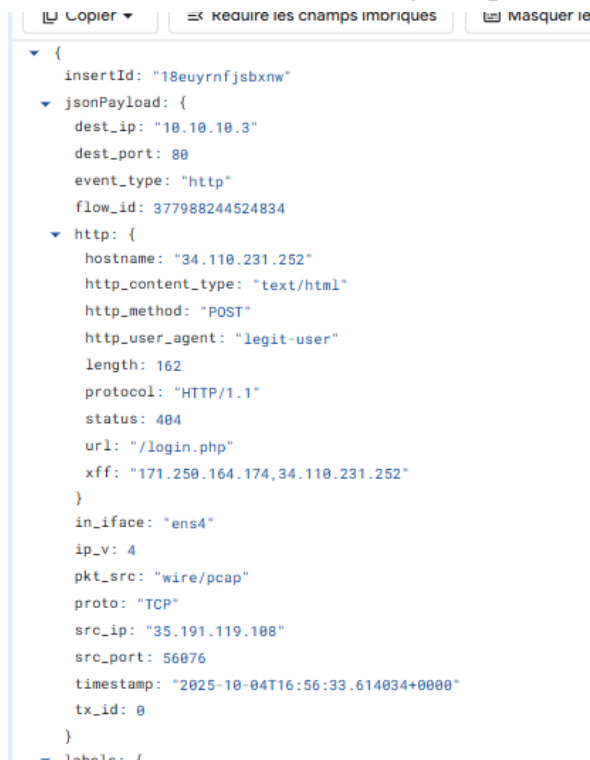
<html>
<head><title>404 Not Found</title></head>
<body>
<center><h1>404 Not Found</h1></center>
<hr><center>nginx/1.24.0 (Ubuntu)</center>
</body>
</html>

```

Hình 3.22: Người dùng sử dụng lệnh hợp lệ

- Kết quả:
 - Cloud Armor: ALLOW → Load Balancer forward request đến backend 10.10.10.3.
 - Packet Mirroring: sao chép lưu lượng của web server và gửi bản sao đến VM Suricata.

- Suricata: ghi nhận HTTP event (POST → /login.php), trường chính: http_method=POST, url=/login.php, http_user_agent="legit-user".
- X-Forwarded-For: jsonPayload.http.xff="171.250.164.174,34.110.231.252" → IP client thật = 171.250.164.174.
- Log lưu trữ trong Cloud Logging với logName = projects/secu-cloud-473814/logs/suricata-eve và hiển thị trên Logs Explorer.



Hình 3.23: bản ghi log trong Cloud Logging ghi nhận request được đẩy vào suricata-eve.

3.3.5. Kết quả và đánh giá

Tiêu chí	Kết quả quan sát	Nhận xét
Ngăn chặn tấn công	Cloud Armor chặn 100% request SQLi, XSS, LFI	Lớp phòng thủ biên hoạt động đúng chức năng
Giám sát nội bộ	Suricata sinh alert chính xác khi có traffic hợp lệ chứa chuỗi nghi ngờ	Cơ chế phản chiếu và giám sát ổn định
Lưu trữ log tập	Log từ Suricata và hệ thống	Đảm bảo tính toàn vẹn

trung	được đẩy lên Cloud Logging	và khả năng truy vết
Độ trễ phản hồi	Trung bình < 2s giữa thời điểm gửi và log xuất hiện	Đạt yêu cầu thử nghiệm

Bảng 3.3: tổng hợp kết quả đánh giá và thực nghiệm

3.3.6. Kết luận thực nghiệm

Kết quả thử nghiệm cho thấy mô hình hoạt động đúng nguyên lý phòng thủ đa lớp:

- Cloud Armor chặn tấn công từ biên, đảm bảo không cho lưu lượng độc hại vào hệ thống nội bộ.
- Suricata IDS giám sát thụ động toàn bộ traffic phản chiếu, phát hiện chính xác các hành vi bất thường.
- Cloud Logging tập trung log, tạo nền tảng cho phân tích sự cố và phát hiện sớm các tấn công phức tạp.

Mô hình đáp ứng tốt các tiêu chí: hiệu quả, ổn định, có khả năng mở rộng và phù hợp triển khai trong môi trường sản xuất thực tế.

3.4. Kết luận chương 3

3.4.1. Hiệu quả chức năng

Phòng ngừa tại biên (Cloud Armor): Các kịch bản tấn công ứng dụng phổ biến (SQLi, XSS, LFI) đều bị chặn ở lớp biên khi rule phù hợp được kích hoạt; điều này giảm đáng kể lưu lượng độc hại vào hệ thống nội bộ và giảm tải cho lớp giám sát.

Giám sát nội bộ (Suricata + Packet Mirroring): Khi lưu lượng hợp lệ được forward, Packet Mirroring cung cấp bản sao đầy đủ cho Suricata; Suricata phát hiện được các mẫu bất thường trong payload (ví dụ POST chứa pass=) và tạo bản ghi event/alert đưa lên Cloud Logging.

Ghi nhận tập trung (Cloud Logging): Log từ Suricata, VPC Flow Logs và Cloud Armor được tập trung, truy vấn được thông qua Logs Explorer và làm nguồn dữ liệu cho phân tích sau sự cố.

3.4.1. Độ tin cậy và vận hành

Hệ thống hoạt động ổn định trong các kịch bản thử nghiệm; độ trễ giữa event phát sinh và log xuất hiện ở Cloud Logging ở mức chấp nhận được cho mục đích giám sát.

Việc dùng X-Forwarded-For cho phép khôi phục IP client thực khi Load Balancer đóng vai trò proxy, hỗ trợ truy vết nguồn gây hại.

3.4.2. Hạn chế và rủi ro còn tồn tại

Nếu toàn bộ lưu lượng được mã hóa (HTTPS) mà không triển khai cơ chế giải mã TLS cho IDS, Suricata không thể phân tích payload ở lớp ứng dụng; TLS inspection có chi phí, phức tạp và rủi ro bảo mật (giữ khóa/tạm giải mã).

Một số tấn công tinh vi, tấn công 0-day hoặc tấn công qua kênh mã hóa có thể né tránh detection nếu rule/signature chưa cập nhật.

Việc mirror 100% traffic gây tiêu tốn băng thông và yêu cầu tài nguyên IDS cao khi ở quy mô lớn — cần cân nhắc sampling hoặc tăng cỡ máy khi đưa vào sản xuất.

3.4.3. Kiến nghị thực tế

Quản trị rule: Thiết lập quy trình cập nhật rule Suricata (Emerging Threats, local.rules) và policy Cloud Armor (managed rules) định kỳ; kiểm thử trước khi đưa vào production.

Tích hợp SIEM & phân tích: Kết nối Cloud Logging với SIEM (BigQuery/ELK/Chronicle/MISP) để phân tích lịch sử, correlation và threat intelligence enrichment.

Alerting & playbook: Xây dựng metric/alert cụ thể (ví dụ suricata_alert_count, http_4xx_rate) và playbook xử lý sự cố (triage, blocking dynamic, forensic).

TLS strategy: Đánh giá nhu cầu TLS inspection: nếu bắt buộc, triển khai giải pháp an toàn (ví dụ TLS proxy ở biên có quản trị khóa chặt chẽ) hoặc sử dụng endpoint/agent-based monitoring bổ sung.

Tối ưu hóa mirror: Ở môi trường lớn, cân nhắc sampling, filter theo port/protocol hoặc scale up IDS để cân bằng chi phí — ghi rõ policy mirror (ingress/egress, proto).

Retention & chi phí: Đặt chính sách retention phù hợp (logs short-term on Cloud Logging, archive long-term lên Cloud Storage/BigQuery) để cân bằng chi phí và tuân thủ yêu cầu pháp lý.

Kiểm thử định kỳ: Thực hiện red-team / penetration test định kỳ và benchmark load để đảm bảo policies không gây false-positive ảnh hưởng UX.

3.4.4. Tổng kết

Mô hình thử nghiệm đã chứng minh được tính khả thi của chiến lược defense-in-depth trên GCP: Cloud Armor giảm thiểu rủi ro đầu vào, Packet Mirroring + Suricata cung cấp khả năng quan sát sâu, và Cloud Logging đảm bảo bằng chứng tập trung cho điều tra. Với các cải tiến quản trị rule, tích hợp SIEM, và chiến lược xử lý TLS/chi phí như đề xuất, kiến trúc này sẵn sàng để mở rộng và áp dụng trong môi trường sản xuất với yêu cầu an ninh cao.

KẾT LUẬN

Trong bối cảnh cuộc cách mạng công nghiệp 4.0 và xu hướng chuyển đổi số đang diễn ra mạnh mẽ, điện toán đám mây đã trở thành nền tảng công nghệ không thể thiếu, mang lại sự linh hoạt, hiệu quả và khả năng mở rộng vượt trội cho các doanh nghiệp. Tuy nhiên, sự phụ thuộc ngày càng tăng vào môi trường đám mây cũng đi kèm với những thách thức và rủi ro bảo mật ngày càng phức tạp, đòi hỏi các tổ chức phải xây dựng những chiến lược phòng thủ vững chắc và toàn diện. Đề án “Nghiên cứu giải pháp đảm bảo an toàn dịch vụ trong điện toán đám mây cho doanh nghiệp” được thực hiện nhằm giải quyết bài toán này, từ việc hệ thống hóa cơ sở lý thuyết đến triển khai và kiểm chứng một mô hình bảo mật thực tiễn.

Qua quá trình nghiên cứu, đề án đã hoàn thành các mục tiêu và nhiệm vụ đã đề ra, với những kết quả cụ thể như sau:

Về mặt lý luận, đề án đã thành công trong việc xây dựng một bức tranh tổng quan và chi tiết về an toàn thông tin trong điện toán đám mây.

- Chương 1 đã hệ thống hóa các kiến thức nền tảng, từ lịch sử hình thành, các khái niệm cốt lõi, đến việc phân tích sâu sắc các mô hình triển khai (Public, Private, Hybrid) và mô hình dịch vụ (IaaS, PaaS, SaaS). Quan trọng hơn, chương này đã nhận diện và phân loại một cách có hệ thống các mối đe dọa và rủi ro an toàn đặc thù, bao gồm rủi ro từ kiến trúc ảo hóa, quản lý truy cập, bảo vệ dữ liệu và các lỗ hổng riêng biệt của từng mô hình dịch vụ. Đây chính là cơ sở khoa học vững chắc để đề xuất các giải pháp phù hợp trong chương tiếp theo.

Về mặt giải pháp, đề án đã đi sâu vào việc phân tích và đề xuất một hệ thống giải pháp bảo mật đa lớp (defense-in-depth), tuân thủ theo nguyên tắc chia sẻ trách nhiệm.

- Chương 2 đã trình bày một danh mục các giải pháp toàn diện, trải dài từ việc bảo vệ kiến trúc, quản lý danh tính và truy cập (IAM, MFA), mã hóa dữ liệu (at-rest và in-transit), đến việc xây dựng hệ thống giám sát và phát hiện đe dọa thông qua SIEM. Các giải pháp được tùy biến cho từng mô hình dịch vụ, giúp doanh nghiệp có cái nhìn rõ ràng về trách nhiệm và công cụ cần thiết. Việc phân tích mô hình thực tế của công ty Softel Solutions đã cung cấp một góc nhìn thực tiễn, làm nổi bật những ưu điểm và cả những thách thức trong việc vận hành một

hệ thống đám mây phức tạp, qua đó khẳng định sự cần thiết của một mô hình phòng thủ được kiểm chứng.

Về mặt thực tiễn, điểm nhấn quan trọng nhất của đề án là việc đã thiết kế, triển khai và đánh giá thành công một mô hình phòng thủ đa lớp trên nền tảng Google Cloud Platform (GCP).

- Chương 3 đã chứng minh tính khả thi và hiệu quả của kiến trúc được đề xuất. Mô hình kết hợp giữa các dịch vụ đám mây gốc (Google Cloud Armor, Packet Mirroring, Cloud Logging) và công cụ mã nguồn mở (Suricata IDS) đã hoạt động đúng như kỳ vọng: các cuộc tấn công phổ biến (SQL Injection, XSS, LFI) đã bị chặn đứng ngay tại lớp biên bởi WAF; đồng thời, các lưu lượng được phép đi vào bên trong đều được giám sát thụ động, giúp phát hiện các hành vi bất thường mà không ảnh hưởng đến hiệu năng hệ thống. Toàn bộ bằng chứng được ghi nhận tập trung, tạo nền tảng vững chắc cho việc điều tra, truy vết và phản ứng sự cố.

Tuy đã đạt được những kết quả tích cực, đề án cũng nhận thấy một số hạn chế và tiềm năng phát triển trong tương lai. Thách thức lớn nhất hiện nay là việc giám sát các lưu lượng được mã hóa (HTTPS/TLS) mà không làm ảnh hưởng đến hiệu năng và quyền riêng tư. Hơn nữa, các hệ thống dựa trên chữ ký như Suricata vẫn có thể bị vượt qua bởi các cuộc tấn công zero-day tinh vi.

Từ những kết quả và hạn chế trên, đề án xin đề xuất một số hướng phát triển trong tương lai:

- Tích hợp giải pháp Phân tích Hành vi Người dùng và Thực thể (UEBA): Bổ sung các thuật toán học máy để xây dựng mô hình hành vi "bình thường", từ đó phát hiện các bất thường và tấn công zero-day mà các quy tắc dựa trên chữ ký không thể nhận diện.
- Xây dựng cơ chế Điều phối, Tự động hóa và Phản ứng Bảo mật (SOAR): Phát triển các kịch bản (playbook) để tự động hóa quy trình phản ứng khi có cảnh báo từ hệ thống giám sát, chẳng hạn như tự động cập nhật tường lửa để chặn IP tấn công hoặc cô lập máy chủ bị xâm nhập, giúp giảm thiểu thời gian xử lý và sai sót của con người.
- Nghiên cứu chiến lược giải mã TLS (TLS Inspection): Đánh giá và triển khai các giải pháp giải mã lưu lượng an toàn tại biên để cho phép

hệ thống IDS/IPS có thể phân tích sâu hơn vào nội dung các gói tin đã mã hóa, nâng cao khả năng phát hiện mối đe dọa.

Tóm lại, đề án đã hoàn thành toàn diện các mục tiêu nghiên cứu, từ lý thuyết đến thực tiễn, và thành công chứng minh rằng một chiến lược phòng thủ đa lớp, kết hợp hài hòa giữa công nghệ, quy trình và con người, là yếu tố then chốt để đảm bảo an toàn cho các dịch vụ trên nền tảng điện toán đám mây. Các kết quả nghiên cứu và mô hình được triển khai trong đề án có thể được xem là một tài liệu tham khảo giá trị, một bản thiết kế vững chắc để các doanh nghiệp, đặc biệt là công ty Softel Solutions, có thể áp dụng và phát triển nhằm xây dựng một môi trường đám mây an toàn, tin cậy và bền vững.

TÀI LIỆU THAM KHẢO

- [1] Cloud computing, Virtualization, Hypervisor, Openstack – Wikipedia (wikipedia.org).
- [2] What is a private cloud? – Microsoft Azure (azure.microsoft.com).
- [3] Mell, P., & Grance, T. (2011). The NIST definition of cloud computing.
- [4] NIST (2011). US Government Cloud Computing Technology Roadmap. [https://www.nist.gov/system/files/documents/itl/cloud/SP_500_293_volume I-2.pdf](https://www.nist.gov/system/files/documents/itl/cloud/SP_500_293_volume_I-2.pdf)
- NIST (2011). The NIST Cloud Computing Reference Architecture. <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication500-292.pdf>
- [5] Dave Shackleford (2013). Fundamentals of Virtualization Security. In: Judy Flynn, (ed). Virtualization Security: Protecting Virtualized Environments, Canada: John Wiley, pp2-13.
- [6] Tim Mather, Subra Kumaraswamy, and Shahed Latif (2009). Cloud Security and Privacy: An Enterprise Perspective on Risks and Compliance. United states of America: O'Reilly Media, Inc: <<https://books.google.co.uk/books?id=BHazecOuDLYC&hl=vi>>
- [7] Monty McDougal (2007). VMWare Escape Publicized at SANSfire 2007. 28 July 2007. FOOL MOON BLOG.
- [8] S. Kumar, S. K. Singh, A. K. Singh, S. Tiwari and R. S. Singh, “Privacy-preserving security using biometrics in cloud computing,” Multimedia Tools and Applications, vol. 77, no. 9, pp. 11017–11039, 2018.
- [9] Y. Yan, L. Wu, G. Gao, H. Wang and W. Xu, “A dynamic integrity verification scheme of cloud storage data based on lattice and bloom filter,” Journal of Information Security and Applications, vol. 39, no. 11, pp. 10–18, 2018.
- [10] Q. Zhang, S. Li, Z. Li, Y. Xing, Z. Yang et al., “CHARM: A cost-efficient multi-cloud data hosting scheme with high availability,” IEEE Transactions on Cloud Computing, vol. 3, no. 3, pp. 372–386, 2015
- [11] R. Maeser, “Analyzing CSP trustworthiness and predicting cloud service performance,” IEEE Open Journal of the Computer Society, vol. 1, pp. 73–85, 2020.

[12] S. Rizvi, J. Mitchell, A. Razaque, M. R. Rizvi and I. Williams, “A fuzzy inference system (FIS) to evaluate the security readiness of cloud service providers,” *Journal of Cloud Computing*, vol. 9, no. 42, pp. 964, 2020.

[13] Isma Zulifqar, Sadia Anayat, Imtiaz Kharal “A Review of Data Security Challenges and their Solutions in Cloud Computing” Govt College Women University Sialkot, Pakistan Received: 12 August 2020; Accepted: 17 November 2020; Published: 08 June 2021.

[14] Open Web Application Security Project. (2021). *OWASP Top 10 2021*. Truy cập ngày 9 tháng 10 năm 2025, từ <https://owasp.org/Top10/>

[15] Open Information Security Foundation. (n.d.). *EVE JSON Output*. Suricata User Guide. Truy cập ngày 9 tháng 10 năm 2025, từ <https://suricata.readthedocs.io/en/latest/output/eve/index.html>

[16] The Suricata Project. (n.d.). *Suricata User Guide*. Truy cập ngày 9 tháng 10 năm 2025, từ <https://suricata.readthedocs.io/en/latest/>

[17] Proofpoint, Inc. (n.d.). *Emerging Threats Rulesets*. Truy cập ngày 9 tháng 10 năm 2025, từ <https://rules.emergingthreats.net/>

[18] Google Cloud. (n.d.). *Cloud Armor documentation*. Truy cập ngày 9 tháng 10 năm 2025, từ <https://cloud.google.com/armor/docs>

[19] Google Cloud. (n.d.). *Packet Mirroring overview*. Truy cập ngày 9 tháng 10 năm 2025, từ <https://cloud.google.com/vpc/docs/packet-mirroring>

[20] Google Cloud. (n.d.). *Cloud Logging documentation*. Truy cập ngày 9 tháng 10 năm 2025, từ <https://cloud.google.com/logging/docs>

[21] Google Cloud. (n.d.). *External HTTP(S) Load Balancing overview*. Truy cập ngày 9 tháng 10 năm 2025, từ <https://cloud.google.com/load-balancing/docs/https>

[22] Google Cloud. (n.d.). *VPC firewall rules overview*. Truy cập ngày 9 tháng 10 năm 2025, từ <https://cloud.google.com/firewall/docs/firewalls>

[23] NGINX, Inc. (n.d.). *Module ngx_http_log_module*. Truy cập ngày 9 tháng 10 năm 2025, từ http://nginx.org/en/docs/http/ngx_http_log_module.html

[24] The sqlmap Project. (n.d.). *sqlmap: automatic SQL injection and database takeover tool*. Truy cập ngày 9 tháng 10 năm 2025, từ <http://sqlmap.org/>